

Curso de Introdução ISO/IEC 27001

ISO/IEC 27001:2022

Sistema de Gestão da Segurança
da Informação



Objetivos do Curso

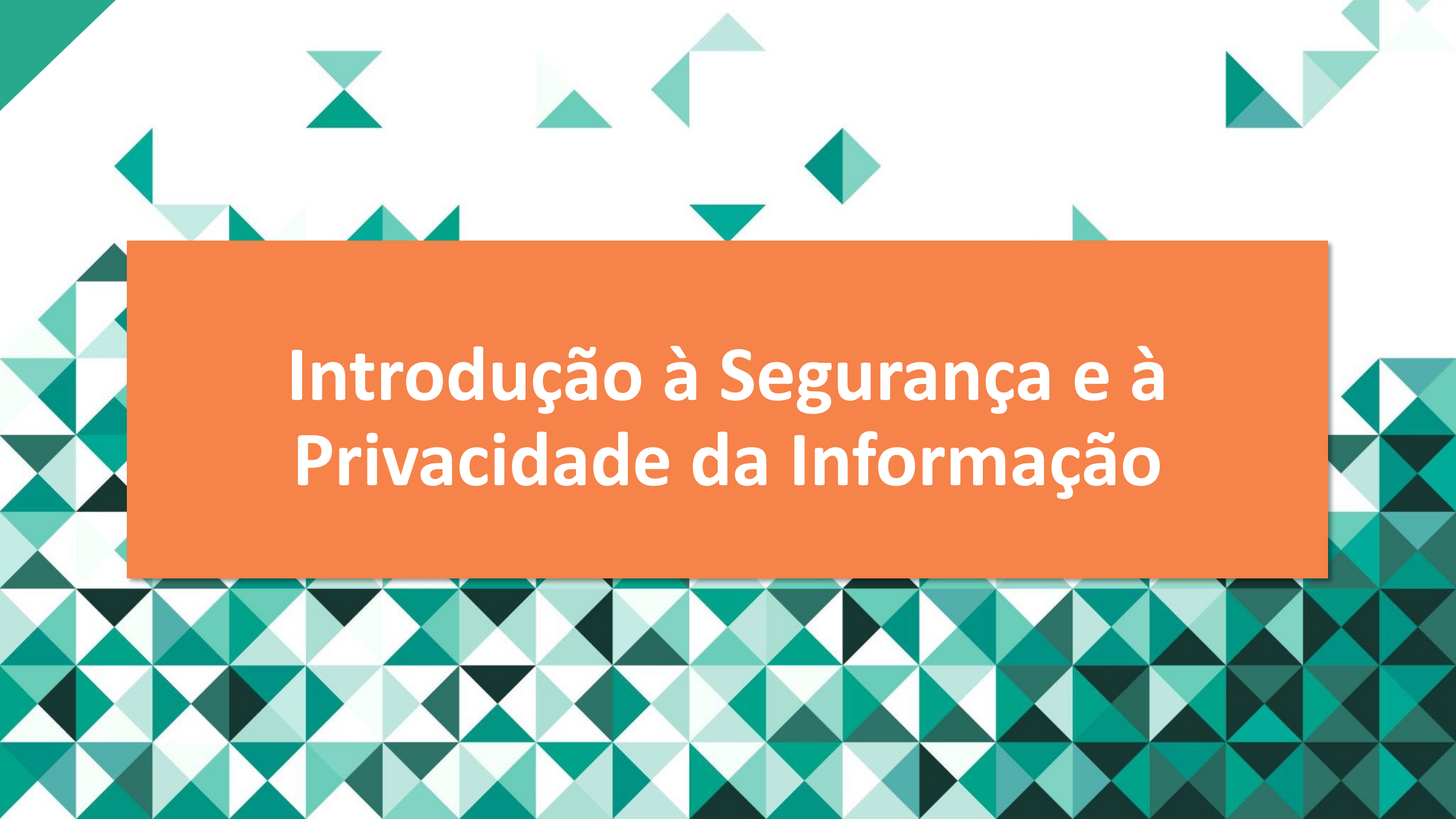
- Prover aos alunos um entendimento do porquê a SI e a PI são importantes no cenário atual
- Prover entendimento sobre os principais conceitos associados à gestão de SI e de PI
- Capacitar os alunos a entender e implementar os requisitos das Normas ICO/IEC 27001 em qualquer organização
- Capacitar os alunos a entender e implementar os controles estabelecidos no Anexo A da ISO/IEC 27001



Programa do curso

- Introdução e Apresentações
- Introdução à Segurança e à Privacidade da informação
- Conceitos Básicos
- A ISO e as Normas de Sistemas de Gestão
- Visão Geral da ISO/IEC 27001
- Interpretação da ISO/IEC 27001 – Requisitos
- Interpretação do Anexo A da ISO/27001 – Controles
- Estudo de caso
- Exercícios



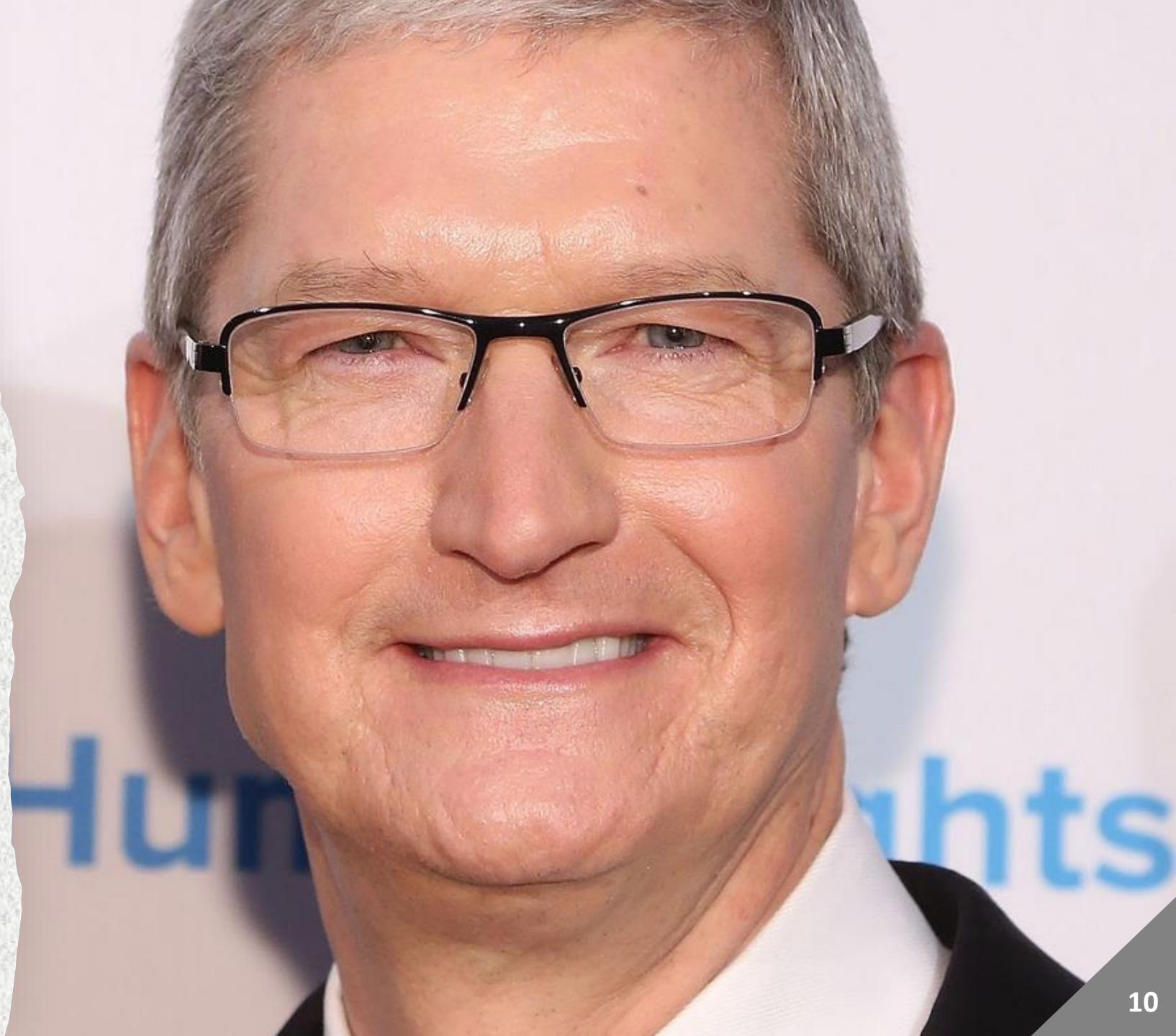


Introdução à Segurança e à Privacidade da Informação

“

Não devemos pedir aos nossos clientes que façam um equilíbrio entre privacidade e segurança. Precisamos oferecer-lhes o melhor de ambos. Em última análise, proteger os dados de outra pessoa é proteger a todos nós.

Tim Cook - Presidente da Apple



Por que **Segurança e Privacidade da Informação?**

- INFORMAÇÃO é um ativo essencial
- Impossível separar NEGÓCIOS e TECNOLOGIA
- Maior "acelerador" da transformação digital: COVID-19
- Aumento dos riscos à segurança
- Vigência da LGPD no Brasil



Informações são ativos **estratégicos**



SETOR DE ALIMENTOS

Cadeia crítica de suprimentos

Ataques terroristas



SETOR DE SAÚDE

Dispositivos médicos em rede

Dados sensíveis

Ameaças de hackers



SETOR QUÍMICO

Fórmulas de novos produtos

Espionagem industrial



SETOR FINANCEIRO

Rede global

Ameaças de hackers e ataques terroristas



SETOR DE SERVIÇOS E TECNOLOGIA

Propriedade intelectual

Disponibilidade

Engenharia Social



291 dados perdidos ou
roubados/ segundo

25 milhões por dia

2018: + de 5 bilhões de
dados comprometidos

Intensificação dos ataques



Prejuízos para as empresas

tecmodo

O que você procura?

Notícias

Últimas Notícias

Mais Lidas

Tutoriais

Colunas

Comparar

Cupons de Desconto

Teste de Velocidade

Maior oleoduto dos EUA pagou cerca de US\$ 5 milhões a hackers

18/05/2021 às 13:00 • 1 min de leitura



SHARE



tecmodo

O que você procura?

Notícias

Últimas Notícias

Mais Lidas

Tutoriais

Colunas

Comparar

Cupons de Desconto

Teste de Velocidade

JBS pagou R\$ 55 milhões em resgate de dados após ataque ransomware

10/06/2021 às 15:30 • 1 min de leitura



SHARE



Casos famosos de espionagem industrial



Querida, fraudei o crachá

Aconteceu em 2007, em Manaus: o gerente da qualidade da LG Electronics usou uma identidade falsa para entrar na unidade da Philips da Amazônia e ter acesso a detalhes sobre uma nova TV de LCD de 52 polegadas da concorrente. O caso foi parar na polícia.



Se está no lixo, não é de ninguém... certo?

Em 2001, a gigante P&G se envolveu em uma acusação bem suja: detetives contratados por ela foram flagrados mexendo no lixo da Unilever, buscando por informações de novas fórmulas capilares. Para evitar a justiça, a P&G pagou US\$ 10 milhões em um acordo.



Desceu quadrado

A Pepsi no Brasil criou em 1994 um plano estratégico confidencial para "partir pra cima" da Coca Cola. Só não contava que o concorrente tivesse acesso aos seus planos através de fitas de som gravadas. Isso inviabilizou o projeto, e a Pepsi acabou vendida...

Prejuízos para as pessoas

ECONOMIA

TECNOLOGIA

Megavazamento de dados de 223 milhões de brasileiros: o que se sabe e o que falta saber

Número é maior do que a população do país, estimada em 212 milhões, porque inclui dados de falecidos. Informações expostas incluem CPF, nome, sexo e data de nascimento, além de uma tabela com dados de veículos e uma lista com CNPJs. Origem dos dados ainda é desconhecida.

Por G1

28/01/2021 18h34 · Atualizado há 4 meses



N revistanews

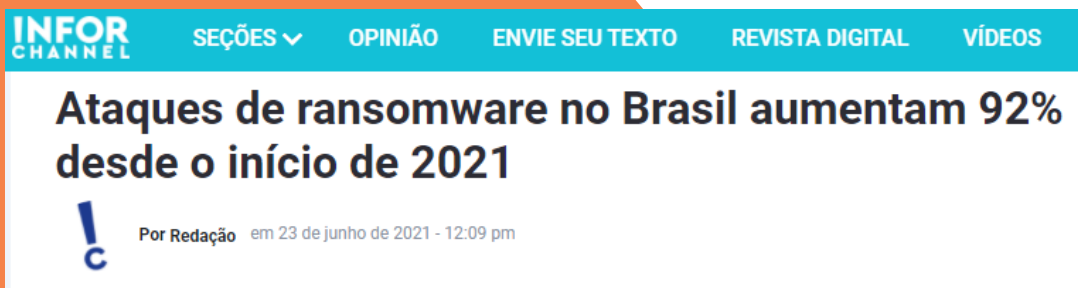
13 de agosto de 2021

[Início](#) | [Notícias](#) | [Maioria dos brasileiros já sofreu tentativa de fraude de seus dados pessoais](#)

Notícias

Maioria dos brasileiros já sofreu tentativa de fraude de seus dados pessoais

NEWS · 2 de julho de 2021



Sem cuidados,
ninguém está
protegido

Mas qual a origem dos ataques?



Governos

Em nome da
"Segurança
Nacional"



Pequenos grupos ou indivíduos

Buscam benefício
próprio; ou por
"uma causa"; ou
"por pura
diversão". São os
Hackers



Empresas

Espionagem
industrial.
Concorrentes
agindo "nas
sombras" para
obter vantagem
indevida



"Inside Job"

Funcionários
descontentes ou
recém demitidos
são fontes
comuns de
vazamento ou
roubo de dados

E o que é a **LGPD**?

Lei Geral de Proteção de Dados Pessoais

Atua na proteção dos interesses dos titulares (donos) de dados pessoais para evitar abusos por parte de controladores e operadores de dados

Lei Federal 13.709/2018



Você já parou
pra pensar em
quantos **dados**
pessoais seus
estão por aí?

Principais pontos da LGPD



Aplicabilidade

Empresas e pessoas físicas que realizam o **tratamento de dados pessoais** em qualquer meio (físico/ eletrônico)



Atores

Titulares dos dados
Controladores
Operadores
Encarregado
ANPD



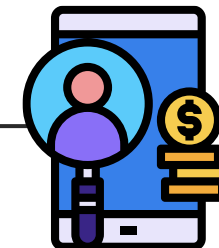
Bases Legais para Empresas

Consentimento
Execução de contratos
Legítimo interesse
Obrigações legais



Obrigações

Garantir os direitos do titular
Finalidade, forma e encerramento do tratamento
Proteção dos dados

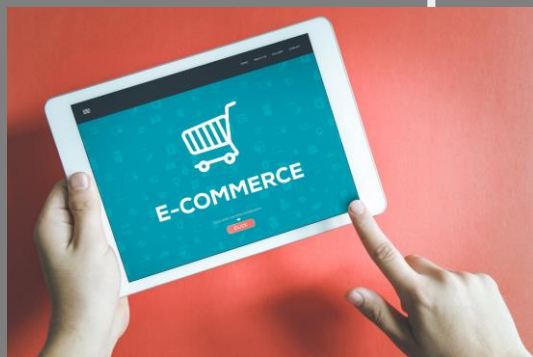


Sanções

Advertência
Multas
Bloqueio ou eliminação dos dados
Suspensão ou proibição do tratamento

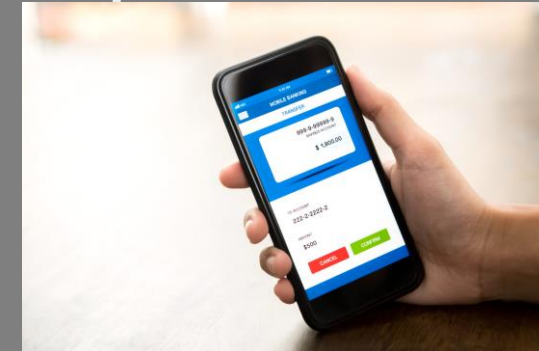


Cadastrando-se
na farmácia



Fazendo
compras on line

Será que os
controladores e
operadores
tratam
corretamente os
dados?



Usando o
internet banking



Candidatando-se
a um emprego

Consequências das falhas de segurança e privacidade



Danos à imagem e reputação

Facebook (2018)



Autuações e multas

Serasa - LGPD (2021)



Perdas financeiras

Colonial Pipeline (2021) e JBS (2021)



Suspensão ou encerramento

Playstation network (2011)

The background of the slide is a complex geometric pattern composed of various shades of teal and green triangles. These triangles are arranged in a way that creates a sense of depth and movement, with some triangles pointing towards the center and others pointing outwards. The pattern is most dense at the bottom and sides, with more sparse, floating triangles in the upper central area.

Conceitos Básicos

Segurança da informação é uma preocupação ancestral



Assírios (1.300 a.c. – 612 a.c)

Polícia secreta, o “Olho do Rei”

Homens disfarçados fazendo amigos
e se misturando à população –
buscando segredos

Levavam **informações** ao rei

Segurança da Informação

Proteção da

- Confidencialidade
- Integridade
- Disponibilidade

das informações



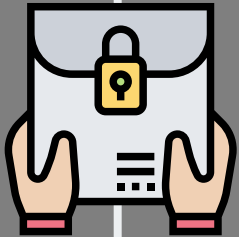
Privacidade da Informação

Proteção do

- Direito à liberdade e privacidade
- Direito ao livre desenvolvimento da personalidade

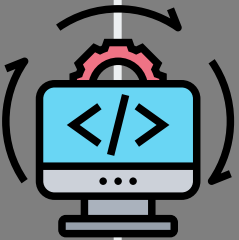
das pessoas naturais (titulares)

Elementos da Segurança da Informação



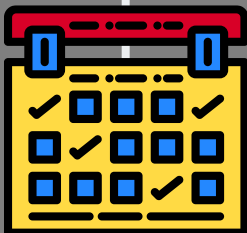
Confidencialidade

Propriedade da informação não ser tornada disponível ou divulgada a indivíduos, entidades ou processos não autorizados



Integridade

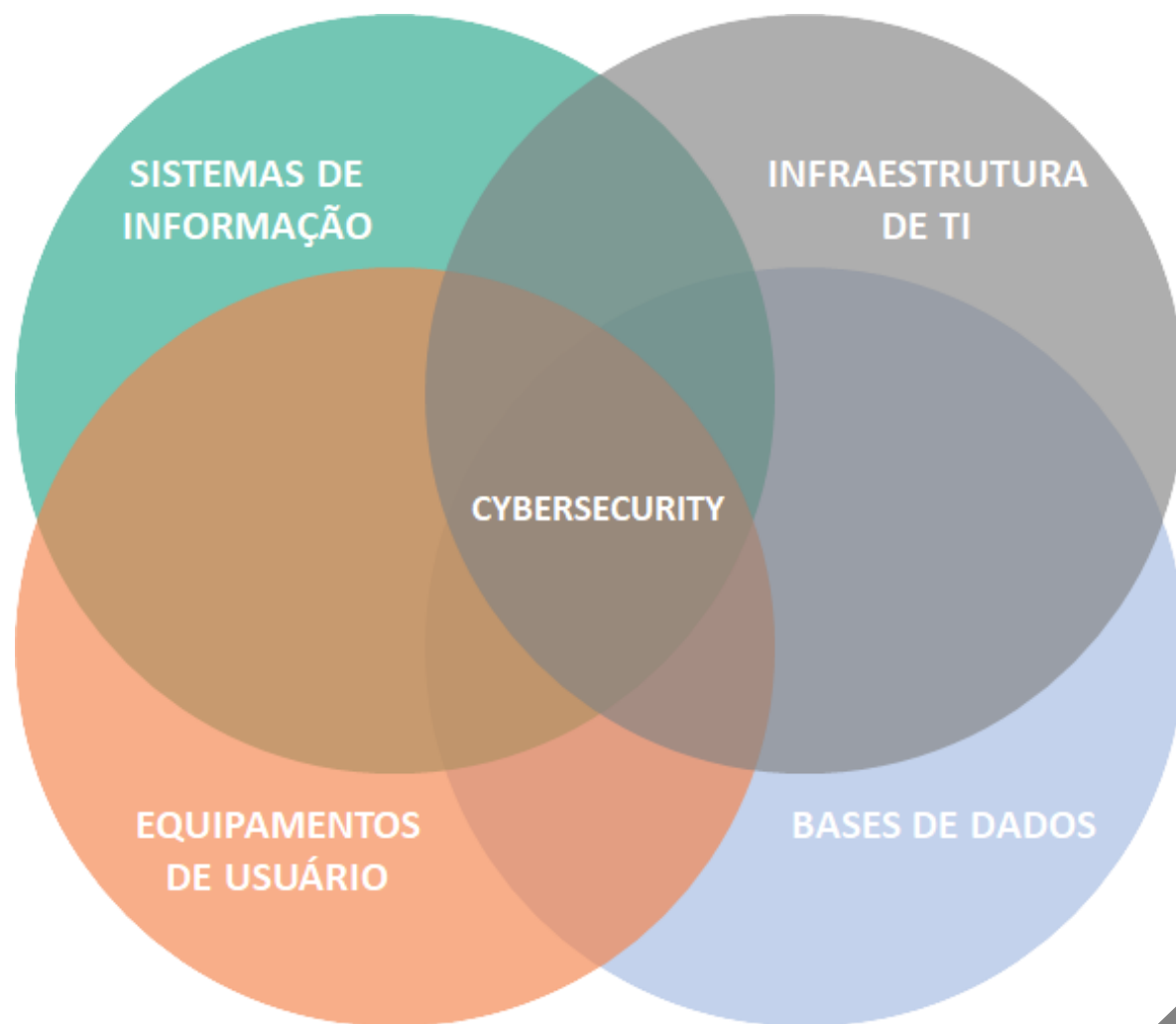
Propriedade de acuracidade e completeza da informação



Disponibilidade

Propriedade de a informação ser acessível e utilizável sob demanda de uma entidade autorizada

Segurança da Informação x Cybersecurity



SEGURANÇA DA INFORMAÇÃO

Modelo de gestão

É para a empresa toda

Avaliação global de riscos

Informações em qualquer mídia

Políticas corporativas

Políticas operacionais

Continuidade de negócios

Atendimento à legislação

Privacidade de dados

CYBERSECURITY

Focada no ambiente de tecnologia

Controle de acesso físico e lógico

Gestão de vulnerabilidades técnicas

Firewall, IDS/ IPS

Antivirus

Ferramenta de DLP

Backup e recuperação de desastres

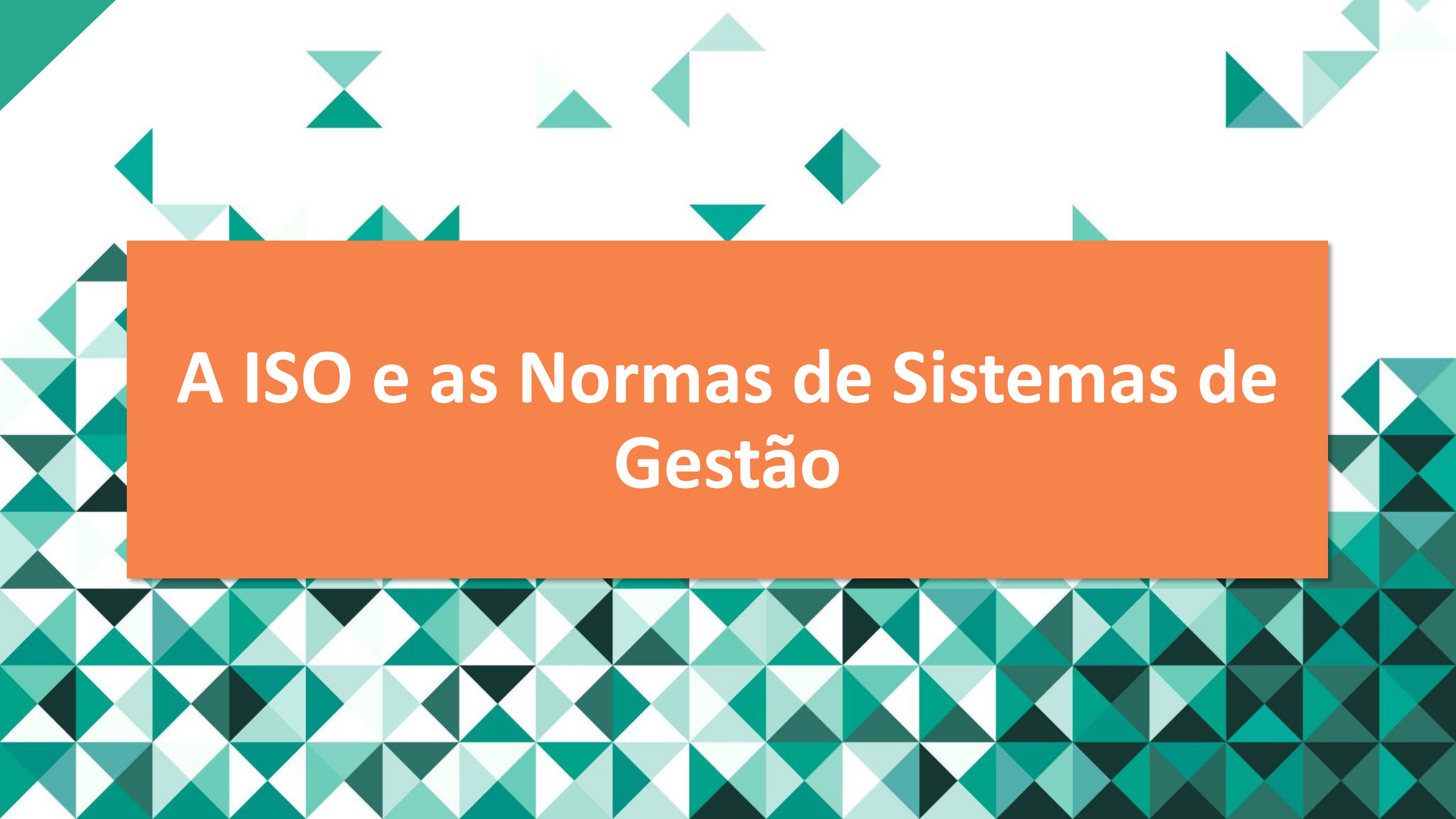
Gestão de incidentes de TI

O Papel da Segurança da Informação nas Organizações

Proteger os dados e informações é crucial

Muitas informações estratégicas e os dados pessoais de clientes, funcionários e fornecedores, se não protegidos, podem colocar em risco a operação de uma empresa. Por isso, segurança e Privacidade da informação são **programas inegociáveis!**



The background of the slide is a complex geometric pattern composed of various shades of teal and green triangles. Some triangles are solid, while others are outlined, creating a dynamic, low-poly aesthetic. The pattern is denser at the bottom and fades slightly towards the top.

A ISO e as Normas de Sistemas de Gestão



International
Organization for
Standardization

O Brasil participa
da ISO através da
ABNT – Associação
Brasileira de
Normas Técnicas

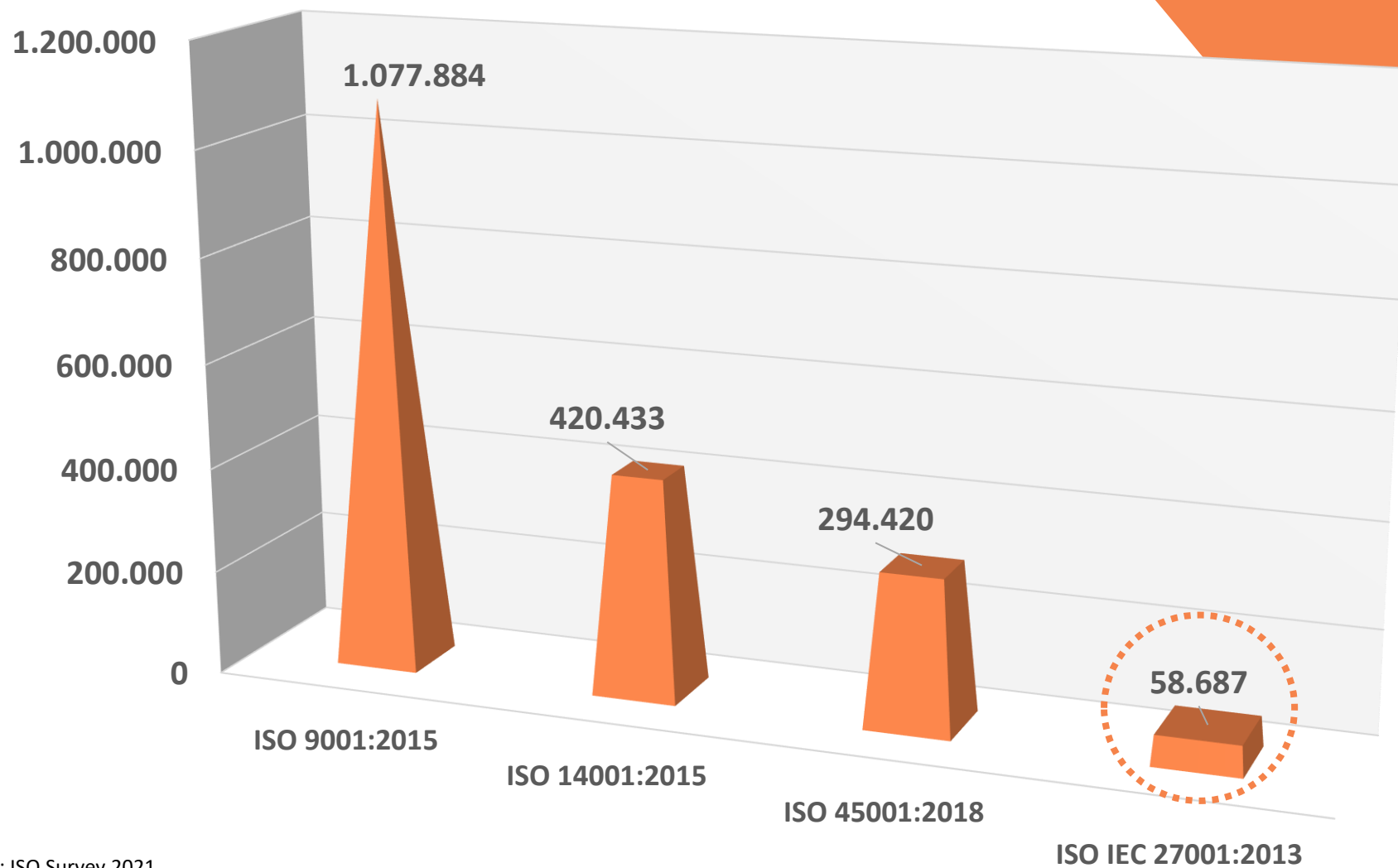
Fundada em 1947,
com sede em
Genebra, Suíça.

Seu papel é elaborar
Normas para
padronizar as mais
diversas áreas do
conhecimento

Fazem parte da ISO
mais de 100 países,
representando
mais de 95% da
economia mundial



Normas ISO mais utilizadas no mundo



Fonte: ISO Survey 2021

Benefícios da utilização de Normas ISO de gestão

- ✓ Padronizam os processos
- ✓ Estruturam os objetivos e indicadores
- ✓ Facilitam a troca internacional de bens e serviços
- ✓ Promovem o reconhecimento pelo mercado
- ✓ Estabelecem um *baseline* mínimo para a gestão
- ✓ Organizam e retém o conhecimento organizacional
- ✓ Criam ou reforçam uma disciplina para a gestão
- ✓ Estabelecem as bases para a capacitação interna e gestão de competências

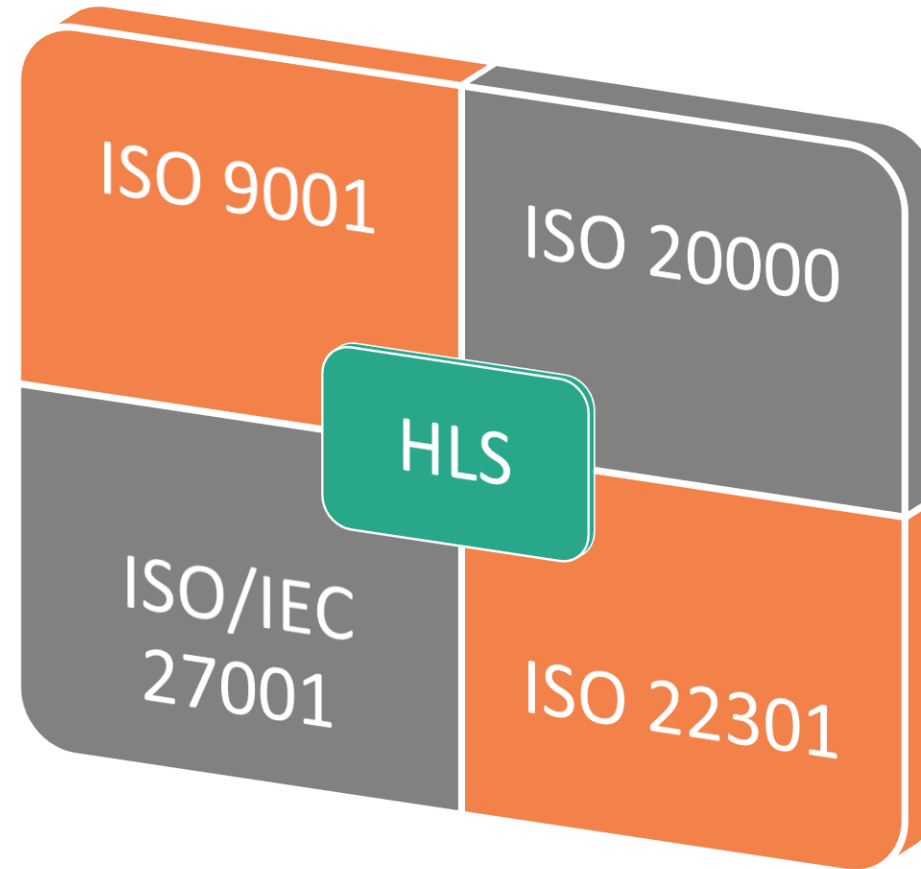


Estrutura de uma Norma ISO

HLS ou ANEXO SL:

Provê a estrutura comum a todas as normas de Sistemas de Gestão publicadas pela ISO.

- Termos e definições compartilhados
- Texto básico idêntico
- Números dos requisitos e cláusulas gerais comuns
- Cada Norma terá parágrafos e subcláusulas específicos de sua disciplina



4. Contexto da Organização

5. Liderança

6. Planejamento

7. Apoio (ou Suporte)

8. Operação

9. Avaliação do desempenho

10. Melhorias

O que é um Sistema de Gestão?

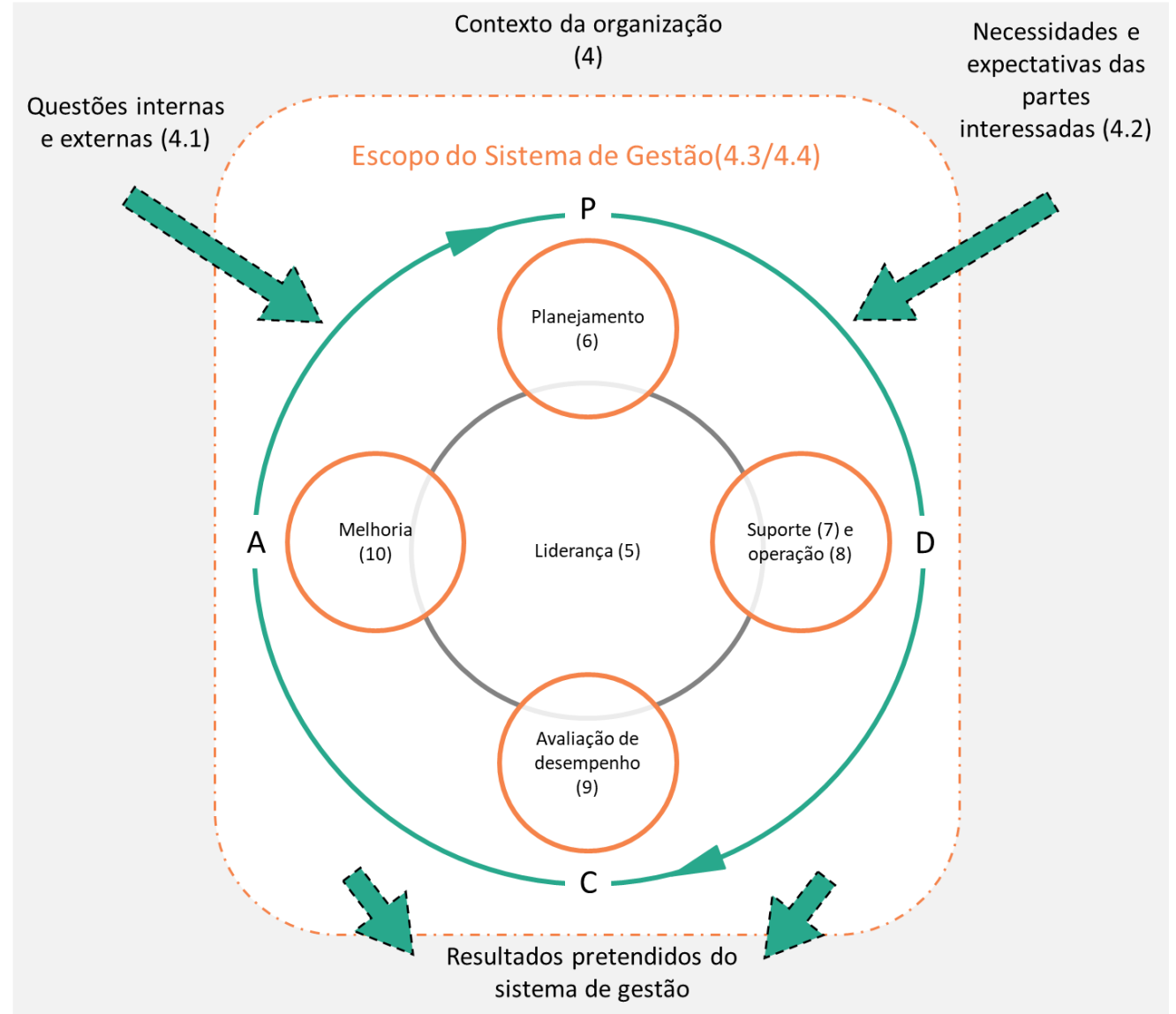
Conjunto integrado de **políticas, objetivos, práticas, procedimentos e processos** utilizados para dirigir e controlar uma **Organização** para o alcance dos seus objetivos

objetivos

resultados

Estrutura de Alto Nível

Modelo genérico de um sistema de gestão

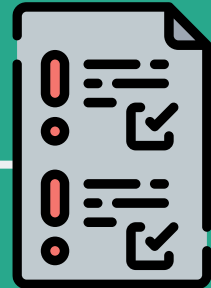


Base do SGSI e SGPI: Gestão de Riscos



Identificar

riscos associados com a perda de confidencialidade, integridade e disponibilidade as informações



Analisar

as potenciais consequências da materialização dos riscos e a probabilidade de que isso ocorra



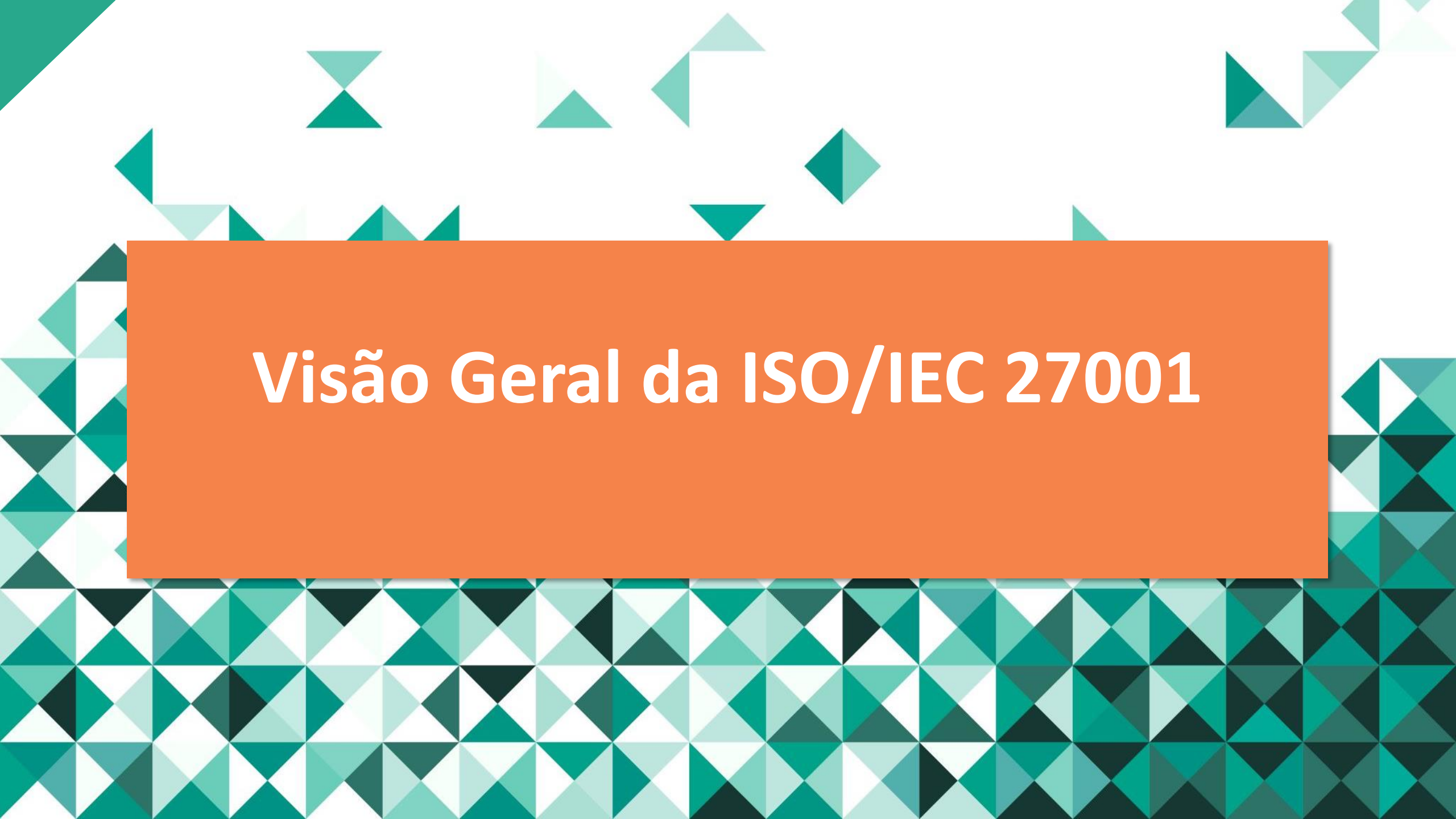
Avaliar

o nível de risco obtido contra critérios estabelecidos, priorizando os riscos para tratamento



Tratar

os riscos, selecionando e aplicando controles de segurança da informação e de privacidade de dados apropriados

The background of the slide is a complex geometric pattern composed of various shades of teal and green triangles and squares. A large, solid orange rectangle is centered on the slide, serving as a backdrop for the title text.

Visão Geral da ISO/IEC 27001

Há muito tempo atrás, em uma galáxia muito, muito distante...

1998
/99

BS 7799-1

Melhores práticas para gestão da segurança da informação

BS 7799-2

Sistemas de gestão de segurança da informação – especificação com orientações para o uso

2000

ISO/ IEC 17799

Tecnologia da informação – Código de prática para gestão da segurança da informação

2005

ISO/ IEC 27001

Tecnologia da informação – Técnicas de segurança – Sistemas de gestão da segurança da informação – Requisitos

2013

2ª edição

2022

3ª edição

Tecnologia da informação, cibersegurança e proteção da privacidade – Sistemas de gestão da segurança da informação – Requisitos

A família de Normas ISO/IEC 27000 (exemplos)

ISO/ IEC 27000

Visão Geral e Vocabulário

ISO/ IEC 27001

Sistemas de Gestão de Segurança da Informação – Requisitos

ISO/ IEC 27002

Controles de Segurança da Informação – Diretrizes

ISO/ IEC 27003

Sistemas de Gestão de Segurança da Informação – Diretrizes

ISO/ IEC 27004

Sistemas de Gestão de Segurança da Informação –
Monitoramento, medição, análise e avaliação – Diretrizes

ISO/ IEC 27005

Diretrizes para gestão de riscos de segurança da informação

ISO/ IEC 27017

Código de práticas para controles de segurança da informação
baseados na ISO/ IEC 27002 para serviços em nuvem

ISO/ IEC 27701

Extensão para a ISO/ IEC 27001 e ISO/ IEC 27002 para gestão da
privacidade da informação

Parte interessada

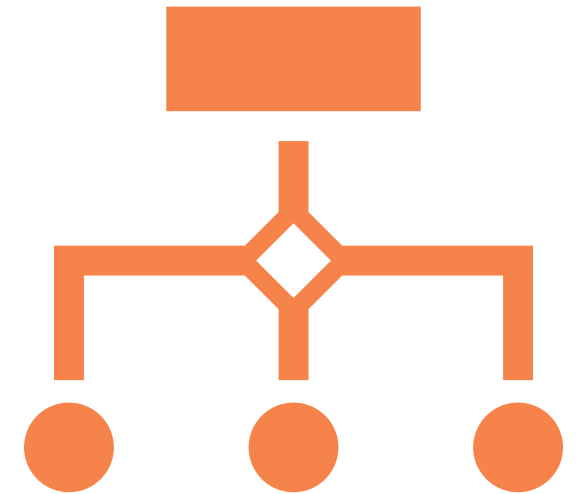
Pessoa ou organização que pode afetar, ser afetada ou se perceber afetada por uma decisão ou atividade.



ISO/ IEC 27000:2018

Alta Direção

Pessoa ou grupo de pessoas que dirigem e controlam uma organização em seu mais alto nível.



ISO/ IEC 27000:2018

Não-repúdio

Habilidade de provar a ocorrência de um evento ou ação e suas entidades de origem.



ISO/ IEC 27000:2018

Autenticidade

Propriedade de que uma entidade é aquilo que alega ser.



ISO/ IEC 27000:2018

Objetivo

Resultado a ser alcançado.

ESTRATÉGICO

TÁTICO

OPERACIONAL



ISO/ IEC 27000:2018

Gestão de Riscos

Atividades coordenadas para dirigir e controlar uma organização no que diz respeito ao risco.

Proprietário do risco

Pessoa ou entidade com responsabilidade e autoridade para gerenciar um risco.

ISO/ IEC 27000:2018



PII – Personal Identifiable Information

Qualquer informação que pode ser usada para identificar um titular de dados (*PII principal*) a quem a informação se relaciona ou que possa ser diretamente ou indiretamente associado a um PII principal.

PII Principal (titular de dados pessoais)

Pessoa natural a quem uma PII se relaciona.



PII Controler (controlador)

Entidade que determina os propósitos e os meios para tratar as PII além das próprias pessoas naturais que usam os dados para propósitos pessoais.

PII Processor (operador)

Entidade que trata as PII em nome de um controlador e de acordo com as instruções deste.

ISO/ IEC 29100:2011



Exemplos de PII

Nome completo



Dados de
documentos

Dados de
saúde

Estrutura da ISO/ IEC 27001:2022

1. Escopo
2. Referências normativas
3. Termos e definições
4. Contexto da organização
5. Liderança
6. Planejamento
7. Apoio para o SGS
8. Operação do SGS
9. Avaliação de desempenho
10. Melhoria

Anexo A

Bibliografia

Estrutura da ISO/ IEC 27701:2019

1. Escopo
2. Referências normativas
3. Termos, definições e abreviações
4. Generalidades
5. Requisitos específicos de PIMS para a ISO/ IEC 27001
6. Diretrizes específicas de PIMS para a ISO/ IEC 27002
7. Diretrizes adicionais da ISO/ IEC 27002 para controladores de PII
8. Diretrizes adicionais da ISO/ IEC 27002 para operadores de PII

Anexo A – Controles adicionais para controladores de PII

Anexo B – Controles adicionais para operadores de PII

Anexo C – Mapeamento para a ISO/ IEC 29100

Anexo D – Mapeamento para a GDPR

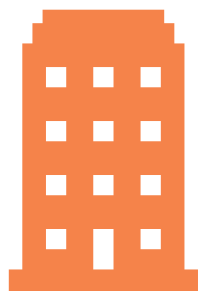
Anexo E – Mapeamento para a ISO/ IEC 27018 e ISO/ IEC 29151

Anexo F – Como aplicar a ISO/ IEC 27701 para a ISO/ IEC 27001 e ISO/ IEC 27002

Bibliografia

Controles de Segurança da Informação

Anexo A da ISO/IEC 27001:2022



**Controles
organizacionais**

(37 controles - grupo A.5)



**Controles de
pessoas**

(8 controles - grupo A.6)



Controles físicos
(14 controles - grupo A.7)



**Controles
tecnológicos**
(34 controles - grupo A.8)

93 controles potencialmente aplicáveis

Controles de Privacidade da Informação

Anexos A e B da ISO/ IEC 27701:2019

**ANEXO A: aplicável aos
CONTROLADORES DE PII**

**ANEXO B: aplicável aos
PROCESSADORES
(operadores) DE PII**

Condições para
Coleta e
Processamento

Obrigações para
com os Titulares

Privacidade desde o
Projeto e por
Padrão

Compartilhamento,
Transferência e
Divulgação

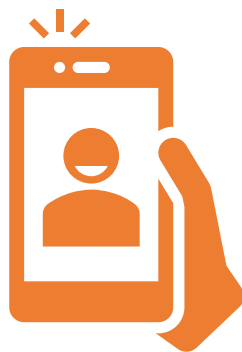
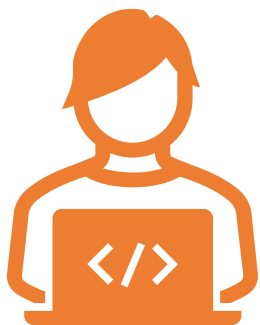


49 controles potencialmente aplicáveis

Para quem a ISO/ IEC 27001 e ISO/ IEC 27701 é mais indicada?

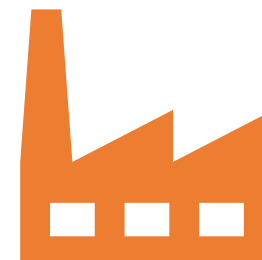
EMPRESAS DE TI

Protegendo suas próprias informações, seus produtos de tecnologia, seus clientes e os titulares de dados pessoais



EMPRESAS TRADICIONAIS

Protegendo suas próprias informações e os titulares de dados pessoais



Benefícios de um SGSI/ SGPI com base na ISO/ IEC 27001 e ISO/ IEC 27701



Aumento da resiliência organizacional



Redução dos riscos de segurança e privacidade



Reconhecimento independente



Redução dos riscos na cadeia de valor



Melhoria da imagem e reputação



Proteção da propriedade intelectual

Como implementar?



Comitê de Segurança e Privacidade

Fazer reuniões regulares



Avaliar e reavaliar riscos

Esteja atento às ameaças



Criar e cumprir políticas

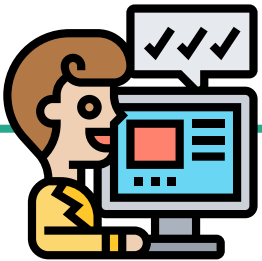
Regras estabelecidas na documentação



Treinar continuamente

O fator humano é o mais importante

Principais informações documentadas



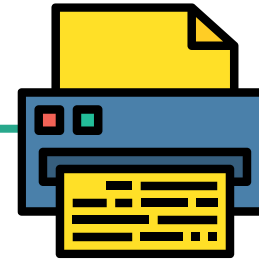
Uso Aceitável
dos Ativos



Classificação
da Informação



Controle de
Acessos



Mesa e tela
limpas,
impressão
segura



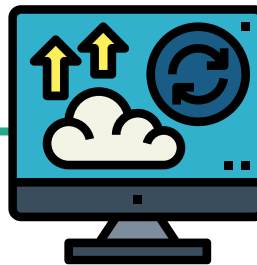
Antivirus



Criptografia e
comunicações
seguras



Desenvolvimento
de software
seguro



Backup e
restore



Gestão de
Incidentes



Continuidade
de Negócios

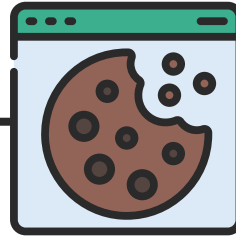
Principais informações documentadas



**Política de
Privacidade
Corporativa**



**Políticas de
Privacidade
dos Sites**



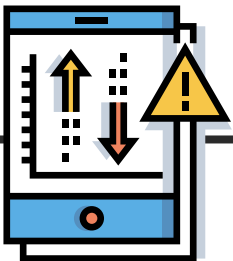
**Políticas de
Cookies**



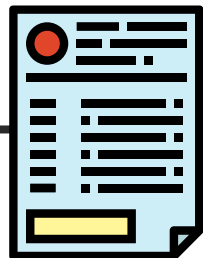
**Registro de
Operações de
Tratamento**



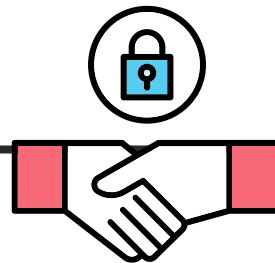
**Inventário
de Dados
Pessoais**



**Inventário de
Riscos de SI e
de PD**



**Declaração de
Aplicabilidade**



**Acordos de
Confidencialidade
e não-divulgação**



**Termos de
consentimento**



Contratos

The background of the slide is a complex geometric pattern composed of various shades of teal and green triangles and squares. A solid orange rectangular box is centered on the slide, containing the title text in white.

Implementando a ISO/ IEC 27001:2022 - Requisitos

Estrutura da ISO/ IEC 27001:2022

1. Escopo
2. Referências normativas
3. Termos e definições
4. Contexto da organização
5. Liderança
6. Planejamento
7. Apoio para o SGSI
8. Operação do SGSI
9. Avaliação de desempenho
10. Melhoria

Anexo A

Bibliografia

Como ler uma Norma ISO de Sistema de Gestão

A palavra/verbo **“DEVE”** significa uma obrigação a ser cumprida(requisito)

“É conveniente que” indica uma recomendação (diretriz).

“PODE” indica permissão, possibilidade ou capacidade

Uma cláusula JAMAIS deve ser lida e interpretada de forma isolada. Todos os requisitos/ cláusulas estão inter-relacionados.

Como interpretar as exigências de INFORMAÇÃO DOCUMENTADA:

“Estar disponível como informação documentada”

“Manter como informação documentada”

Deve existir um documento controlado conforme 7.5

“Reter informação documentada”

Deve existir um registro controlado conforme 7.5

“Manter informação documentada sobre os processos”

Deve existir um procedimento documentado controlado conforme 7.5

1. Escopo

A ISO 27001 especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação dentro do contexto da organização.

Também inclui requisitos para a avaliação e tratamento de riscos de segurança da informação.

Os requisitos são genéricos e podem ser aplicados a todas as organizações, independente do tipo, tamanho ou natureza.

Para fins de busca de conformidade ou certificação de conformidade, nenhum requisito das seções de 4 a 10 pode ser excluído.

2. Referências Normativas

ISO/IEC 27000, Information technology -- Security techniques --
Information security management systems -- Overview and vocabulary.



3. Termos e Definições

Ver ISO/ IEC 27000.

Outras terminologias:

- Plataforma de navegação ISO Online: disponível em <https://www.iso.org/obp>
- IEC Electropedia: disponível em <https://www.electropedia.org/>

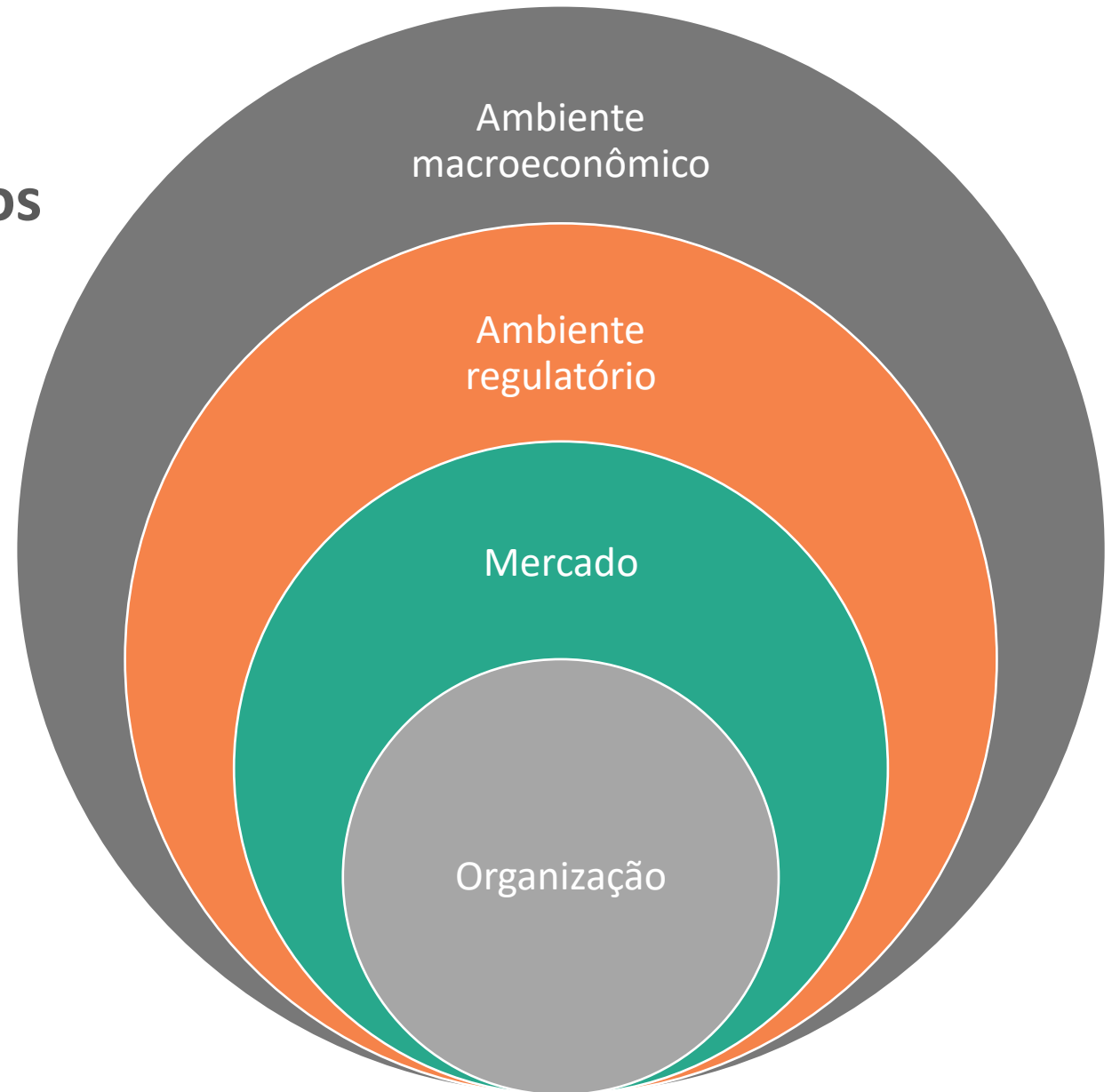


4 Contexto da Organização

- 4.1 Entendendo a organização e seu contexto
- 4.2 Entendendo as necessidades e expectativas das partes interessadas
- 4.3 Determinando o escopo do sistema de gestão da segurança da informação
- 4.4 Sistema de gestão da segurança da informação

4 Contexto da Organização

“O ambiente de negócios em que a Organização opera e como ele pode afetar o SGSI”

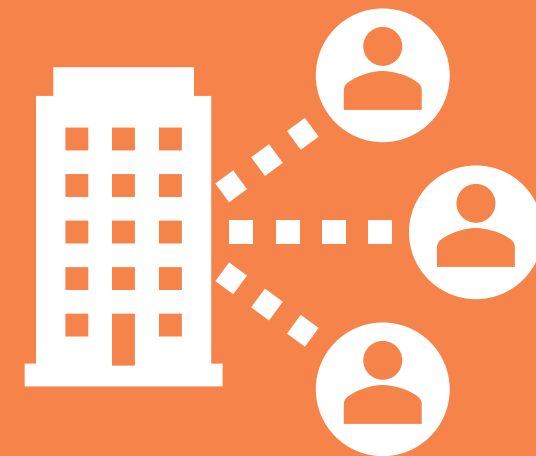


4 Contexto da Organização

4.1. Entendendo a organização e seu contexto

A organização deve determinar as questões internas e externas que são relevantes para o seu propósito e que afetam sua capacidade para alcançar os resultados pretendidos do seu sistema de gestão da segurança da informação.

NOTA: A determinação destas questões refere-se ao estabelecimento do contexto interno e externo da organização considerado na cláusula 5.4.1 da ISO 31000:2018.



Dicas de implementação:

Normalmente as Organizações já possuem um “modus operandi” para lidar com questões internas e externas. Isso pode ser um processo tácito ou formal. Exemplos:

- Análises do ambiente interno e externo (SWOT);
- Planejamento estratégico (mapas estratégicos, CANVAS e outros meios de formalização);
- Atas de reuniões de diretoria/ conselho.

Levar em consideração qualquer abordagem consciente da organização sobre como esses elementos podem afetar o SGSI – atentar que não há obrigatoriedade de existir informação documentada, embora seja uma boa prática.

4 Contexto da Organização

4.2 Entendendo as necessidades e expectativas das partes interessadas

Determinar:

- a) as partes interessadas que são relevantes para o sistema de gestão da segurança da informação;
- b) os requisitos relevantes dessas partes interessadas;
- c) quais desses requisitos serão atendidos por meio do sistema de gestão da segurança da informação.

NOTA: *Os requisitos das partes interessadas podem incluir requisitos legais e regulatórios, bem como obrigações contratuais.*



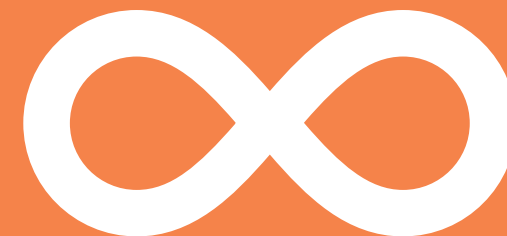
Dicas de implementação:

Partes interessadas típicas incluem: clientes externos; clientes internos; fornecedores; acionistas/ sócios; funcionários; direção executiva; terceirizados; órgãos reguladores; parceiros de negócio; etc. Estas partes interessadas podem afetar, ser afetadas ou se perceber afetadas pelas decisões da Organização com relação a SI.

- Tabelas identificando as partes interessadas, os seus requisitos em relação a SI e quais desses requisitos a Organização pretende atender.
- Mapeamento de partes interessadas.
- Os requisitos podem ser assumidos pela Organização; não há obrigação de manifestação explícita das PI.

4 Contexto da Organização

4.3 Determinando o escopo do Sistema de gestão da segurança da informação



Determinar os limites e a aplicabilidade do SGSI para estabelecer o seu escopo.

Ao determinar este escopo, a Organização deve considerar:

- a) As questões externas e internas referidas em 4.1
- b) Os requisitos referidos em 4.2
- c) As interfaces e dependências entre as atividades desempenhadas pela organização e aquelas que são desempenhadas por outras organizações.

O Escopo do SGSI deve estar disponível e ser mantido como informação documentada.

4 Contexto da Organização

4.3 Determinando o escopo do Sistema de gestão da segurança da informação

Exemplo de declaração de escopo válida:

“A Empresa XPTO S.A. aplica um Sistema de Gestão para proteger as informações relevantes para os seus negócios e aquelas associadas aos seguintes produtos e serviços:

- *Serviços de pentesting de aplicações e sistemas*
- *Serviços de scan de vulnerabilidades de redes computacionais*
- *Serviços de scan de vulnerabilidade de infraestrutura física*

Não está incluído neste escopo qualquer infraestrutura física de tecnologia provida por terceiros.”



Dicas de implementação:

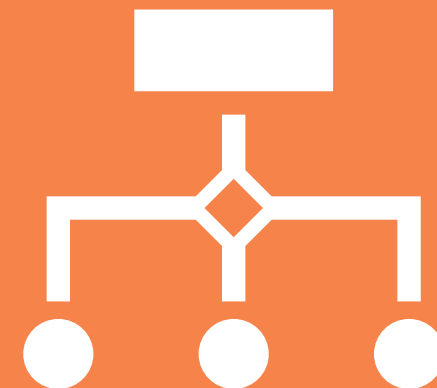
Determinar o escopo é essencial para delimitar o esforço de implementação do sistema de gestão.

- O Escopo deve ser declarado em um documento específico ou como parte integrante de um documento de alto nível (por exemplo, um Manual do SGSI);
- Pode estar em diferentes tipos de mídia, como documentos eletrônicos ou impressos, gravações de áudio e gravações de vídeo.

4 Contexto da Organização

4.4 Sistema de gestão da segurança da informação

A Organização deve estabelecer, implementar, manter e melhorar continuamente um SGSI, incluindo os processos necessários e suas interações, de acordo com os requisitos da ISO/IEC 27001.



Dicas de implementação:

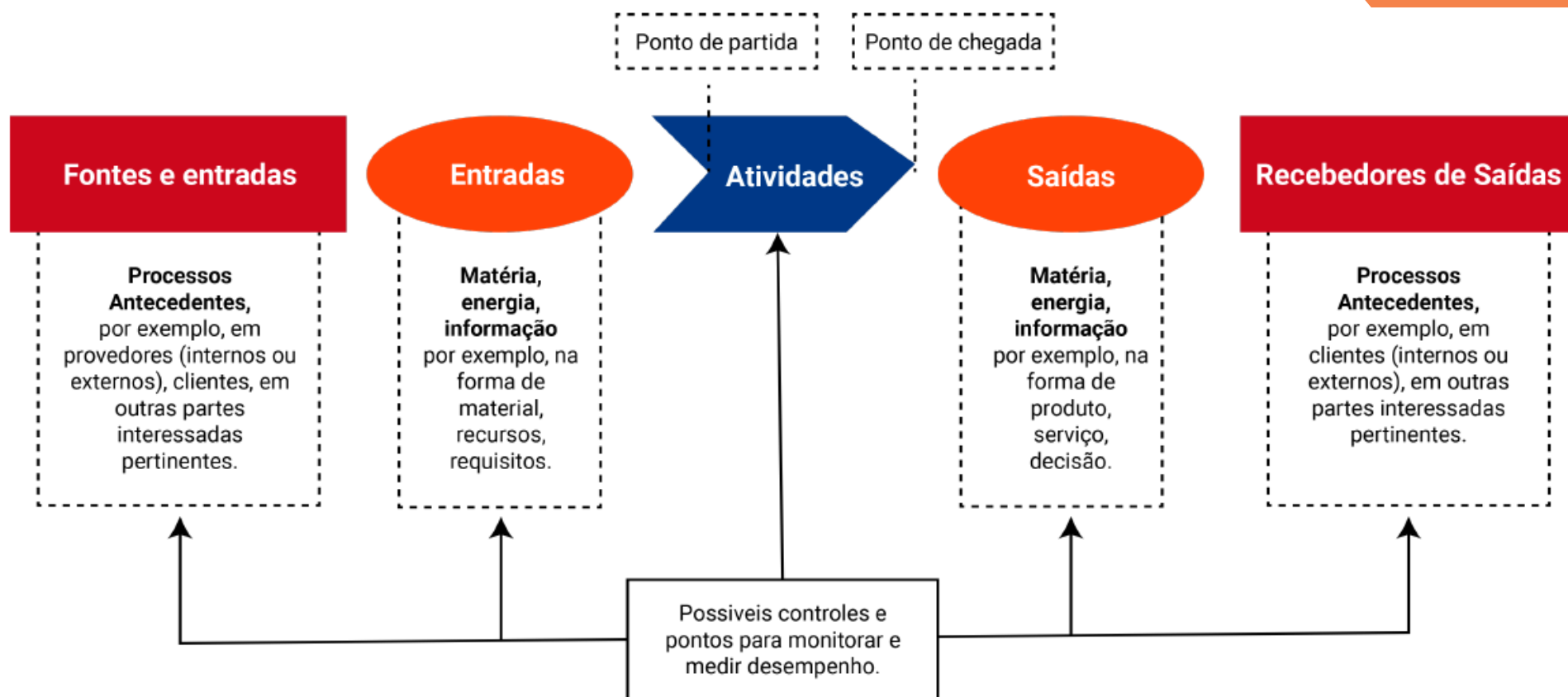
Partindo da definição de “sistema de gestão”, organize os processos relevantes para o SGSI; diferente de uma Norma como a ISO 9001 (que abrange todo o negócio), a ISO/IEC 27001 necessitará de parte dos processos organizacionais para ser bem sucedido. Boas práticas para documentar processos:

- Macrofluxo de processos, mapas de processos ou descritivos de processos declarados em documentos específicos ou como parte integrante de um documento de alto nível (por exemplo, um Manual do SGSI).
- Podem estar em forma gráfica ou textual, ou outros meios.
- Três ferramentas comuns para o mapeamento de processos:
 - Fluxogramas;
 - Diagrama de tartaruga;
 - SIPOC.

4 Contexto da Organização

4.4 Sistema de gestão da segurança da informação

Exemplo de mapa genérico de processo utilizando o SIPOC



5 Liderança

5.1 Liderança e comprometimento

5.2 Política

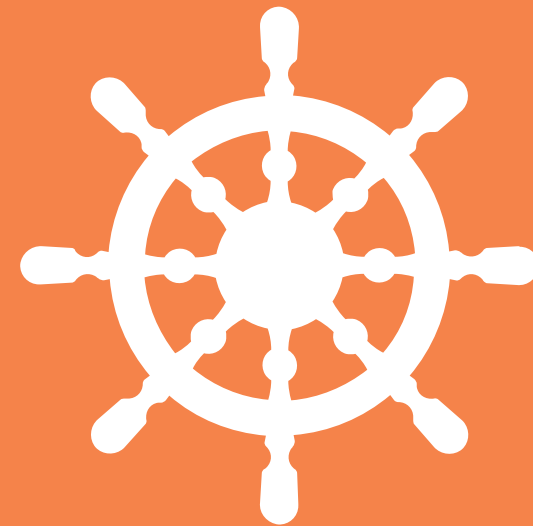
5.3 Papéis, responsabilidades e autoridades organizacionais

5 Liderança

5.1 Liderança e comprometimento

A alta Direção deve demonstrar liderança e comprometimento com relação ao SGSI, através de:

- a) assegurando que a política de segurança da informação e os objetivos de segurança da informação estão estabelecidos e são compatíveis com o direcionamento estratégico da organização;
- b) garantindo a integração dos requisitos do sistema de gestão da segurança da informação dentro dos processos da organização;
- c) assegurando que os recursos necessários para o sistema de gestão da segurança da informação estejam disponíveis;
- d) comunicando a importância de uma gestão eficaz da segurança da informação e da conformidade com os requisitos do sistema de gestão da segurança da informação;
- e) assegurando que o sistema de gestão da segurança da informação alcance os resultados pretendidos;
- f) orientando e apoiando pessoas para que contribuam para eficácia do sistema de gestão da segurança da informação;



5 Liderança

5.1 Liderança e comprometimento

A alta Direção deve demonstrar liderança e comprometimento com relação ao SGSI, através de (continuação):

g) promovendo a melhoria contínua; e

h) apoiando outros papéis relevantes da gestão para demonstrar como sua liderança se aplica às áreas sob sua responsabilidade.

NOTA: A referência a “negócios” neste documento pode ser interpretada de forma ampla para significar aquelas atividades que são essenciais para os propósitos da existência da organização.



Dicas de implementação:

Convém documentar em alto nível (por exemplo, no Manual do SGSI) os meios pelos quais a Alta Direção atende a cada item da cláusula 5.1, incluindo, mas não se limitando, a:

- Como a alta direção cria e aprova a política do SGSI;
- Como ela decide sobre e aprova recursos para implementação, manutenção e melhoria do SGSI (orçamentos para Opex e Capex, por exemplo);
- Como a Alta Direção determina as questões internas e externas relevantes para o SGSI e assegura a disseminação da cultura de SI nos processos da Organização;
- Envolvimento da Alta Direção nos processos de comunicação sobre temas relevantes para o SGSI (por exemplo objetivos do SGSI e resultados alcançados).

5 Liderança

5.2 Política



A Alta Direção deve estabelecer uma política de segurança da informação que:

- a) seja apropriada ao propósito da organização;
- b) inclua os objetivos de segurança da informação (ver 6.2) ou forneça uma estrutura para estabelecer os objetivos de segurança da informação;
- c) inclua um comprometimento para satisfazer os requisitos aplicáveis relacionados com segurança da informação; e
- d) inclua um comprometimento para a melhoria contínua do sistema de gestão da segurança da informação.

A política de segurança da informação deve:

- e) estar disponível como informação documentada;
- f) ser comunicada dentro da organização; e
- g) estar disponível para as partes interessadas, como apropriado.

5 Liderança

5.2 Política

Exemplo de declaração de política válida:

“A Empresa XPTO S.A. , atuando na prestação de serviços de segurança de aplicações, redes e infraestrutura de TI, assegura a proteção e a privacidade das informações utilizadas por ela, respeitando os seguintes princípios:

- *Cumprimento de todos os requisitos de segurança e privacidade da informação aplicáveis*
- *Promoção da melhoria contínua do sistema de gestão da segurança da informação*
- *Redução dos riscos de segurança da informação*
- *Maximização da disponibilidade das informações, sistemas e infraestrutura”*



Dicas de implementação:

A política exigida em 5.2 NÃO É a Política de Segurança da Informação (PSI) que as organizações normalmente elaboram para atender aos controles do Anexo A.

- A Política do SGSI pode estar declarada em um documento específico ou como parte integrante de um documento de alto nível (por exemplo, um Manual do sistema de gestão da segurança da informação) e pode estar em diferentes tipos de mídia, como documentos eletrônicos ou impressos, gravações de áudio e gravações de vídeo.
- Deve comunicada à sua força de trabalho através de diversos meios, como portais de intranet, e-mail, canais de redes sociais internas, etc e disponível no website institucional. O objetivo é ser fonte da disseminação da cultura de segurança.

Exemplo – Políticas do SGSI publicamente disponíveis

[Política Estratégica de Segurança da Informação | Neoway](#)

[Assertiva - Política de Segurança \(assertivasolucoes.com.br\)](#)

[Sobre Nós - DATAPROM](#)

[Juntos Somos + | Venha para a Juntos Somos Mais](#)

[politica_corporativa_si_cyber_pt.pdf \(bradescoseguranca.com.br\)](#)

5 Liderança

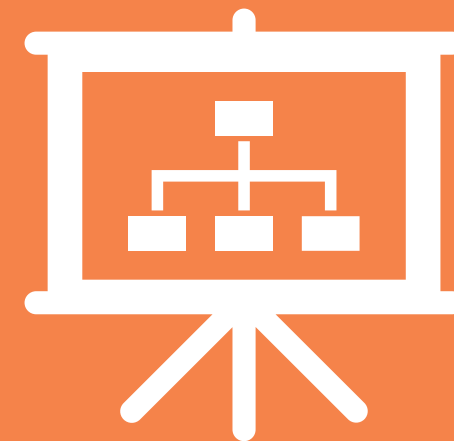
5.3 Papéis, responsabilidades e autoridades organizacionais

A Alta Direção deve assegurar que as responsabilidades e autoridades para papéis relevantes para o SGSI sejam atribuídas e comunicadas.

A Alta Direção deve atribuir responsabilidades e autoridades para:

- a) Assegurar que o SGSI esteja em conformidade com os requisitos da ISO 27001;
- b) Relatar o desempenho do SGSI para a Alta Direção.

NOTA: A Alta Direção pode também atribuir responsabilidades e autoridades para relatar o desempenho do sistema de gestão da segurança da informação dentro da organização.



Dicas de implementação:

Normalmente as organizações já possuem suas definições de responsabilidades e autoridades. Para o SGSI, deve-se procurar pelas atribuições específicas para SI. Podem existir funções dedicadas para SI (setores, times ou indivíduos) ou isso pode ser adicional às responsabilidades existentes. Convém que sejam documentadas em meios diversos como:

- Organogramas;
- Matrizes RACI;
- Documentação do SGSI (políticas, normas, procedimentos, instruções de trabalho, descrições de cargos, etc.).

Conhecimento sobre responsabilidades demonstrados pelas pessoas durante entrevistas de auditoria.

6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.1 Generalidades

6.1.2 Avaliação dos riscos de segurança da informação

6.1.3 Tratamento dos riscos de segurança da informação

6.2 Objetivos de segurança da informação e planos para alcançá-los

6.3 Planejamento de mudanças



O conceito de “pensamento baseado em risco” é novo?

Ou será que está tão internalizado em nossas vidas que nem percebemos que o praticamos...

**Tomamos decisões baseadas em riscos
todos os dias. O tempo todo. Na vida
pessoal e no trabalho.**

Alguém duvida?

E a qualidade das decisões tomadas assusta...

  **Gustavo**  @Gusttra · 20h

Se o seu dia foi ruim. Se você fez alguma bobagem, vacilou, deu algum mole... Se você se acha, por algum motivo, uma pessoa muito burra, estúpida, otária.
EU VOU SALVAR O SEU DIA! ...

 **tiquim quer casar com beck** @SnooPy0s_

To customizando Cartões de Crédito

Quem tiver interesse manda DM

- Nome completo
- CPF
- Número do cartão
- Data de validade
- CVV



3:19 PM · 27 de mai de 2019 · TweetDeck

8,3 mil Retweets · 20,1 mil Curtidas

 **Deyse Costa** 18 min

Deyse [redacted]
002.67 [redacted]
0987 2 [redacted]
11/28 [redacted]
376 [redacted]
QUERO DA MULHER MARAVILHA

Curtir Responder 21

 **Marcus Kamiya** 12 h

Marcus Kamiya Hisashi CPF 095 285.3 [redacted] Card
5201 [redacted] é
05/2021 CVV 587 Quero do Homem de Ferro

Curtir Responder 220

 **Rafaela Bittencourt** r... · 45 respostas

6:41 · 30 mai 19 · Twitter Web Client



Em negócios, identificar, avaliar e controlar riscos é crucial.

Isso pode acontecer em diversos níveis, assumir diversas formas, ser mais ou menos complexo e envolver poucas ou muitas pessoas.



RISCOS
DE SEGURANÇA
DA INFORMAÇÃO



Conceitos em gestão de riscos

Risco

Efeito da incerteza sobre os objetivos



Tolerância ao Risco

Quanto risco posso ter?

Nível de Risco

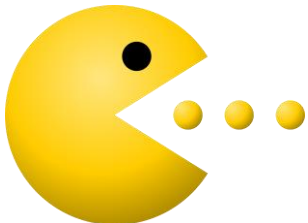
Quanto risco tenho?

Apetite ao Risco

Quanto risco eu quero ter?

Apetite ao Risco

Quantidade de risco que alguém está disposto a tomar para alcançar seus objetivos.



Apetite ao Risco x Tolerância ao Risco

O caso do viciado em apostas

apetite ao risco > tolerância ao risco

Percepção de risco

a capacidade de *enxergar* o risco

Valores/
experiência

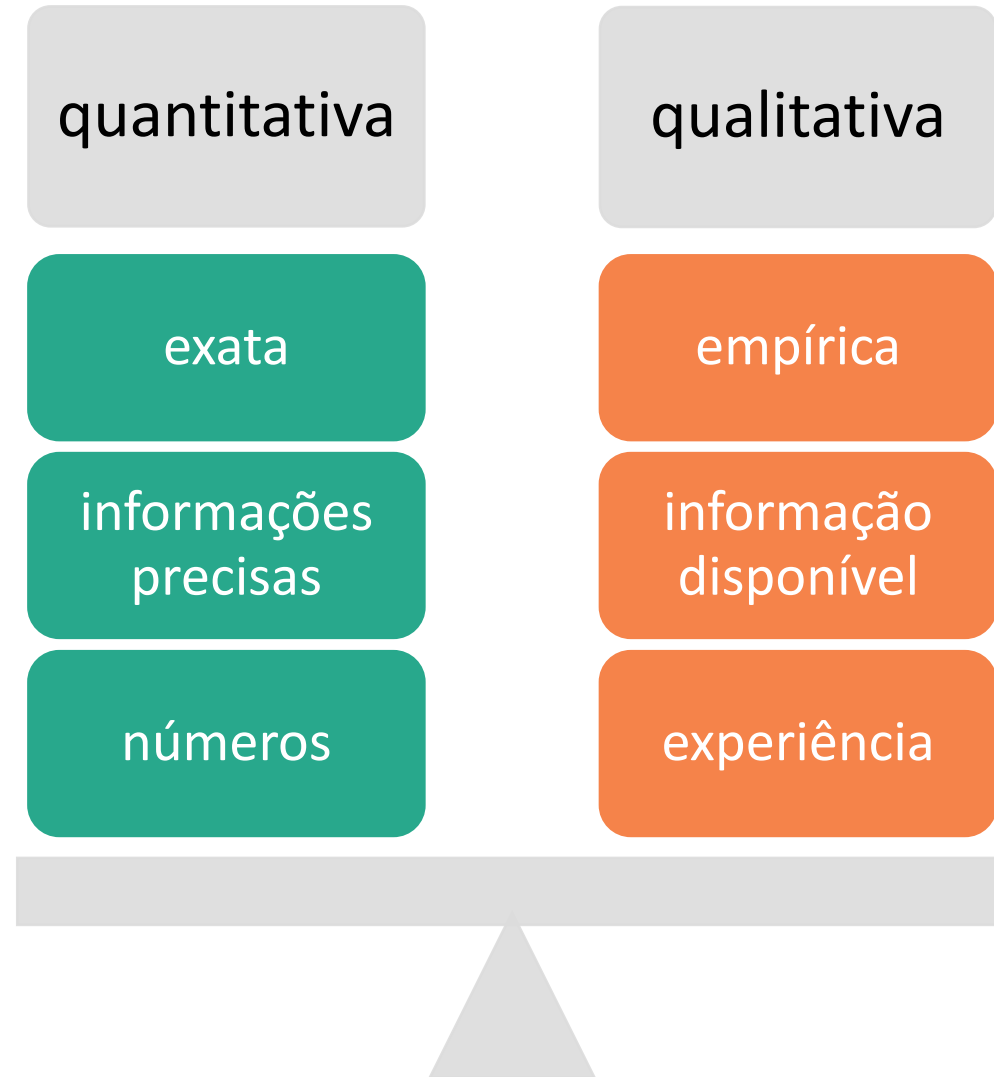
Momento
atual

Informação
disponível

Como melhorar nossa capacidade de tomar decisões



Tipos de análise de riscos



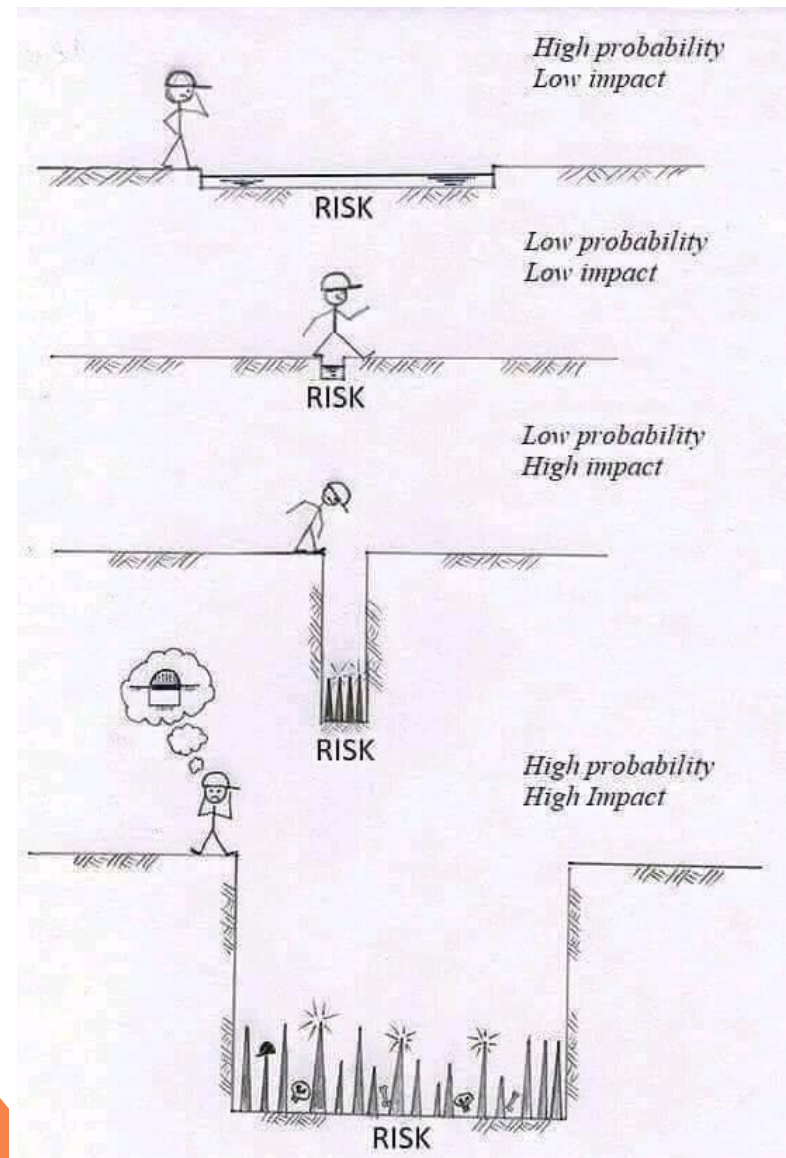


ATENÇÃO

O objetivo da gestão de riscos não é proibir a tomada de “decisões arriscadas”.

É permitir que isso possa ser feito com consciência e responsabilidade.

Resumindo:



6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.1 Generalidades

Quando do planejamento do sistema de gestão da segurança da informação, a organização deve considerar as questões referenciadas em 4.1 e os requisitos descritos em 4.2 e determinar os riscos e oportunidades que precisam ser considerados para:

- a) assegurar que o sistema de gestão da segurança da informação pode alcançar seus resultados pretendidos;
- b) prevenir ou reduzir os efeitos indesejados; e
- c) alcançar a melhoria contínua.

A organização deve planejar:

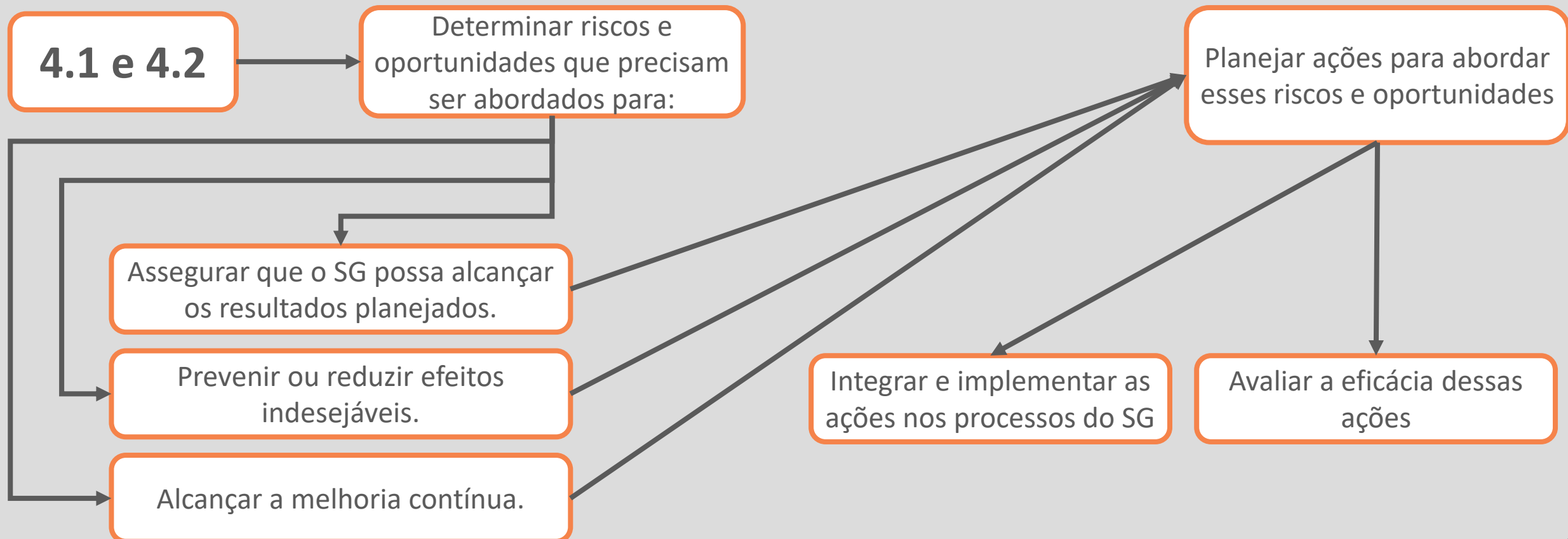
- d) as ações para considerar estes riscos e oportunidades; e
- e) como:
 - 1) integrar e implementar estas ações dentro dos processos do seu sistema de gestão da segurança da informação; e
 - 2) avaliar a eficácia destas ações.



6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.1 Generalidades



6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.1 Generalidades

Exemplo de boa prática de atendimento – Ligando 4.1 ao 6.1.1

I/E	Questão	R/ O	Ação	Prazo	Status
I	Infraestrutura de TIC	O	Manter ações do time infra para assegurar disponibilidade	Contínuo	Em andamento
I	Cultura de conscientização em segurança da informação	R	Conscientização via plataforma Hacker Rangers	Jan/2020	Em andamento
I	Melhoria da segurança da informação	O	Contratação de consultorias para projetos de expansão/ certificação	2º Sem/19	Concluído
I	Situação da governança interna	R	Realização das certificações e auditorias SI; Financeira; Compliance	2º Sem/20	Em andamento
I	Custo fixo operacional das ferramentas de SI	O	Redução do custo operacional via análise de despesas	Nov/2019	Concluído
I	Fragilidades de segurança física	R	Aquisição e instalação de sistema de controle de acesso	Fev/2020	Em andamento
E	LGPD – Lei Geral de Proteção de Dados	R	Realizar adequações com consultoria	1º Sem/20	Em andamento
E	Ataques externos ao ambiente (site/ blog/ plataforma)	R	Contratação de serviços/ parceiro para gestão de vulnerabilidades técnicas	Set/2019	Concluído

6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.1 Generalidades

Exemplo de boa prática de atendimento – Ligando 4.2 ao 6.1.1

Parte interessada	Requisitos (afetando SI)	R/ O	Ação	Prazo	Status
Clientes	Serviços prestados com segurança (assegurar CID)	O	Análise crítica e revisão periódica	Semestral	Em andamento
		R	Gestão da capacidade de processamento (AWS) – monitorar serviço	Contínuo	Em andamento
Funcionários	Proteção das informações pessoais e de familiares fornecidas à Empresa.	R/O	Atendimento aos requisitos da LGPD	1º Sem/ 22	Concluído
Acionistas	Proteção da imagem e reputação da Organização e dos seus acionistas.	R/O	Obtenção das certificações ISO 27001 e ISO 27701; Adequação LGPD	1º Sem/23	Em andamento
		O	Adequação para homologação cadastro positivo	1º Sem/22	Em andamento
Fornecedores (serviços de software)	Continuidade dos serviços e proteção das informações de propriedade intelectual do fornecedor e sigilo de propostas comerciais.	R	Definição de um “dono” para cada serviço de assinatura visando evitar interrupções de serviço); Acordos de confidencialidade; conscientização	2º Sem/19	Concluído
Fornecedores (hospedagem cloud)	Proteção das informações de propriedade intelectual do fornecedor e sigilo de propostas comerciais	O	Acordos de confidencialidade; conscientização	Contínuo	Em andamento
Governo Federal (Marco Civil da Internet e LGPD)	Cumprimento da legislação referente à proteção de dados pessoais e outras relacionadas a TI e segurança da informação	R/O	Adequação à legislação LGPD e certificações ISO 27001 e ISO 27701	1º Sem/23	Em andamento
Imprensa	Informações transparentes para o mercado e público em geral	O	Contratação de assessoria de imprensa para relacionamento com a mídia	2º Sem/22	Concluído

6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.2 Avaliação dos riscos de segurança da informação

A organização deve definir e aplicar um processo de avaliação de riscos de segurança da informação que:

- a) estabeleça e mantenha critérios de riscos de segurança da informação que incluam:
 - 1) os critérios de aceitação do risco; e
 - 2) os critérios para desempenhar as avaliações dos riscos de segurança da informação;
- b) assegure que as repetidas avaliações de riscos de segurança da informação produzam resultados consistentes, válidos e comparáveis;
- c) identifique os riscos de segurança da informação:
 - 1) aplicando o processo de avaliação dos riscos de segurança da informação para identificar os riscos associados com a perda de confidencialidade, integridade e disponibilidade da informação dentro do escopo do sistema de gestão da segurança da informação; e
 - 2) identifique os responsáveis pelos riscos.



6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.2 Avaliação dos riscos de segurança da informação (continuação)

d) analise os riscos de segurança da informação:

- 1) avaliando as consequências potenciais que podem resultar se os riscos identificados em 6.1.2 c) 1) forem materializados
- 2) avaliando a probabilidade realística da ocorrência dos riscos identificados em 6.1.2 c) 1); e
- 3) determinando os níveis de risco;

e) avalie os riscos de segurança da informação:

- 1) comparando os resultados da análise dos riscos com os critérios de riscos estabelecidos em 6.1.2 a); e
- 2) priorizando os riscos analisados para tratamento.

A Organização deve reter informação documentada sobre o processo de avaliação de riscos de segurança da informação.



Cr terios de risco

O que s o

- **Avalia  o:** Racional para a atribui  o de valores de PROBABILIDADE e CONSEQU  NCIA (IMPACTO) da materializa  o dos riscos.
- **Aceita  o:** Racional para decidir se um risco   aceit vel ou n o.
- S o uma TRILHA e n o um TRILHO.
- Refer ncia que pode ser personalizada para cada Organiza  o, assegurando o princ pio da **customiza  o**.



Critérios de avaliação - Probabilidade

Probabilidade		Critérios de avaliação
0	Improvável	O risco nunca se materializou na Organização e é improvável que isso aconteça.
1	Baixa	O risco pode se materializar no intervalo de até 1 ano. Houve pelo menos 1 ocorrência nos últimos 12 meses.
2	Média	O risco pode se materializar no intervalo de até 6 meses. Houve pelo menos 1 ocorrência nos últimos 6 meses.
3	Alta	O risco pode se materializar no intervalo de até 1 mês. Houve pelo menos 1 ocorrência no último mês.
4	Crítica	O risco pode se materializar em intervalo inferior a 1 mês. Houve ocorrências há menos de 1 mês.

Critérios de avaliação - Impacto

Impacto		Critérios de avaliação (referência para todos os tipos de risco)
0	Sem impacto	A materialização do risco não traz nenhuma consequência danosa para a Organização. Não há perda de confidencialidade, integridade ou disponibilidade. Não há danos à imagem e reputação. Não há vazamento de nenhum tipo de informação. Não há desatendimento de requisito legal/ compliance. Não há problemas operacionais, de qualidade ou de continuidade de negócios. Não há nenhum tipo de impacto ambiental ou à saúde/ segurança das pessoas. Não há comprometimento das estratégias de negócios. Nenhum impacto na capacidade de gerar receitas, honrar compromissos ou no fluxo de caixa.
1	Baixo	A materialização do risco implica em consequências leves, plenamente reversíveis com ações de contenção em tempo resposta inferior a 4h. Danos leves à imagem e reputação. Não há desatendimento de requisito legal ou contratual. Não há comprometimento dos SLA. Não há perda de confidencialidade. Não há perda de integridade de um ativo crítico. Pode haver perda rápida de disponibilidade (menos de 1h); Problemas operacionais e de qualidade pontuais, afetando poucos clientes. Não há interrupção que requeira acionamento das medidas de continuidade de negócios. Impacto ambiental leve, plenamente reversível com medidas locais. Dano leve à saúde/ segurança das pessoas, plenamente reversível com medidas locais e que não gera afastamento do trabalho. Impacto na capacidade de gerar receitas ou honrar compromissos ou manter o fluxo de caixa no curto prazo (até 30 dias).
2	Médio	A materialização do risco implica em consequências reversíveis com ações de contenção em maior escala em tempo resposta inferior a 8h. Danos moderados à imagem e reputação. Não há desatendimento de requisito legal. Requisito contratual desatendido pontualmente. Pode haver comprometimento do SLA de resposta a eventos/ incidentes. Não há perda de confidencialidade. Pode haver perda de temporária de integridade de um ativo crítico. Pode haver perda moderada de disponibilidade (menos de 4h); Problemas operacionais e de qualidade recorrentes, afetando clientes no curto prazo (até 30 dias). Não há interrupção que requeira acionamento das medidas de continuidade de negócios. Impacto ambiental moderado, reversível com medidas que se estendem ao entorno da Organização no curto prazo (até 30 dias). Danos à saúde/ segurança das pessoas levam a afastamento de até 15 dias do trabalho. Impacto na capacidade de gerar receitas ou honrar compromissos ou manter o fluxo de caixa no médio prazo (até 90 dias).
3	Alto	A materialização do risco traz consequências graves, porém ainda reversíveis, em tempo resposta superior a 8h. Danos graves à imagem e reputação. Desatendimento pontual de requisito legal. Desatendimento importante de requisito contratual. Comprometimento do SLA de nível de serviço. Perda de confidencialidade. Perda de integridade de ativo crítico de reversão demorada. Problemas operacionais e de qualidade recorrentes, afetando clientes no médio prazo (até 90 dias). Interrupção requer acionamento do comitê de gerenciamento de crises para tomada de decisão sobre acionamento de medidas de continuidade. Impacto ambiental grave, reversível com medidas que se estendem além entorno da Organização no médio prazo (até 90 dias). Danos à saúde/ segurança das pessoas levam a afastamento de mais de 15 dias do trabalho. Impacto na capacidade de gerar receitas ou honrar compromissos ou manter o fluxo de caixa no médio para longo prazo (até 180 dias).
4	Crítico	A materialização do risco se dá em um cenário de desastre. Danos permanentes à Organização, com consequências catastróficas em tempo de recuperação superior a 24h. Danos catastróficos à imagem e reputação da Empresa. Desatendimento de requisito legal em larga escala. Quebra de contrato junto ao cliente. Perda de confidencialidade, integridade e disponibilidade permanentes, ou dificilmente reversíveis face ao impacto causado; Problemas operacionais e de qualidade recorrentes, afetando clientes no médio para longo prazo (até 180 dias); Interrupção requer que o comitê de crise acione as medidas de continuidade de negócios. Impacto ambiental catastrófico, de reversão difícil ou irreversível, com medidas que se estendem além entorno da Organização no longo prazo (acima de 180 dias). Danos à saúde/ segurança das pessoas levam mortes ou incapacitação permanente. Impacto na capacidade de gerar receitas ou honrar compromissos ou manter o fluxo de caixa no longo prazo (mais de 180 dias).

Critérios de aceitação dos riscos

		Probabilidade					
		0	1	2	3	4	
Impacto	0	0	1	2	3	4	Níveis de Risco
	1	1	2	3	4	5	
	2	2	3	4	5	6	
	3	3	4	5	6	7	
	4	4	5	6	7	8	

Observação: Os critérios de aceitação determinados asseguram que impactos ou probabilidades **críticos** combinados com probabilidades ou impactos baixos resultam em obrigação de tratar o risco. Em outras palavras: criticidade de qualquer um dos critérios de avaliação tem peso maior.

Critérios de Aceitação do Risco	Priorização dos Riscos para Tratamento
Baixo	Não tratar (Aceitar)
Médio	Decisão de tratar
Alto	Obrigação de tratar

6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.3 Tratamento dos riscos de segurança da informação

A organização deve definir e aplicar um processo de tratamento dos riscos de segurança da informação para:

- a) selecionar, de forma apropriada, as opções de tratamento dos riscos de segurança da informação, levando em consideração os resultados da avaliação dos riscos;
- b) determinar todos os controles que são necessários para implementar as opções de tratamento dos riscos da segurança da informação escolhidas;

NOTA 1: *As organizações podem projetar os controles, conforme requerido, ou identificá-los de qualquer outra fonte.*

- c) comparar os controles determinados em 6.1.3 b) acima com aqueles no Anexo A e verificar que nenhum controle necessário tenha sido omitido;

NOTA 2: *O Anexo A contém uma lista de possíveis controles de segurança da informação. Os usuários desta Norma são instruídos a utilizar o Anexo A para garantir que nenhum controle necessário tenha sido omitido;*

NOTA 3: *Os controles de segurança da informação listados no Anexo A não são exaustivos e controles adicionais de segurança da informação podem ser incluídos, se necessário.*



6 Planejamento

6.1 Ações para abordar riscos e oportunidades

6.1.3 Tratamento dos riscos de segurança da informação (continuação)

d) elaborar uma declaração de aplicabilidade que contenha:

- os controles necessários (ver 6.1.3b) e c));
- justificativa para sua inclusão;
- se os controles necessários estão implementados ou não; e
- justificativa para a exclusão de quaisquer controles do Anexo A;

e) preparar um plano para tratamento dos riscos de segurança da informação;

f) obter a aprovação dos responsáveis pelos riscos do plano de tratamento dos riscos de segurança da informação e a aceitação dos riscos residuais de segurança da informação;

A organização deve manter a informação documentada relativa ao processo de tratamento dos riscos de segurança da informação;

NOTA 4: O processo de tratamento e a avaliação dos riscos de segurança da informação desta norma está alinhado com os princípios e diretrizes gerais definidas na ISO 31000.



6 Planejamento

6.1 Ações para abordar riscos e oportunidades

Dicas de implementação:

- Estabelecer um processo, política ou procedimento para gestão de riscos de segurança da informação;
- Pode ser implementado um único processo para gestão de riscos corporativos, que inclui todas as categorias de risco;
- Podem existir processos distintos de gestão de riscos, para cada categoria de riscos;
- Criar critérios de aceitação de risco, incluindo declarações de apetite ao risco, como apropriado;
- Elaborar um inventário de riscos ou biblioteca de riscos (na 27001, devem ser documentados);
- Associar a cada risco um *risk owner*, ou um proprietário do risco;
- Priorizar os riscos de acordo com os critérios de aceitação e elaborar os planos de tratamento;
- Selecionar todos os controles aplicáveis para tratar os riscos priorizados (Anexo A);
- Elaborar uma declaração de aplicabilidade;
- Determinar os riscos residuais e obter aceitação dos *risk owners*.



Exemplo – Inventário de riscos

Avaliação do Risco Puro ou Inerente					Proprietário do risco (risk owner)	Opção de Tratamento	Avaliação do Risco Residual				
# Risco	Situações em que o risco pode se materializar (processos de negócio, atividades, produtos e serviços)	P	I	NRP			P	I	NRR	Aceito?	Último FUP
R01-01	Funcionários com excesso de privilégios na Blitz Platform	2	2	4	Fulano de Tal	Mitigar/ reduzir	1	1	2	Sim	06/02/2023
R01-02	Prestadores de serviço com excesso de privilégios na Blitz Platform	2	3	5	Fulano de Tal	Mitigar/ reduzir	1	2	3	Sim	06/02/2023
R01-03	Falta de revisão periódica de acessos na Blitz Platform	3	3	6	Fulano de Tal	Mitigar/ reduzir	1	2	3	Sim	06/02/2023
R001-04	Ações de sabotagem na Blitz Platform (funcionários e terceiros)	2	4	6	Fulano de Tal	Mitigar/ reduzir	1	2	3	Sim	06/02/2023
R01-05	Ataque de ransomware à infraestrutura em Cloud	3	4	7	Fulano de Tal	Mitigar/ reduzir	1	3	4	Sim	06/02/2023
R01-06	Ataques de força bruta, negação de serviços e exploração de outras vulnerabilidades na Blitz Platform	3	3	6	Fulano de Tal	Mitigar/ reduzir	1	3	4	Sim	06/02/2023
R01-07	Falha de integridade nos bancos de dados da Blitz Platform	2	3	5	Fulano de Tal	Mitigar/ reduzir	1	2	3	Sim	06/02/2023
R01-08	Falha nas configurações de segurança da Blitz Platform	1	3	4	Fulano de Tal	Mitigar/ reduzir					
R01-09											
R01-10											

Exemplo – Seleção dos controles

Seleção dos Controles Aplicáveis aos Riscos Avaliados (específico para segurança e privacidade da informação)			
Controle	Status	Controle	Status
SI-A.5.1 - Políticas para segurança da informação	Em revisão/ melhoria	SI-A.6.1 - Triagem	Implementado
SI-A.5.2 - Papéis e responsabilidades pela segurança da informação	Implementado	SI-A.6.2 - Termos e condições de emprego	Implementado
SI-A.5.3 - Segregação de funções	Implementado	SI-A.6.3 - Conscientização, educação e treinamento em segurança da informação	Implementado
SI-A.5.10 - Uso aceitável da informação e outros ativos associados	Implementado	SI-A.6.4 - Processo disciplinar	Implementado
SI-A.5.15 - Controle de acesso	Implementado	SI-A.8.2 - Direitos de acesso privilegiado	Em revisão/ melhoria
SI-A.5.16 - Gestão de identidades	Implementado	SI-A.8.3 - Restrição de acesso a informações	
SI-A.5.17 - Informação de autenticação	Implementado	SI-A.8.4 - Acesso ao código fonte	
SI-A.5.18 - Direitos de acesso	Implementado	SI-A.8.5 - Autenticação segura	
SI-A.5.19 - Segurança da informação no relacionamento com fornecedores	Implementado	SI-A.8.7 - Proteção contra malware	
SI-A.5.20 - Endereçando a segurança da informação nos acordos com fornecedores	Implementado	SI-A.8.8 - Gestão de vulnerabilidades técnicas	
SI-A.5.21 - Gerenciando a segurança da informação na cadeia de suprimentos de tecnologia da informação e comunicação (TIC)	Implementado	SI-A.8.12 - Prevenção contra vazamento de dados	
SI-A.5.22 - Monitoramento, revisão e gerenciamento de mudanças de serviços de fornecedores	Implementado	SI-A.8.13 - Cópias de segurança das informações (backup)	
SI-A.5.23 - Segurança da informação para uso de serviços em nuvem	Implementado	SI-A.8.14 - Redundância de instalações processamento de informações	
SI-A.5.24 - Planejamento e preparação para gestão de incidentes de segurança da informação	Implementado	SI-A.8.15 - Registros de atividade (logging)	
SI-A.5.25 - Avaliação e decisão sobre eventos de segurança da informação	Implementado	SI-A.8.16 - Monitoramento de atividades	
SI-A.5.26 - Resposta a incidentes de segurança da informação	Implementado	SI-A.8.17 - Sincronização de relógios	
SI-A.5.27 - Aprendendo a partir de incidentes de segurança da informação	Implementado	SI-A.8.18 - Uso de programas utilitários privilegiados	
SI-A.5.28 - Coleta de evidências	Implementado	SI-A.8.19 - Instalação de software em sistemas operacionais	
SI-A.5.29 - Segurança da informação durante interrupções	Em implementação	SI-A.8.21 - Segurança dos serviços de rede	
SI-A.5.30 - Prontidão de TIC para continuidade de negócios	Em implementação	SI-A.8.24 - Uso de criptografia	

Exemplo – Plano de tratamento de risco

Plano de Tratamento dos Riscos (ações para controles em implementação/ Em revisão/melhoria)					
#	Ação	Responsável	Prazo	Situação	Último FUP
R01-A01	Concluir, publicar e treinar as pessoas no documento "Plano de Emergências e Continuidade de negócios"	Ciclano da Silva	15/04/2023	Em andamento	22/02/2023
R01-A02	Planejar e executar exercício do BCP - Plano de Continuidade de Negócios - Cenário: Indisponibilidade da plataforma Blitz devido invasão dos servidores em nuvem.	Ciclano da Silva	15/06/2023	Não iniciado	22/02/2023
R01-A03	Concluir implementação do projeto "Single Sign On" e revisão dos direitos de acesso privilegiado.	Fulano de Tal	31/03/2022	Em andamento	22/02/2023
R01-A04					
R01-A05					
R01-A06					
R01-A07					
R01-A08					
R01-A09					
R01-A10					

Exemplo – Declaração de Aplicabilidade

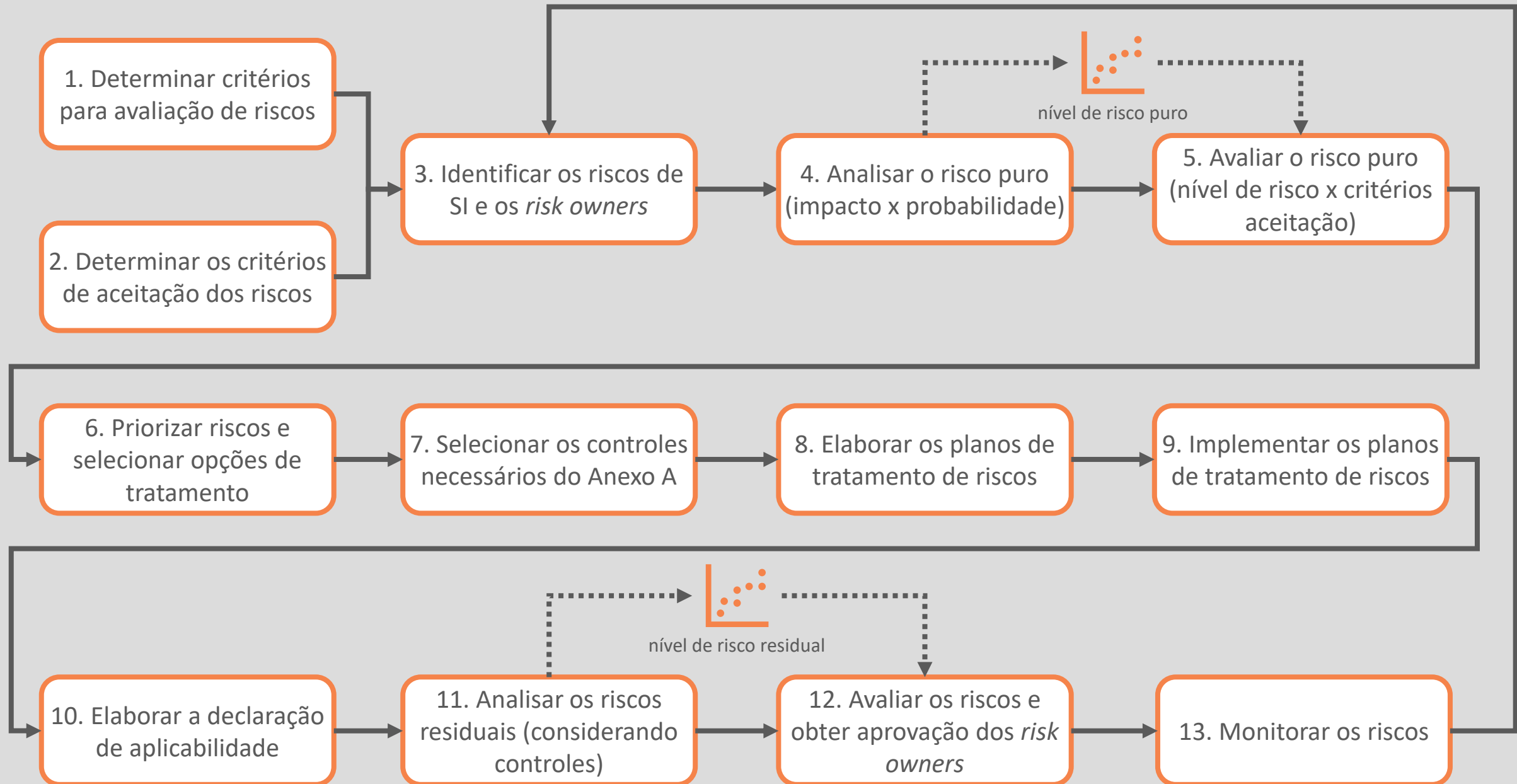
Declaração de Aplicabilidade - ISO/ IEC 27001 e ISO/ IEC 27701

[Voltar](#)

©Bushidô Business Academy 2023

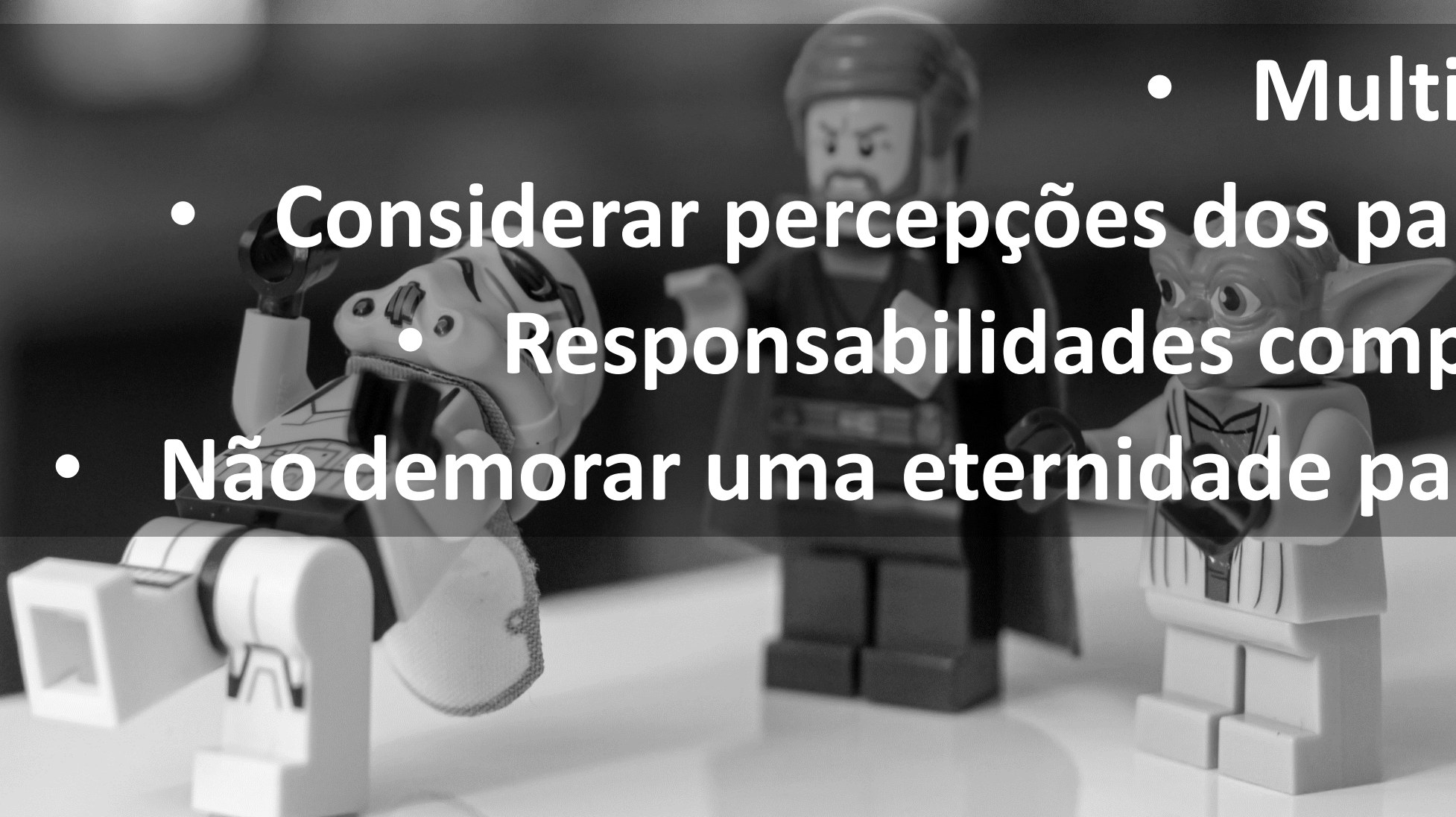
Seção	Nome do Controle	Descrição do Controle	Aplicável?	Justificativa para ser aplicável/ não aplicável	Implementado?	Resumo da Implementação/ Ref. aos Planos de Ação
ISO/ IEC 27001:2022 - Anexo A						
A.5 Controles Organizacionais						
A.5.1	Políticas para segurança da informação	Uma política de segurança da informação e políticas por tópicos específicos devem ser definidas, aprovadas pela administração, publicadas, comunicadas e reconhecidas pelo pessoal e partes interessadas relevantes, e revisadas em intervalos planejados e se ocorrerem mudanças significativas.	Sim	Controle necessário para assegurar que todas as políticas aplicáveis previstas neste documento sejam identificadas e implementadas.	Sim	A Blitz possui um conjunto de políticas de SI desenvolvidas, implementadas e comunicadas, conforme descrito nos demais controles apresentados neste documento.
A.5.2	Papéis e responsabilidades pela segurança da informação	As funções e responsabilidades pela segurança da informação devem ser definidas e alocadas de acordo com as necessidades da organização.	Sim	Controle necessário para assegurar que os colaboradores em cada nível da Organização entendem as suas responsabilidades perante SI.	Sim	Os papéis e responsabilidades pela SI são definidos e documentados no Manual do SGSI e nos demais documentos do SGSI. Algumas responsabilidades podem estar atribuídas sem que estejam necessariamente documentadas.
A.5.3	Segregação de funções	Deveres e áreas de responsabilidade conflitantes devem ser segregados.	Sim	Controle necessário para evitar conflitos de interesse e que uma única pessoa possa requisitar, aprovar e executar demandas/ ações em S.	Em revisão	Segregação de funções é implementada de diversas formas, incluindo: - Atribuição de perfis de acesso a sistemas e aplicações de acordo com a função do colaborador/ terceiro - Atribuição de responsabilidades formais na Organização
A.5.4	Responsabilidades da direção	A administração deve exigir que todo o pessoal aplique a segurança da informação de acordo com a política de segurança da informação, políticas de tópicos específicos e os procedimentos estabelecidos pela organização.	Sim	Controle necessário para evidenciar o compromisso estabelecido pela Alta Direção e demais níveis de liderança com o SGSI.	Sim	A Alta Direção da Blitz definiu e aprovou a Política Estratégica de Segurança da Informação. Através do planejamento e alocação de recursos para o SGSI, análise dos resultados das auditorias internas, realização das Análises Críticas pela Direção e atuando nos treinamentos de segurança, exerce seu papel de exigir das pessoas o cumprimento das regras do SGSI.
A.5.5	Contato com autoridades	A organização deve estabelecer e manter contato com as autoridades relevantes.	Sim	Controle necessário para assegurar que a Organização mantém ou manterá contrato apropriado com autoridades no caso de ocorrência de incidentes de segurança que requeiram esse tipo de reporte.	Sim	Caso seja necessário, a Blitz poderá manter contato com as seguintes autoridades: - Polícia civil (para registro de BO em caso de suspeita de incidente criminoso) - ANPD (para comunicação de incidente envolvendo dados pessoais)
A.5.6	Contato com grupos de interesse especial	A organização deve estabelecer e manter contato com grupos de interesse especial ou outros fóruns especializados em segurança e associações profissionais.	Sim	Controle necessário para assegurar que a Organização tenha acesso a informação de ponta sobre novas ameaças, ataques ou tentativa de ataques ocorridos, e vulnerabilidades.	Sim	A Blitz participa de diversos fóruns de discussão sobre SI, detecção de ameaças, notícias sobre ataques cibernéticos, além de boletins técnicos dos fabricantes e desenvolvedores das soluções de hardware e software que utiliza.

Processo de Gestão de Riscos de SI e do SoA (*Statement of Applicability*)



Dicas para a Gestão de Riscos

- Multidisciplinar
- Considerar percepções dos participantes
 - Responsabilidades compartilhadas
- Não demorar uma eternidade para finalizar



Informação documentada resultante do processo de gestão de riscos (cláusulas 6 e 8)

- *Processo de gestão de riscos* (política, procedimento, *workflow* em ferramenta ou vídeo-treinamento)
 - *Inventário de riscos de SI* (dicionário de riscos, matriz de riscos, cadastro de riscos ou outras nomenclaturas adotadas pelas Organizações)
 - *Processo de tratamento de riscos de SI* (política, procedimento, *workflow* em ferramenta ou vídeo-treinamento)
 - Planos de tratamento de riscos
 - Declaração de aplicabilidade

6 Planejamento

6.2 Objetivos de segurança da informação e planos para alcançá-los

A organização deve estabelecer os objetivos de segurança da informação para as funções e níveis relevantes.

Os objetivos de segurança da informação devem:

- a) ser consistentes com a política de segurança da informação;
- b) ser mensurável (se praticável);
- c) levar em conta os requisitos de segurança da informação aplicáveis, e os resultados da avaliação e tratamento dos riscos;
- d) ser monitorados;
- e) ser comunicados;
- f) ser atualizados como apropriado;
- g) estar disponíveis como informação documentada.



6 Planejamento

6.2 Objetivos de segurança da informação e planos para alcançá-los (continuação)



A organização deve reter informação documentada dos objetivos de segurança da informação. Quando do planejamento para alcançar os seus objetivos de segurança da informação, a organização deve determinar:

- h) o que será feito;
- i) quais recursos serão necessários;
- j) quem será responsável;
- k) quando será concluído;
- l) como os resultados serão avaliados.

6 Planejamento

6.2 Objetivos de segurança da informação e planos para alcançá-los (continuação)

Normalmente encontramos dois tipos de objetivos:

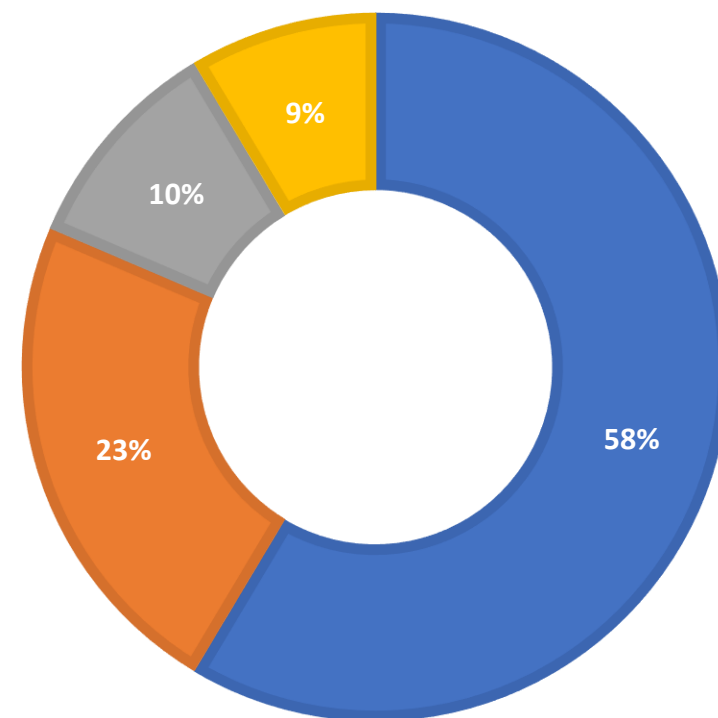
- **Objetivos FINITOS:** baseados na implementação de programas e projetos.
- **Objetivos RECORRENTES:** ligados ao cumprimento de metas de revisão periódica do desempenho. Os objetivos recorrentes levam ao desdobramento de indicadores estratégicos – Precisa haver pelo menos um!!!

Dicas de implementação:

- Elaborar os Objetivos de SI de forma alinhada com o direcionamento estratégico; usar fontes como: planejamento estratégico; sistema de OKR e outras, conforme apropriado;
- Considerar do sistema de indicadores de desempenho aqueles que podem ser associados ao SGSI, incluindo o planejamento de ações para alcançar os resultados pretendidos;
- Objetivos típicos de um SGSI: Redução de níveis de risco; disponibilidade de aplicações, sistemas e infraestrutura; tratamento de vulnerabilidades críticas; entre outros;
- A existência de planos de ação apenas sobre **resultados** de indicadores ligados aos objetivos NÃO ATENDE a este requisito.

RISCOS DO SGSI 2022

■ Baixo ■ Médio ■ Alto ■ Crítico



6 Planejamento

6.2 Objetivos da GS e planejamento para alcançá-los

Exemplo de boa prática para objetivos e planos para alcançá-los

Compromisso da Política	Objetivo	Meta	Indicador	Ações	Responsável	Prazo	Recursos Necessários
Assegurar a disponibilidade dos serviços críticos	Maximizar disponibilidade	Assegurar disponibilidade de 99,9998%	Taxa de Disponibilidade	Prever em contrato com os serviços de Cloud SLA de disponibilidade para os sistemas críticos	Gerente de Infraestrutura	31/07/2022	--
Reduzir os riscos de SI	Reduzir riscos não toleráveis	Zerar riscos não toleráveis	Número de Riscos Não Toleráveis	Implementar NGF	Gerente de Infraestrutura	15/05/2022	R\$ 85.000,00
Não parar nunca	Tornar insignificante risco de interrupção	Migrar serviços digitais para cloud em seis meses	Follow Up de Projeto	Elaborar e implementar projeto de migração dos serviços da plataforma para hospedagem em nuvem de alta confiabilidade (Azure, AWS ou GCP)	Gerente de Infraestrutura	31/07/2022	R\$ 200.000,00

Coerência com compromissos da política

Preferência por objetivos proativos e não reativos

Plano de ação consistente

6 Planejamento

6.3 Planejamento de mudanças

Quando a Organização determinar a necessidade de mudanças em seu sistema de gestão da segurança da informação, essas mudanças devem ser conduzidas de forma planejada.



Dicas de implementação:

- Apesar de ser um requisito novo na ISO/ IEC 27001:2022, a versão anterior da Norma já mencionava gerenciamento de mudanças no requisito 8.1 (que foi mantido);
- O controle A.8.32 especificamente se refere à gestão de mudanças.;
- Crie ou revise um processo, política ou procedimento para a gestão de mudanças (GMUD);
- Considere as seguintes informações mínimas para um processo de GMUD: objetivo da mudança; passo a passo da mudança; pessoal envolvido; processos afetados; momento oportuno para implementar a mudança; plano de *rollback*; guarda das evidências da implementação da mudança.

7 Apoio

7.1 Recursos

7.2 Competência

7.3 Conscientização

7.4 Comunicação

7.5 Informação documentada

7.5.1 Generalidades

7.5.2. Criando e atualizando informação documentada

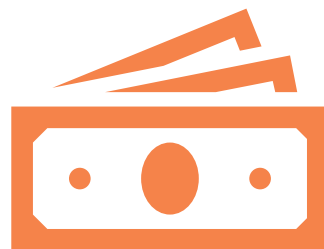
7.5.3. Controle da informação documentada

7 Apoio

7.1 Recursos



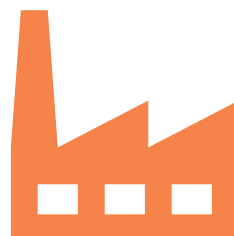
Pessoas
Competentes



Recursos
Financeiros



Infraestrutura,
máquinas e
equipamentos



Ambiente para
operação dos
processos



Recursos de
monitoramento e
medição

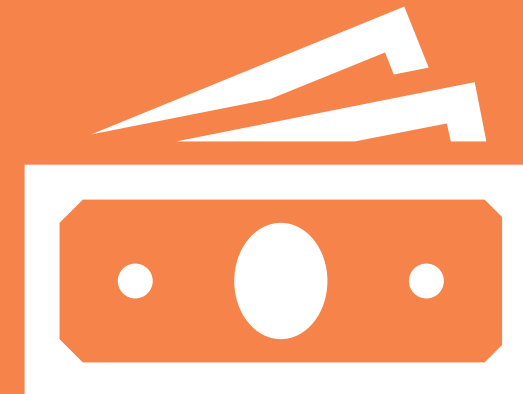


Conhecimento
Organizacional

7 Apoio

7.1 Recursos

A organização deve determinar e prover os recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua do sistema de gestão da segurança da informação.



Dicas de implementação:

- Leve em consideração qualquer processo existente de planejamento e controle orçamentário; identifique neste processo como a Organização trata tecnologia e outros itens que podem ser associados à segurança (Orçamento contemplando TI, segurança lógica, segurança física, facilities); caso este processo não exista, estruture-o;
- Leve em consideração também o planejamento de contratação de pessoas/ *headcount* para suportar as atividades;
- O “Orçamento” deve contemplar tanto Opex quanto Capex;
- Provisione recursos para atividades de gestão e de operação (por exemplo: auditorias internas e externas; sistemas necessários para a proteção do negócio; recursos para capacitação de pessoas; entre outros);
- Estabeleça ou leve em consideração os rituais de gestão: planejamento estratégico, revisão orçamentária, revisão trimestral de desempenho (forecast), etc;
- Documente, em alto nível (por exemplo, no manual do SGSI), a descrição dos processos de gestão de recursos utilizados para atender às necessidades do SGSI.

7 Apoio

7.2 Competência

Capacidade de aplicar conhecimentos e habilidades para alcançar os resultados pretendidos

EDUCAÇÃO

TREINAMENTOS

EXPERIÊNCIA

7 Apoio

7.2 Competência



A organização deve:

- a) determinar a competência necessária das pessoas que realizam trabalho sob seu controle e que afeta o desempenho e a eficácia do SGSI;
- b) assegurar que essas pessoas são competentes com base na educação, treinamento ou experiência;
- c) onde aplicável, tomar ações para adquirir a competência necessária e avaliar a eficácia das ações tomadas; e
- d) reter informação documentada apropriada como evidência da competência.

NOTA: *Ações apropriadas podem incluir, por exemplo: fornecimento de treinamento, mentoria ou realocação dos funcionários atuais; ou a contratação de pessoas competentes..*

Dicas de implementação:

- Verifique se o processo de recrutamento e seleção existente leva em consideração uma base acordada (preferencialmente documentada) de competências: descrições de cargo/ função; processo de definição e revisão de competências no fluxo de recrutamento e seleção; caso não exista, crie e implemente;
- Implemente um processo de capacitação de acordo com as necessidades ou riscos de segurança, como iniciativa da Organização para eliminar eventuais lacunas de competência;
- Implemente um processo de avaliação de desempenho das pessoas para demonstrar a eficácia da gestão de competências;
- Retenha as evidências de competência apropriadas (currículos, certificados de cursos, resultados de avaliações de desempenho, entre outras).

7 Apoio

7.3 Conscientização



Pessoas que realizam trabalho sob o controle da organização devem estar conscientes:

- a) da política de gestão da segurança da informação;
- b) da sua contribuição para a eficácia do SGSI, incluindo os benefícios da melhoria do desempenho em SI; e
- c) das implicações da não conformidade com os requisitos do SGSI.

Dicas de implementação:

- Implemente este processo em conjunto com o controle A.6.3. Implemente um processo estruturado de *onboarding*, enfocando a política estratégica do SGSI, os conceitos básicos de gestão de riscos e as principais medidas de mitigação
- Os funcionários devem ser capazes de responder questões como:
 - Qual é a SUA visão sobre a política de gestão da segurança da informação da empresa?
 - De que maneira você pode contribuir para que a empresa permaneça segura contra ataques cibernéticos e vazamento de informações?
 - O que pode acontecer quando você deixa de cumprir as normas e procedimentos de segurança e privacidade da informação?

LEMBRE:
**as PESSOAS são o elo mais forte da
segurança e da privacidade!**



7 Apoio

7.4 Comunicação



A organização deve determinar as comunicações internas e externas relevantes para o SGSI incluindo:

- a) sobre o que ela irá comunicar;
- b) quando comunicar;
- c) com quem se comunicar;
- d) como comunicar;
- e) quem vai ser responsável pela comunicação.

Dicas de implementação:

- Definir um “plano de comunicação” contemplando os itens da Norma em que o verbo “comunicar” é conjugado; Considerar toda as comunicações internas e externas relevantes que estejam associadas ao SGSI;
- Realizar as comunicações de acordo com o plano;
- Manter registros de comunicações realizadas;
- Entrevistar as pessoas para captar se as comunicações são eficazes.

7 Apoio

7.4 Comunicação

Plano de Comunicação - Exemplo

Tipo	O que comunicar	Quando comunicar	Quem comunica	A quem comunica	Como comunica
I	Política do Sistema de Gestão	Continuamente	CEO	Todos os funcionários	Intranet
I	Objetivos do Sistema de Gestão	Continuamente	Gerente da Qualidade	Todos os funcionários	Intranet
I	Resultados (indicadores)	Mensalmente	CEO	Todos os funcionários	Reunião Mensal
I	Incidentes de segurança da informação	A cada ocorrência	CISO	Todos os funcionários	Email
E	Não-Conformidades de fornecedores	A cada ocorrência	Gerente da Qualidade	Fornecedor envolvido	Email
E	Respostas a solicitações de clientes	A cada ocorrência	Gerente de relacionamento	Clientes externos	Email
E	Respostas a solicitações de titulares dos dados	A cada ocorrência	Blue Team	Titulares de dados pessoais	Email
I	Resultados das avaliações de riscos	Semestralmente	CISO	Diretoria e gestores	Reunião semestral

7 Apoio

7.5 Informação documentada

7.5.1. Generalidades

O SGSI da organização deve incluir:

- a) informação documentada requerida pela ISO 27001;
- b) informação documentada determinada pela organização como sendo necessária para a eficácia do SGSI.

NOTA: A extensão da informação documentada para um sistema de gestão de Segurança da Informação pode diferir de uma organização para outra, devido:

- ao tamanho da organização e seu tipo de atividades, processos, produtos e serviços;
- à complexidade dos processos e suas interações;
- à competência das pessoas.

Quem decide sobre quais documentos devem existir é a própria Organização!

ATENÇÃO!!!

Não existe regra fixa para tipo, formato ou quantidade de documentos.

A NOTA da seção 7.5.1 ajuda a esclarecer este aspecto do sistema de gestão.

Regra de ouro: não crie burocracia desnecessária!!!

7 Apoio

7.5 Informação documentada

7.5.2. Criando e atualizando

Ao criar e atualizar informação documentada, a organização deve assegurar apropriados:

- a) identificação e descrição (por exemplo, um título, data, autor ou número de referência);
- b) formato (por exemplo, linguagem, versão do software, gráficos) e meio (por exemplo, papel, eletrônico);
- c) análise crítica e aprovação quanto à adequação e suficiência.



DICA

Aproveite os formatos e mídias que já existem na sua Organização. Organize os tipos de documentos que já existem em uma hierarquia.

Crie novos tipos de documentos APENAS SE ISSO FOR ABSOLUTAMENTE NECESSÁRIO.

7 Apoio

7.5 Informação documentada

7.5.3. Controle de informações documentadas

A informação documentada requerida pelo SGSI e pela ISO/IEC 27001 deve ser controlada para assegurar que:

- a) ela esteja disponível e adequada para o uso, onde e quando ela for necessária;
- b) ela esteja adequadamente protegida (por exemplo, contra perda de confidencialidade, uso impróprio ou perda de integridade).



Informação certa disponível
para a pessoa certa mediante
acesso autorizado

7 Apoio

7.5 Informação documentada

7.5.3. Controle de informações documentadas (continuação)

Para o controle da informação documentada, a organização deve considerar as seguintes atividades, conforme aplicável:

- a) distribuição, acesso, recuperação e uso;
- b) armazenagem e preservação, incluindo a preservação da legibilidade;
- c) controle de mudanças (por exemplo, controle de versão);
- d) Retenção e disposição.

A informação documentada de origem externa, determinada pela organização como necessária para o planejamento e operação do SGSI, deve ser identificada como apropriada, e controlada.

NOTA: Acesso pode implicar uma decisão quanto à permissão para somente ver a informação documentada, ou a permissão e autoridade para ver e alterar a informação documentada.



7 Apoio

7.5 Informação documentada

Exemplos de informações documentadas que devem ser controladas pela Organização, e que afetam o SG:

Internos

Instruções operacionais
Procedimentos operacionais
Planejamento Estratégico
Formulários/ Check lists
Playbooks/ Runbooks
Certificados de treinamento
Atas de reuniões
SLAs/ NDAs para clientes



Externos

Diplomas legais
Licenças (se aplicável)
Contratos de clientes
Normas técnicas aplicáveis
Projetos de clientes ou fornecedores
SLAs/ NDAs de fornecedores

7 Apoio

7.5 Informação documentada



Dicas de implementação:

- Estabeleça um processo para a gestão da informação documentada;
- Estabeleça uma hierarquia para os documentos internos;
- Defina responsabilidades e autoridades pela elaboração e aprovação de documentos internos;
- Use os diferentes formatos que um documento pode ter, adaptando-os às suas necessidades; atentar para formas mais modernas de documentação, como *playbooks* e *runbooks* em plataformas digitais de trabalho;
- *Workplaces* digitais como MS 365, ClickUp, Google Workspace, entre outros, permitem que documentos sejam gerados com controle automático de versões e manutenção do histórico detalhado de alterações sem necessidade de interferência do usuário, facilitando em muito a gestão de documentos;
- Atentar para formas modernas de criação de documentos, como documentos colaborativos;
- Estabeleça listas controladas de documentos de origem externa e atribuição de responsabilidades por manter tais listas atualizadas;
- Garanta que os documentos de origem externa relevantes para o SGSI seja de conhecimento das pessoas que precisam utilizá-los.

8 Operação

8.1 Planejamento e controle operacional

8.2 Avaliação de riscos de segurança da informação

8.3 Tratamento dos riscos de segurança da informação

8 Operação

8.1 Planejamento e controle operacional

A organização deve planejar, implementar e controlar os processos necessários para atender aos requisitos, e para implementar as ações determinadas na cláusula 6, por meio:

- do estabelecimento de critérios para os processos;
- da implementação do controle dos processos de acordo com os critérios estabelecidos.

Informação documentada deve estar disponível na extensão necessária para gerar confiança de que os processos tenham sido conduzidos conforme planejado.

A organização deve controlar as mudanças planejadas e analisar criticamente as consequências de mudanças não intencionais, tomando ações para mitigar quaisquer efeitos adversos, conforme necessário.

A organização deve assegurar que aqueles processos, produtos e serviços providos externamente que sejam relevantes para o sistema de gestão da segurança da informação sejam controlados.



Dicas de implementação:

- Políticas, procedimentos e instruções de trabalho criados para o SGSI
- Registros e evidências gerais da aplicação das políticas, procedimentos e instruções
- Existência de processo, política ou procedimento formal para gestão de mudanças (como um documento específico ou como parte integrante de outro documento)

8 Operação

8.2 Avaliação dos riscos de segurança da informação

A organização deve realizar avaliações de riscos de segurança da informação a intervalos planejados ou quando mudanças significativas forem propostas ou ocorrerem, levando em conta os critérios estabelecidos em 6.1.2 a).

A organização deve reter informação documentada dos resultados das avaliações de risco de segurança da informação.

Dicas de implementação:

- Inventário de riscos de segurança da informação atualizado conforme critérios definidos pela Organização

8 Operação

8.3 Tratamento dos riscos de segurança da informação

A organização deve implementar o plano de tratamento de riscos de segurança da informação.

A organização deve reter informação documentada dos resultados do tratamento dos riscos de segurança da informação.



Dicas de implementação:

- Inventário de riscos de segurança da informação atualizado conforme critérios definidos pela Organização
- Planos de tratamento de riscos implementados e atualizados

9 Avaliação do Desempenho

9.1 Monitoramento, medição, análise e avaliação

9.2 Auditoria interna

9.3 Análise crítica pela direção

Avaliação do desempenho

9.1 Monitoramento, medição, análise e avaliação

A organização deve determinar:

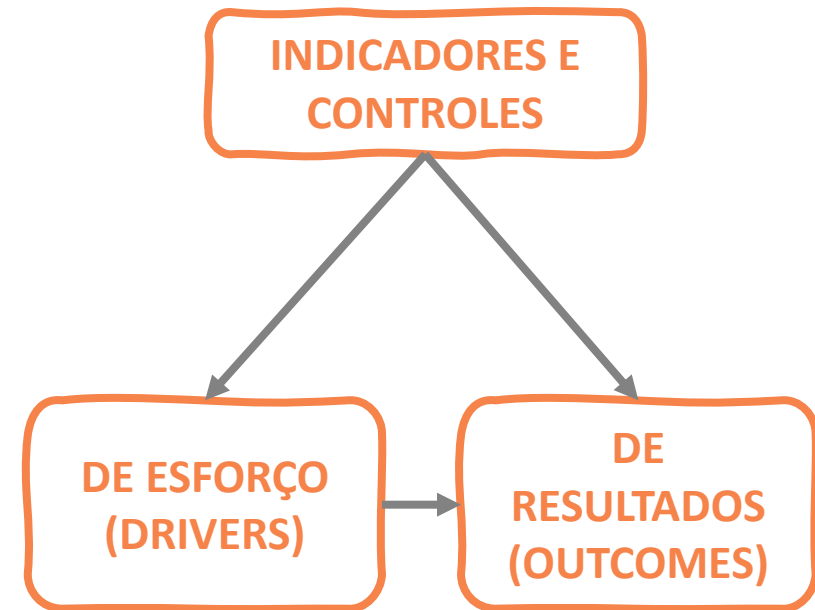
- a) o que precisa ser monitorado e medido, incluindo controles e processos de segurança da informação;
- b) os métodos para monitoramento, medição, análise e avaliação, conforme aplicável, para assegurar resultados válidos. Os métodos selecionados devem ser comparáveis e reproduzíveis para serem válidos;
- c) quando o monitoramento e a medição devem ser realizados;
- d) quem deve medir e monitorar;
- e) quando os resultados do monitoramento e da medição devem ser analisados e avaliados; e
- f) quem deve analisar e avaliar estes resultados.

Informação documentada deve estar disponível como evidência dos resultados.

A Organização deve avaliar o desempenho e a eficácia do sistema de gestão da segurança da informação.

Dicas de implementação:

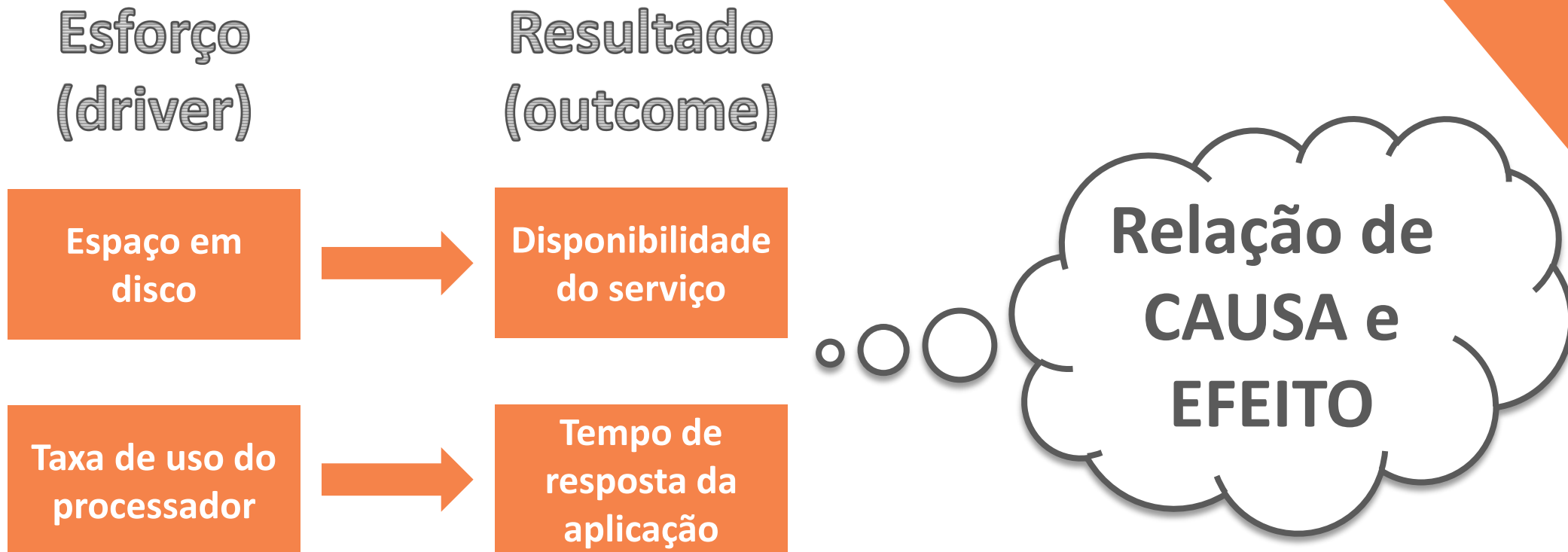
- Convém estabelecer um processo ou procedimento para esta atividade;
- Estabeleça indicadores de desempenho definidos e monitorados cobrindo:
 - Estratégia e operação;
 - Confidencialidade, integridade, disponibilidade;
 - Riscos;
- Gráficos e indicadores providos por ferramentas automatizadas, incluindo alertas gerados;
- Tenha tanto indicadores de esforço quando de resultados.



Avaliação do desempenho

9.1 Monitoramento, medição, análise e avaliação

Exemplos de Indicadores de Esforço e de Resultados



Medição x Monitoramento

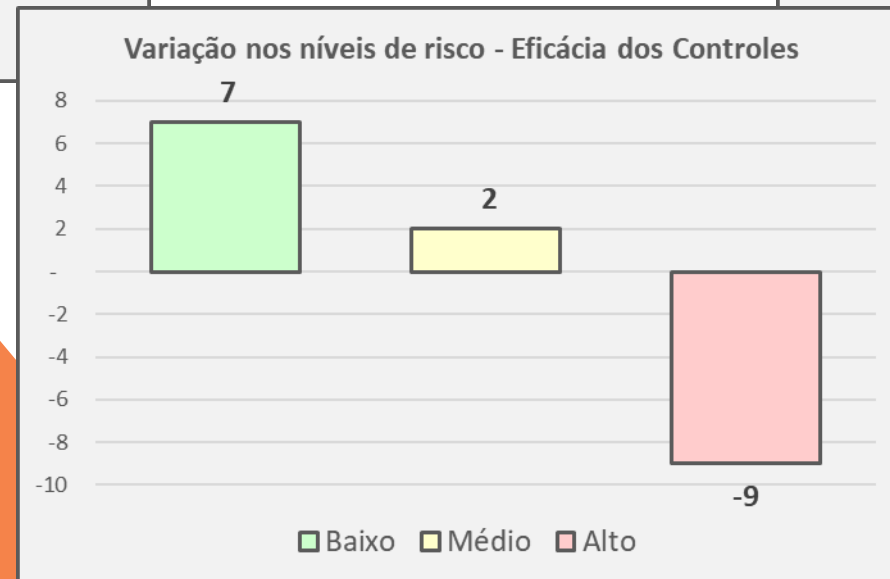
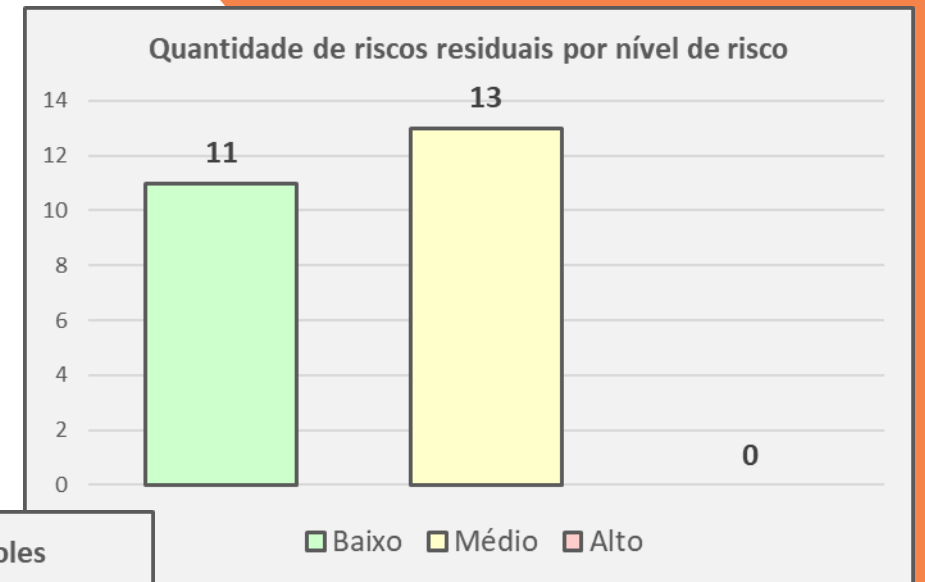
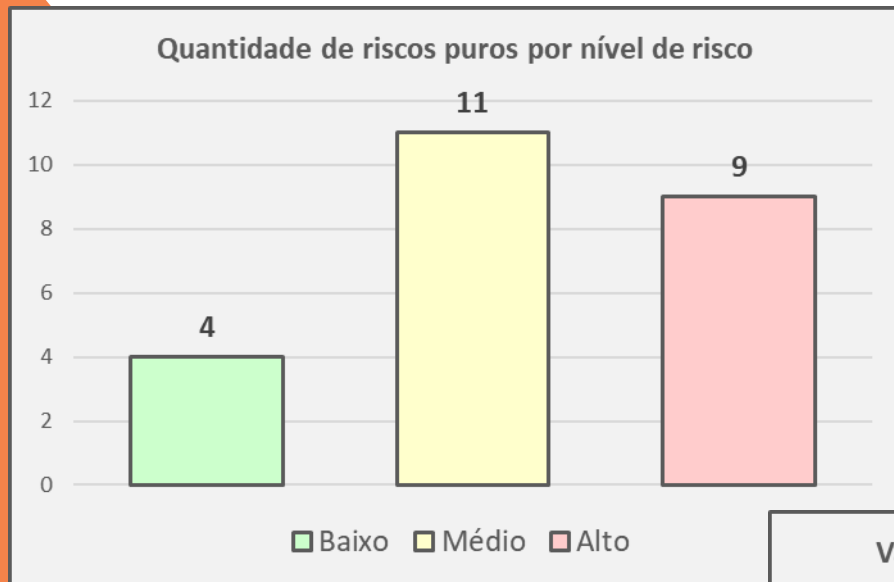
MEDIR

Comparar uma grandeza ou conjunto de grandezas com outro de mesma natureza tomado como padrão, com o objetivo de determinar o seu valor.

MONITORAR

Determinar a situação de um sistema, processo, produto, serviço ou atividade.

Exemplo de Indicadores e Monitoramento



Avaliação do desempenho

9.2 Auditoria interna

Auditoria:

Processo sistemático, independente e documentado para obter **evidência objetiva** e avaliá-la objetivamente para determinar a extensão na qual os **critérios de auditoria** são atendidos.



Avaliação do desempenho

9.2 Auditoria interna



9.2.1 Generalidades

A organização deve conduzir auditorias internas a intervalos planejados para prover informações sobre o quanto o sistema de gestão da segurança da informação:

a) está em conformidade com:

- 1) os requisitos da própria organização para o seu sistema de gestão da segurança da informação;
- 2) os requisitos desta Norma;

b) está efetivamente implementado e mantido.

Avaliação do desempenho

9.2 Auditoria interna (continuação)

9.2.2. Programa de auditoria interna

Organização deve planejar, estabelecer, implementar e manter um programa de auditoria, incluindo a frequência, métodos, responsabilidades, requisitos de planejamento e relatórios.

Quando do estabelecimento do(s) programa(s) de auditoria interna, a organização deve considerar a importância dos processos pertinentes e os resultados de auditorias anteriores.

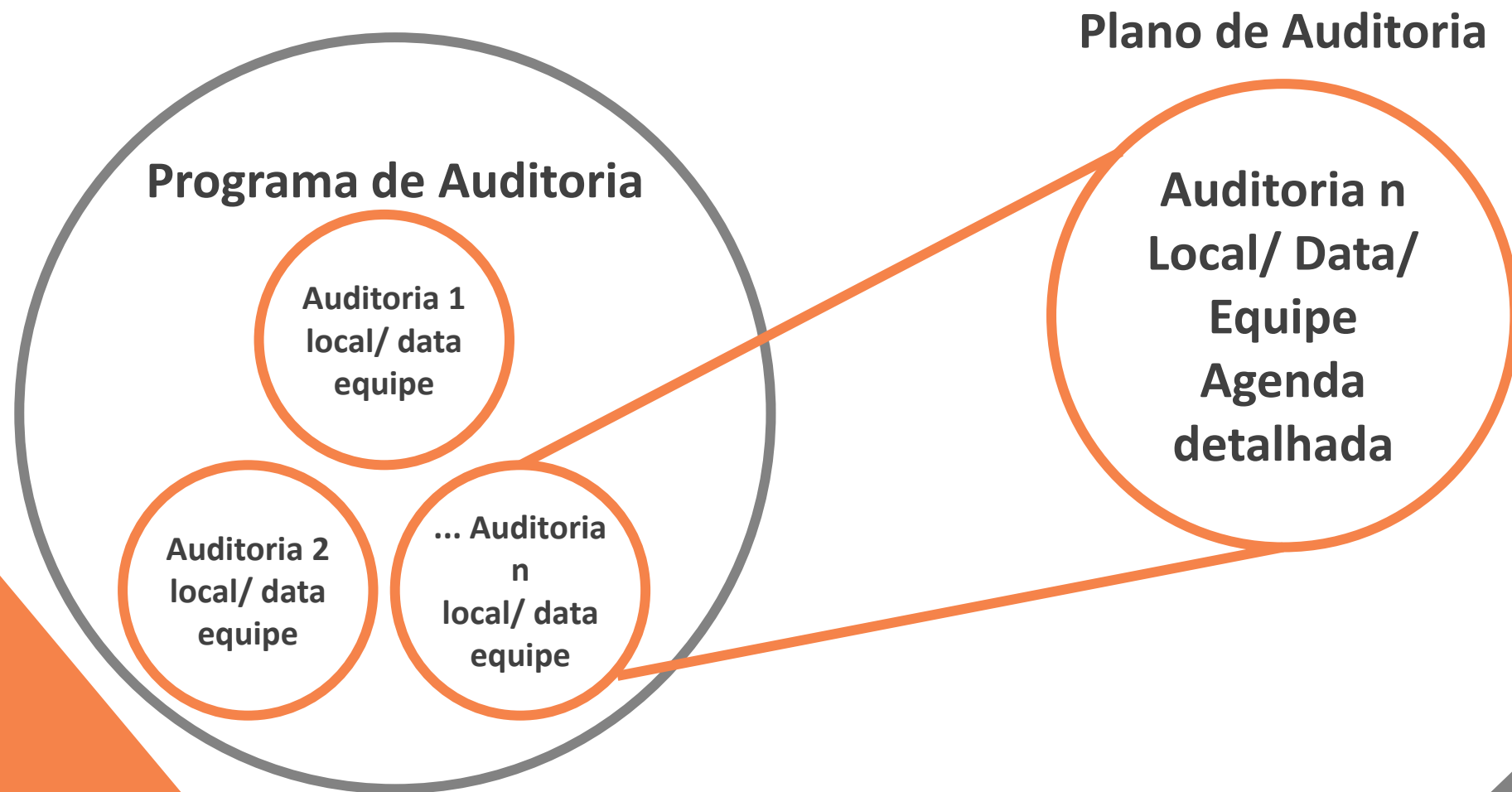
A organização deve:

- a) definir os critérios e o escopo da auditoria, para cada auditoria;
- b) selecionar auditores e conduzir auditorias que assegurem objetividade e imparcialidade do processo de auditoria;
- c) assegurar que os resultados das auditorias são relatados para a gestão relevante.

Informação documentada deve estar disponível como evidência da implementação do(s) programa(s) de auditoria e dos resultados da auditoria.



Programa de Auditoria x Plano de Auditoria





PROGRAMA DE AUDITORIA

Objetivos do programa	Avaliar o grau de implementação e eficácia do Sistema de Gestão	Elaborado por	Freddie Mercury
Escopo	Serão avaliados todos os processos do Sistema de Gestão ao longo do ciclo de 1 ano		
Empresa/ processo	Made In Heaven Ice Cream Co.		

Tipo da Auditoria	
☒ Auditoria interna (funcionários da empresa)	☐ Auditoria de terceira parte
☐ Auditoria interna terceirizada	☐ Auditoria de segunda parte

Critério(s) da Auditoria			
☒ ISO 9001:2015	☒ ISO 14001:2015	☒ ISO 45001:2018	☐ ISO/IEC 27001:2013
☐ ISO 22301:2019	☐ ISO 20000-1:2018	☐ Outro (indicar):	☐ Outro (indicar):

PROCESSOS/ÁREAS	PROGRAMA ANUAL – ANO: 2020											
	Jan	Fev	Mar	Abr	Maio	Jun	Jul	Ago	Set	Out	Nov	Dez
Gestão da Qualidade												
Alta Direção												
P&D												
Marketing												
Comercial												
Infraestrutura e manutenção (facilities)												
Compras												
PCP												
Recursos Humanos												
SSMA (Segurança, saúde e meio ambiente)												
Produção – Sorvetes												
Produção – Picolés												
Produção - Garrafinhas												
Gestão de Contratos												

Forma de execução das auditorias	☒ Presencial	☐ Remota	☐ Híbrida	Data:	15/01/2020
----------------------------------	--	---------------------------------	----------------------------------	-------	------------

Observações e justificativas para as auditorias remotas:	- A primeira auditoria da Gestão da Qualidade será híbrida – parte das evidências necessitam de verificação “in loco”, por ser a primeira auditoria. A segunda auditoria será totalmente remota. - A Auditoria da Alta Direção pode ser feita de forma 100% remota – todas as evidências podem ser apresentadas à distância. - Os processos de Marketing, Comercial, PCP e Gestão de Contratos operam a plataforma informatizada “Order to Heaven”, onde todos os processos são executados em workflows eletrônicos. Todas as pessoas destes processos podem ser entrevistadas por meio de videoconferência. - Os processos Compras, Recursos Humanos e SSMA receberão a sua primeira auditoria e por essa razão não podem receber auditoria somente remota. Nas auditorias subsequentes do Programa, porém, poderão ser auditados de forma remota somente. - Os processos produtivos e de infra estrutura/ manutenção receberão a primeira auditoria, e convém que sejam auditorias 100% presenciais. As auditorias subsequentes serão híbridas, pois muitas evidências são físicas e ambientais.
--	--

Plano de Auditoria



F0035

Plano de Auditoria
Revisão 7 (Dezembro/2016)

Tipo de Auditoria: Fase 1				Ordem de Serviço No: 000000	
Cliente		Made In Heaven			
Endereços e localidades		Panny Lane, 282 – London			
Critérios de Auditoria		ISO 9001:2015 e documentação do sistema de gestão da Organização			
Escopo da auditoria		Serão avaliados os processos e áreas do sistema de gestão de acordo com o Plano de Auditoria a seguir:			
Objetivos da auditoria		Proceder à auditoria de Certificação – Fase 1 – do sistema de gestão da qualidade			
Data e hora da reunião de abertura		29/10/2018 – 13:00 h		Equipe de auditoria	
Data e hora da reunião de encerramento		29/10/2018 – 17:00 h		Líder	Ezio Auditore (EA)
Representante do auditado		Mr. Freddie Mercury		Membro(s)	
Data em que o plano de auditoria foi enviado ao auditado		23/10/2018		Outros	
Data	Hora	Auditor	Processo		Cláusula
29/10/2018	13:00-13:15	EA	Reunião de abertura e apresentação do processo de auditoria		
	13:15-13:30		Tour pela Organização		
	13:30-15:00		Entendimento dos processos do Sistema de Gestão da Qualidade – Contexto da Organização; Partes interessadas; Escopo; Liderança e foco no cliente; Política da Qualidade; Planejamento (riscos e oportunidades; objetivos da qualidade)		
	15:00-16:00		Auditoria interna; Análise crítica pela Direção; Ação corretiva.		
	16:00-16:30		Planejamento da Auditoria – Fase 2		
	16:30-17:00		Preparação do Relatório de Auditoria		
	17:00-17:30		Reunião de encerramento		

Avaliação do desempenho

9.2 Auditoria interna

Dicas de implementação:

- Definir um processo ou procedimento documentado para a gestão de auditorias internas;
- Critérios para escolha de auditores internos, sejam eles membros da própria organização ou subcontratados como prestadores de serviço;
- Elabore um programa de auditoria definido e o comunique dentro da organização;
- Prepare planos de auditoria para cada auditoria individual e os comunique dentro da organização;
- Crie relatórios de auditorias internas consistentes (constatações de conformidade, de não conformidade e oportunidades de melhoria – registre as evidências avaliadas);
- Providencie o tratamento das não-conformidades registradas em tempo hábil;
- Utilize a ISO 19011 como referência para estruturar o atendimento a este requisito.

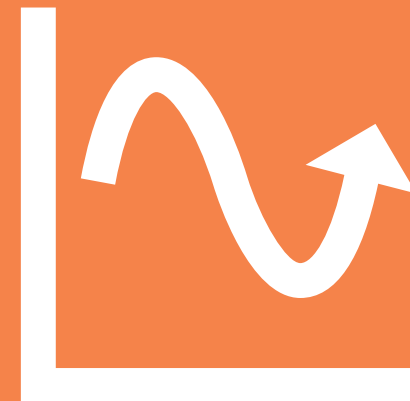


Avaliação do desempenho

9.3 Análise crítica pela direção

9.3.1 Generalidades

A Alta Direção deve analisar criticamente o sistema de gestão da segurança da informação da organização a intervalos planejados para assegurar a sua contínua adequação, pertinência e eficácia.



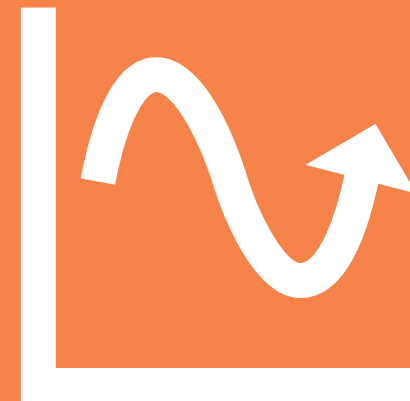
Avaliação do desempenho

9.3 Análise crítica pela direção (continuação)

9.3.2 Entradas para a análise crítica

A análise crítica pela Direção deve incluir considerações sobre:

- a) situação das ações de análises críticas anteriores;
- b) mudanças nas questões internas e externas que sejam relevantes para o sistema de gestão da segurança da informação;
- c) Mudanças nas necessidades e expectativas das partes interessadas que sejam relevantes para o sistema de gestão de segurança da informação;
- d) realimentação sobre o desempenho da segurança da informação, incluindo tendências nas:
 - 1) não conformidades e ações corretivas;
 - 2) resultados de monitoramento e medição;
 - 3) resultados de auditorias; e
 - 4) cumprimento dos objetivos de segurança da informação.
- e) realimentação das partes interessadas;
- f) resultados da avaliação dos riscos e situação dos planos de tratamento dos riscos; e
- g) oportunidades para melhoria contínua.



Avaliação do desempenho

9.3 Análise crítica pela direção (continuação)



9.3.3 Saídas da análise crítica

Os resultados da análise crítica pela Direção devem incluir decisões relativas a oportunidades para melhoria contínua e quaisquer necessidades para mudanças do sistema de gestão da segurança da informação.

Informação documentada deve estar disponível como evidência dos resultados das análises críticas pela direção.

Dicas de implementação:

- Os temas da análise crítica não precisam estar cobertos em um único evento;
- Identifique onde a Organização determinou a abordagem de cada item de entrada exigido em 9.3.2;
- Verifique se, ao longo de um ciclo (tipicamente anual), se todos os temas foram abordados;
- Verifique os registros de cada análise crítica anterior, para verificar que os acompanhamentos de pendências estão sendo feitos;
- Evidencie que de fato houve a participação da alta direção em cada evento de análise crítica;
- Evidencie que são tomadas decisões e ações em função dos resultados da análise crítica;
- Avalie se o intervalo determinado entre as análises críticas é suficiente para que a Alta Direção se mantenha informada sobre o desempenho do SGSI e possa tomar decisões em tempo hábil.

Modelo para Análise Crítica

Estrutura de reporte: dados – análise – conclusão – decisão

1

Fup de análises
críticas anteriores

2

Mudanças em
questões internas
e externas
relevantes

3

NC's e ações
corretivas

4

Resultados de
monitoramento e
medição

5

Resultados de
auditorias internas
e externas

6

Resultados de
auditorias de
clientes

7

Cumprimento dos
objetivos de
segurança da
informação

8

Feedback de
partes interessadas

9

Resultados das
avaliações de riscos
de SI e status dos
planos de tratamento
dos riscos

10

Oportunidades
para melhoria
contínua

10 Melhoria

10.1. Melhoria contínua

10.2 Não-conformidade e ação corretiva

Melhoria

10.1 Melhoria contínua

A organização deve continuamente melhorar a pertinência, adequação e eficácia do sistema de gestão da segurança da informação.

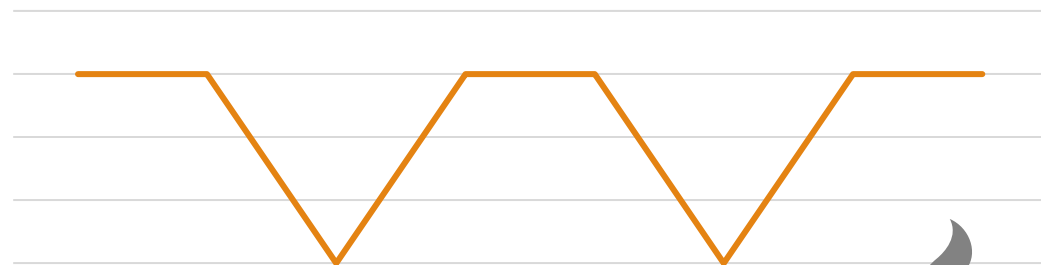


Dicas de implementação:

- Evolução positiva nas metas de desempenho;
- Evolução positiva nos níveis de risco de segurança da informação;
- Redução de ocorrências de incidentes de segurança ao longo do tempo;
- Redução de vulnerabilidades ao longo do tempo.

Que melhoria queremos?

Melhoria de Recuperação - KAIFUKU



Melhoria de recuperação. Desempenho cai, corrige desempenho. Na verdade não é melhoria; é conviver com incêndios.



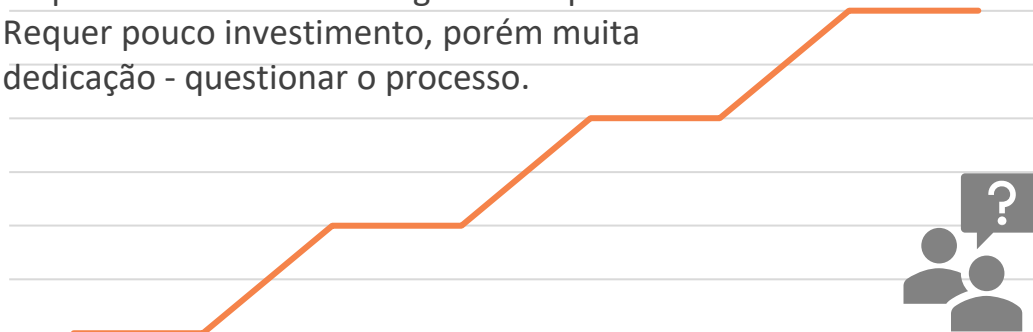
Melhoria Disruptiva - KAIRYO

Melhoria substancial em custo espaço de tempo.
Requer muitos recursos (\$\$)



Melhoria Contínua - KAIZEN

Pequenas melhorias ao longo do tempo.
Requer pouco investimento, porém muita dedicação - questionar o processo.



Melhoria

10.2 Não-Conformidade e Ação Corretiva

Quando uma não conformidade ocorre, a organização deve:

a) reagir à não conformidade, e conforme apropriado:

- 1) tomar ações para controlar e corrigi-la; e
- 2) lidar com as consequências;

b) avaliar a necessidade de ações para eliminar as causas de não conformidade, para evitar sua repetição ou ocorrência, por um dos seguintes meios:

- 1) analisando criticamente a não conformidade;
- 2) determinando as causas da não conformidade; e
- 3) determinando se não conformidades similares existem, ou podem potencialmente ocorrer.

c) implementar quaisquer ações necessárias;

d) analisar criticamente a eficácia de quaisquer ações corretivas tomadas; e

e) realizar mudanças no Sistema de gestão da segurança da informação, quando necessário.

As ações corretivas devem ser apropriadas aos efeitos das não conformidades encontradas.

A organização deve reter informação documentada como evidência da:

- f) natureza das não conformidades e quaisquer ações subsequentes tomadas; e
- g) dos resultados de qualquer ação corretiva.



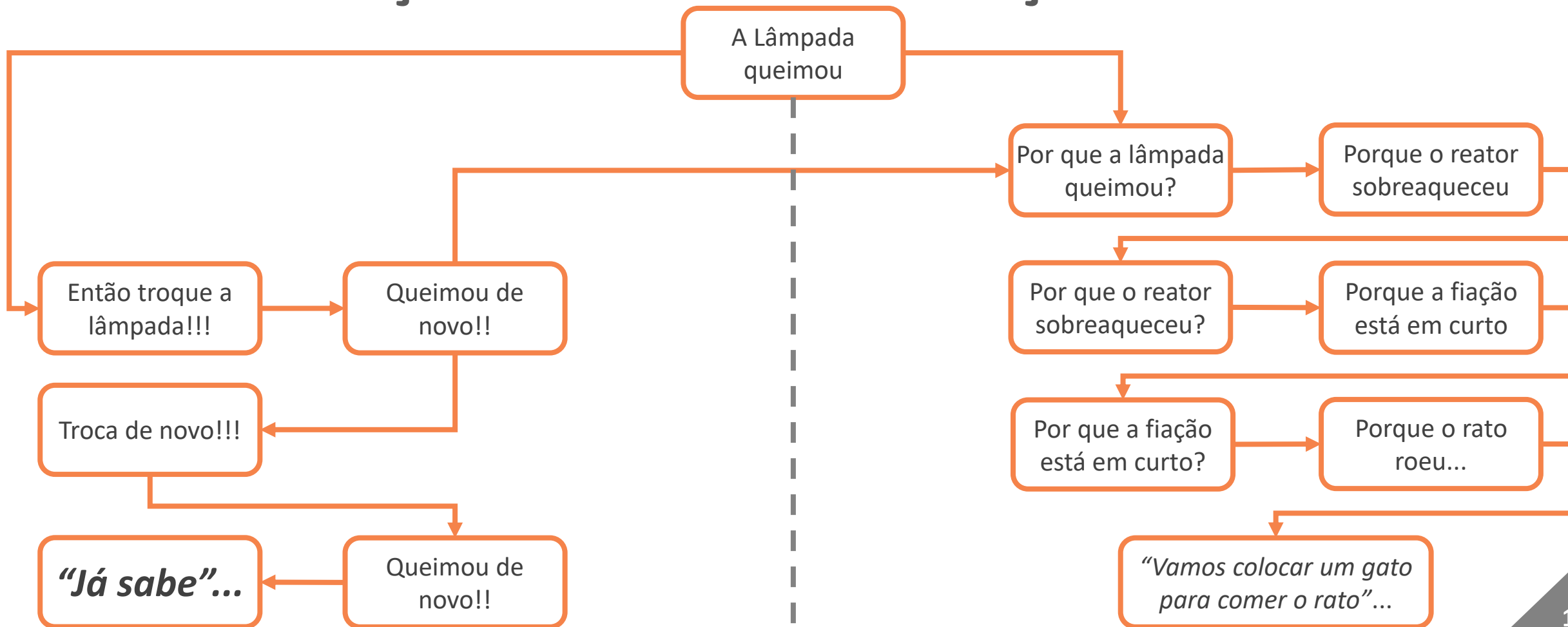
Melhoria

10.2 Não-Conformidade e Ação Corretiva (continuação)

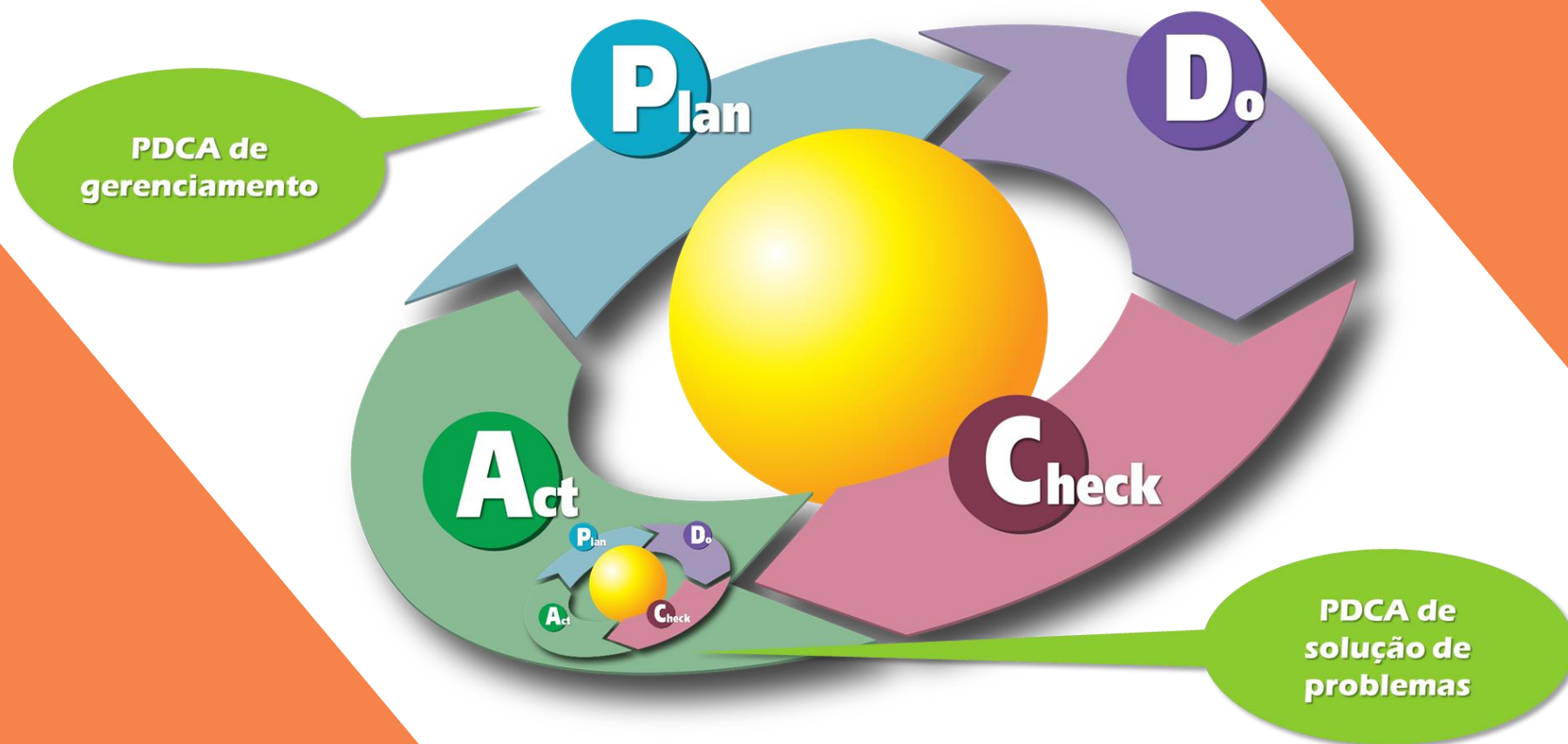
CORREÇÃO

X

AÇÃO CORRETIVA



Lembrando conceitos...

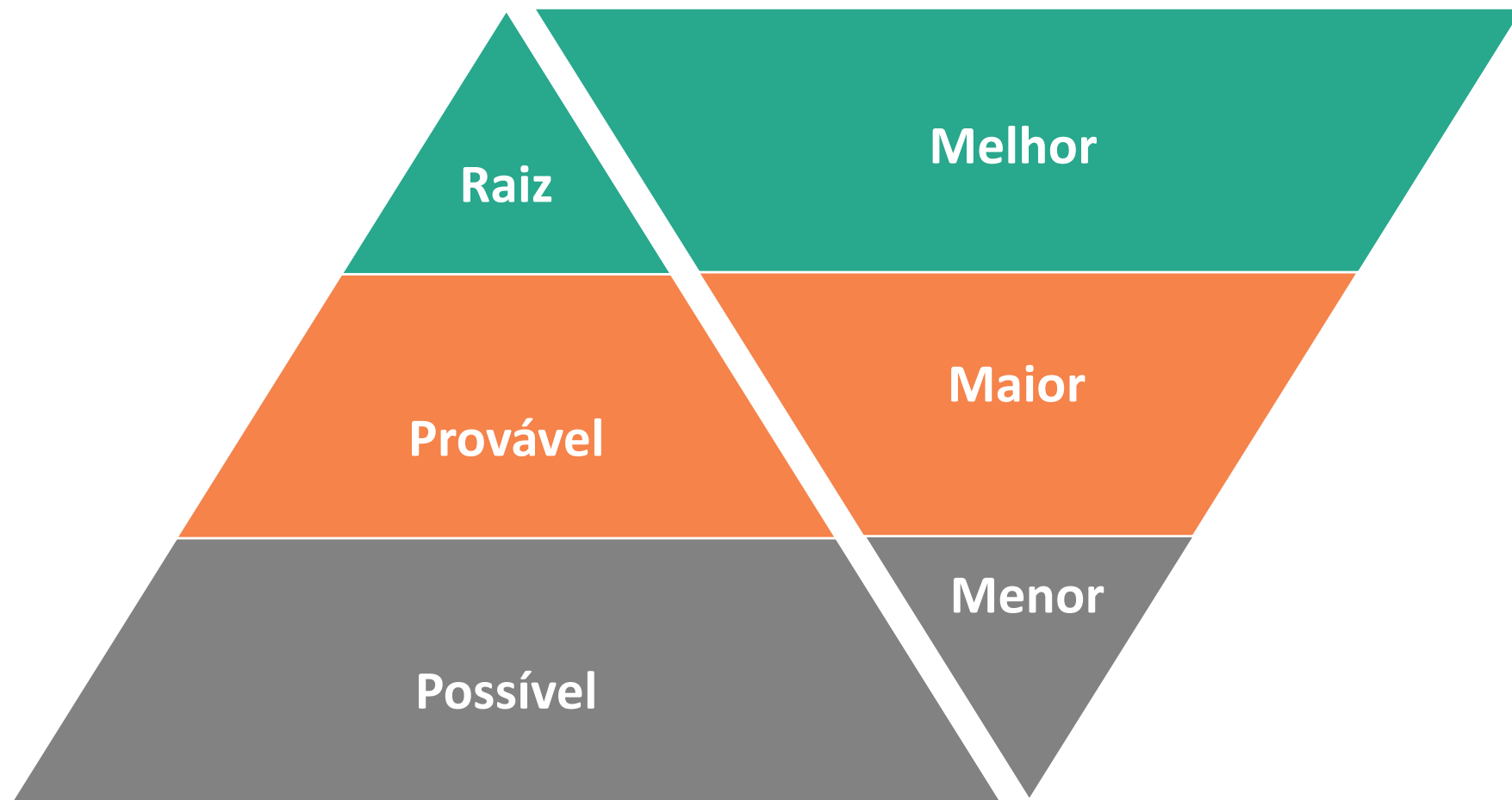


Etapa fundamental: Análise de causas

**Tipos de
Causas**

x

**Chance de
Eficácia do
Plano de Ação**



Analizando causas com os 5 porquês

Por que o computador não está funcionando?

Porque o cabo está desconectado da tomada

Por que o cabo está desconectado da tomada?

Porque o cabo foi “puxado” da tomada

Por que o cabo foi “puxado” da tomada?

Porque alguém tropeçou no cabo puxando-o da tomada

Por que as pessoas tropeçam no cabo?

Porque o cabo fica solto no meio do caminho

Por que o cabo fica solto no meio do caminho?

Porque o cabo é muito longo

Por que o cabo é muito longo?

Uh?... Eu não sei...



SOLUÇÃO:

Conecte-o na tomada!!!

SOLUÇÃO A: Diminuir comprimento do cabo

SOLUÇÃO B: Prender cabo com canaleta na parede

SOLUÇÃO C: Deslocar computador mais próximo da tomada

Melhoria

10.2 Não-Conformidade e Ação Corretiva (continuação)

Dicas de implementação:

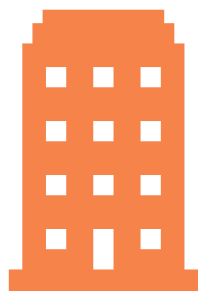
- Estabeleça um processo ou procedimento documentado para identificação e tratamento de NC's
- Assegure o registro das NCs vindas de várias fontes como:
 - Auditorias internas ou externas
 - Incidentes de segurança
 - Manifestações de partes interessadas (graves ou recorrentes)
 - Falhas no cumprimento dos processos, políticas e procedimentos
- Cumprimento do ciclo de tratamento das NC's:
 - Correção
 - Análise de causas
 - Decisão sobre necessidade ou não de ação corretiva
 - Implementação das ações corretivas consideradas necessárias
 - Avaliação da eficácia das ações corretivas executadas, em momento apropriado



The background of the slide is a complex geometric pattern composed of various shades of teal and green triangles and squares. A large, solid orange rectangle is centered on the slide, serving as a backdrop for the title text.

Implementando a ISO/ IEC 27001:2022 - Controles

Estrutura do Anexo A da ISO/ IEC 27001:2022



**Controles
organizacionais**

(37 controles - grupo A.5)



**Controles de
pessoas**

(8 controles - grupo A.6)



Controles físicos
(14 controles - grupo A.7)



**Controles
tecnológicos**
(34 controles - grupo A.8)

93 controles potencialmente aplicáveis

A implementação do Anexo A requer do profissional competências técnicas em TI

ATENÇÃO!!!
SOMENTE os controles aplicáveis devem ser implementados.
Estabeleça as justificativas para os controles considerados não aplicáveis.

A.5

CONTROLES ORGANIZACIONAIS

Controle

Uma política de segurança da informação e políticas por tópicos específicos devem ser definidas, aprovadas pela administração, publicadas, comunicadas e reconhecidas pelo pessoal e partes interessadas relevantes, e revisadas em intervalos planejados e se ocorrerem mudanças significativas.

- É um controle preventivo;
- Resume a abordagem da Organização para segurança da informação;
- Levar em conta os requisitos de negócio, as estratégias, requisitos legais, regulatórios e contratuais;
- Deve ser aprovada pela Alta Direção;
- Pode ser desdobrada em políticas de tópicos específicos, conforme requeridas em outros controles (p. ex. controle de acesso; segurança física e ambiental; gestão de ativos; transferência de informações; configuração e manuseio seguro de dispositivos de *endpoint* de usuários; segurança de redes; gestão de incidentes; *backup* e *restore*; criptografia; desenvolvimento seguro; etc..);
- **Não confundir** com a política exigida no requisito 5.2.

Dicas de implementação:

- Definir uma política de segurança da informação de Alto Nível, e que seja “amigável”
- Definição de outras políticas de segurança para tópicos específicos, conforme for aplicável à organização (ligar com a análise e tratamento de riscos e a declaração de aplicabilidade, conforme requisito 6.1.3 da ISO/ IEC 27001)
- Definir e aplicar de um processo de análise crítica e revisão periódica das políticas, ou revisões motivadas por mudanças importantes – coordenar com o requisito 7.5 da ISO/ IEC 27001.

Controle

As funções e responsabilidades pela segurança da informação devem ser definidas e alocadas de acordo com as necessidades da organização.

- É um controle preventivo;
- Foca na definição e atribuição de responsabilidades específicas pela segurança da informação, como por exemplo: proteção da informação e ativos associados à informação; conduzir processos específicos de SI, como por exemplo revisão de direitos de acesso; atividades da gestão de riscos de segurança da informação, em particular aceitação de riscos residuais pelos proprietários dos riscos; cumprimento das políticas e procedimentos de segurança da informação;
- Podem estar em diversas formas;
- Liga-se ao requisito 5.3.

Dicas de implementação:

- Existência de um organograma destacando as funções associadas à segurança da informação
- Existência de funções de liderança e times específicos focados em segurança da informação (CTO; CISO; Blue Team; Red Team; analistas de segurança da informação; etc..)
- Descrição de responsabilidades na documentação do sistema de gestão
- Entrevistas com o pessoal em geral para obter entendimento sobre se elas entendem o seu papel com relação à segurança da informação

Controle

Deveres e áreas de responsabilidade conflitantes devem ser segregados.

- É um controle preventivo;
- Seu propósito é reduzir o risco de fraudes, erros e *by-pass* dos controles de segurança;
- Tipicamente a segregação é requerida para atividades como: gestão de mudanças; gestão de direitos de acesso; desenvolvimento de software; instalação de softwares; gestão de segurança da informação junto a fornecedores e parceiros; etc..
- Toma forma na definição de limites de ação para funções que podem interferir na segurança, dividindo o trabalho a ser feitos em etapas de criação/ execução/ aprovação.

Dicas de implementação:

- Existência e uso de fluxos de trabalho particionados em diversas etapas de criação, execução e aprovação
- Existência de limites de alçada para tomada de decisões;
- Exigência de dupla aprovação para determinadas decisões ou ações;
- Existência de papéis e funções não conflitantes entre si para uma mesma pessoa;
- Automação de fluxos de trabalho e de processos de tomada de decisão com base em RBAC

Controle

A administração deve exigir que todo o pessoal aplique a segurança da informação de acordo com a política de segurança da informação, políticas de tópicos específicos e os procedimentos estabelecidos pela organização.

- É um controle preventivo;
- Seu propósito é assegurar que a Alta Direção entenda e exerça seu papel em relação à SI e seu poder de influência sobre as pessoas;
- Requer um papel ativo nas ações de educação conscientização em segurança da informação;
- Inclui a participação da Alta Direção na definição e aprovação das políticas de segurança e aplicação das medidas disciplinares;
- A Alta Direção também demonstra esse controle através do planejamento e alocação de recursos para que a segurança da informação seja efetivamente implementada;
- Trabalha em conjunto com o requisito 5.1

Dicas de implementação:

- Aprovação das políticas de segurança de alto nível por parte da alta direção
- A Alta Direção deve promover pessoalmente a Segurança da Informação (comunicados, eventos, etc..)
- Planejamento dos processos de educação e treinamento em segurança da informação.

Controle

A organização deve estabelecer e manter contato com as autoridades relevantes.

- É um controle preventivo e corretivo;
- Seu propósito é assegurar o adequado fluxo de informações sobre segurança da informação entre a organização e autoridades relevantes (legais ou regulatórias);
- Tais autoridades podem incluir forças policiais, autoridades regulatórias (como ANPD e BACEN), conforme aplicável;
- Estes contatos são esperados nos momentos de se comunicar incidentes de segurança em tempo hábil e/ou manter-se informado sobre as expectativas das autoridades relevantes, conforme aplicável.

Dicas de implementação:

- Identificação das autoridades relevantes com as quais a Organização pode ou deve se comunicar a respeito de assuntos relacionados com a segurança da informação (por exemplo: na própria declaração de aplicabilidade; ou no “plano de comunicações” eventualmente criado para atender ao requisito 7.4 da Norma; ou nos planos de recuperação de desastres e/ou planos de continuidade de negócios; ou ainda através de canais estabelecidos por autoridades como a ANPD e o BACEN, conforme aplicável)
- Autoridades típicas podem incluir as forças policiais, ANPD, BACEN e outras.

Controle

A organização deve estabelecer e manter contato com grupos de interesse especial ou outros fóruns especializados em segurança e associações profissionais.

- É um controle preventivo e corretivo;
- Seu propósito é permitir que a Organização se mantenha informada a respeito de desenvolvimentos em segurança da informação, conhecimento sobre boas práticas e informação nova e atualizada a respeito de alertas, avisos e atualizações contra ataques e vulnerabilidades;
- Pode ser atendido de várias maneiras: participação ativa em fóruns especializados; assinatura de serviços de informação especializados em segurança da informação e segurança cibernética; recebimento de avisos e alertas de fornecedores de TIC a respeito dos produtos utilizados pela Organização.

Dicas de implementação:

- Evidências de participação da organização em fóruns de discussão especializados em segurança da informação e de segurança cibernética;
- Acesso a informações divulgadas por fornecedores e fabricantes de software e hardware utilizados pela Organização sobre novas ameaças ou novas vulnerabilidades;
- Acesso a atualizações de segurança de softwares e hardware liberadas para tratar novas ameaças conhecidas;
- Assinatura de serviços de notícias especializadas em segurança da informação.

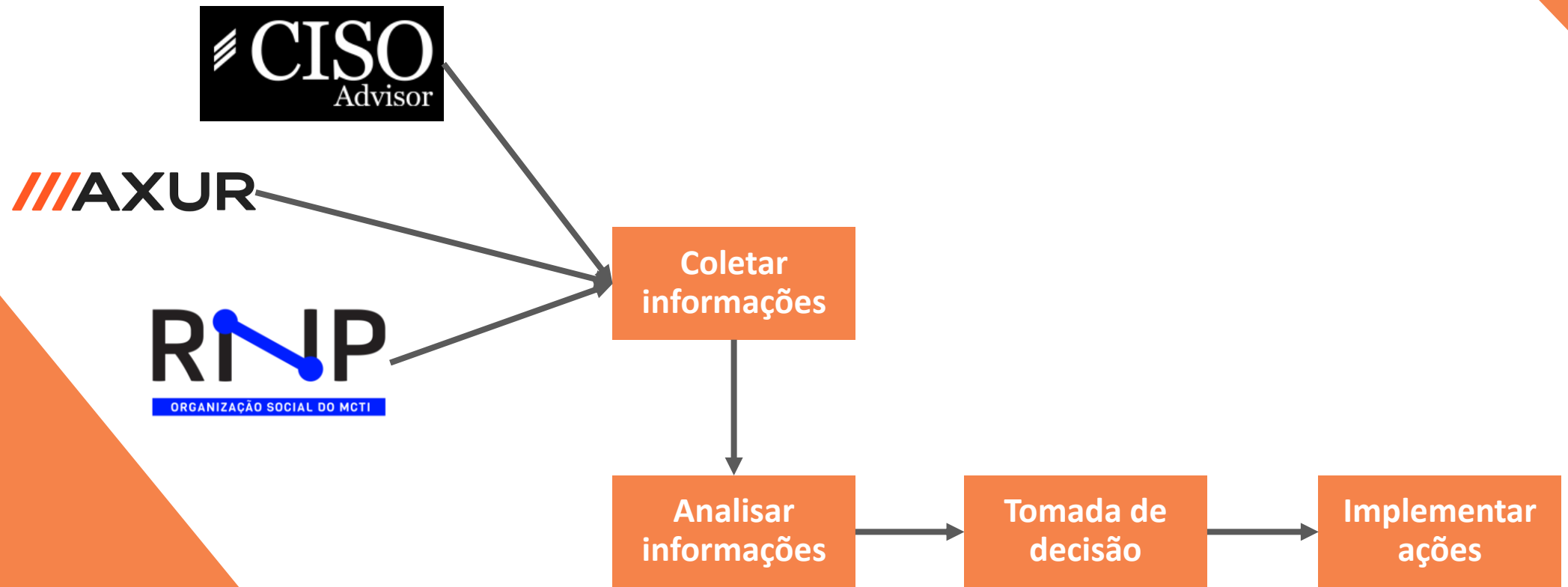
Controle (NOVO)

As informações relacionadas a ameaças à segurança da informação devem ser coletadas e analisadas para produzir inteligência sobre ameaças.

- É um controle preventivo;
- Pode ser implementado em níveis estratégico, tático e operacional;
- Profundidade da abordagem pode levar em conta riscos, recursos, porte e complexidade do ambiente da organização;
- Usar em conjunto com controle “A.5.6 Grupos especiais de interesse”;
- Criar um processo sistemático de coleta de informações sobre novas ameaças, avaliação, decisão e implementação de ações;
- Fontes de informação: fabricantes das soluções utilizadas pela organização; fóruns de discussão; sites de notícias especializadas em segurança; incidentes de segurança noticiados pela mídia; ferramentas automatizadas; times de pesquisa da própria organização.

Dicas de implementação:

- Registros, e-mails, banco de conhecimento e outras fontes de informação sobre tipos de ataques, metodologias utilizadas pelos atacantes, recomendações de ação emitidas por especialistas, entre outras;
- Planos de ação ou GMUDs implementadas para mitigação de ameaças identificadas;
- Revisão do processo de gestão de riscos, conforme aplicável, caso a ameaça seja nova e não abordada em riscos já mapeados pela Organização.



Controle

A segurança da informação deve ser integrada ao gerenciamento de projetos.

- É um controle preventivo;
- Assegurar que os riscos à segurança da informação são abordados no gerenciamento de projetos de qualquer natureza;
- Pode ser aplicado a projetos de processos de negócio, mudança de layouts físicos, construção de instalações e *facilities*, desenvolvimento de software, entre outros;
- Garantir que os riscos de segurança sejam abordados em estágios iniciais dos projetos e revisados ao longo do ciclo de vida;
- Toma a forma tipicamente em especificações de requisitos de segurança em projetos e abordagem a estes requisitos e riscos associados.

Dicas de implementação:

- Especificações de requisitos de segurança em termos de abertura de projetos;
- Análises críticas de riscos e ações tomadas ao longo da execução dos projetos;
- GMUDs abordando riscos de segurança da informação na fase de planejamento das mudanças;
- Termos de encerramento de projetos que demonstrem que os riscos à segurança foram tratados ao longo do ciclo de vida do projeto.

Controle

Um inventário de informações e outros ativos associados, incluindo proprietários, deve ser desenvolvido e mantido.

- É um controle preventivo;
- O inventário a que se refere o controle vai além de inventário de dispositivos e softwares instalados;
- Convém que inclua uma lista dos sistemas, bancos de dados, pastas de arquivos e arquivos considerados críticos para a Organização em termos de segurança da informação;
- Pode incluir determinados insumos e informações impressas, hardware e dispositivos de armazenamento e processamento de informações;
- Pode ser uma lista única ou um conjunto de inventários implementados em diferentes processos ou departamentos;
- Deve incluir o apontamento do proprietário do ativo;
- O nível de detalhamento dos inventários deve ser proporcional às necessidades da Organização.

Dicas de implementação:

- Inventários do ambiente tecnológico produzido e mantido através de ferramentas de inventário;
- Inventário de ativos em nuvem (lista de VM's, bancos de dados, instâncias em atividade, etc.);
- Inventário centralizado ou descentralizado;
- Processos usados pela Organização para manter os inventários atualizados;
- Processos utilizados pela organização para manter os ativos protegidos (controle de acesso, restrição de acesso às informações, entre outras).

Controle

As regras para o uso aceitável e os procedimentos para lidar com informações e outros ativos associados devem ser identificados, documentados e implementados.

- É um controle preventivo;
- Tipicamente implementado através de uma política de uso aceitável de ativos (documento específico ou parte do conteúdo de outros documentos);
- O uso aceitável inclui regras para acessar, processar, armazenar, transferir ou descartar informações e outros ativos e deve ser comunicada internamente e para partes interessadas que possam ter acesso às informações e ativos relevantes;
- A forma de comunicar pode incluir a divulgação da própria política de uso aceitável e/ou a inclusão de regras em termos de responsabilidade e acordos de confidencialidade e não divulgação;
- Inclui também as regras para uso de dispositivos de usuários, incluindo BYOD, se aplicável, bem como informações da organização armazenadas em serviços de nuvem.

Dicas de implementação:

- Existência de uma política aprovada e comunicada para uso aceitável de informações e outros ativos associados (como um documento específico, como parte de um documento mais amplo ou mesmo como um conjunto de documentos aplicados em diferentes contextos e circunstâncias, como NDA's, termos de responsabilidade por ativos, acordos de confidencialidade, entre outros);
- Conhecimento das pessoas a respeito do que pode e do que não pode ser feito com as informações e outros ativos associados (conscientização).

Controle

O pessoal e outras partes interessadas, conforme apropriado, devem devolver todos os ativos da organização em sua posse mediante mudança ou término de seu emprego, contrato ou acordo.

- É um controle preventivo;
- Ativos em uso ou em posse de pessoas ou entidades devem ser devolvidos de forma segura quando do término de contratos de trabalho ou de prestação de serviços;
- Esses ativos podem incluir dispositivos de *endpoint* de usuários, mídias de armazenamento removíveis, dispositivos físicos de autenticação, equipamentos especializados, entre outros;
- Informações ou conhecimento que sejam relevantes para as operações da organização devem ser transferidos de volta para a Organização;
- Convém que sejam tomadas medidas de salvaguarda para evitar que informações relevantes sejam copiadas antes da devolução dos ativos (proteção da propriedade intelectual).

Dicas de implementação:

- Termos de devolução de ativos assinados pelos usuários ou custodiantes dos ativos;
- Evidências físicas dos ativos devolvidos.

Controle

As informações devem ser classificadas de acordo com as necessidades de segurança da informação da organização, com base na confidencialidade, integridade, disponibilidade e requisitos relevantes das partes interessadas.

- É um controle preventivo;
- Seu objetivo é entender as necessidades de proteção das informações de acordo com a sua importância para a Organização e partes interessadas;
- Convém que uma política específica para este tópico seja estabelecida;
- Tipicamente encontramos três níveis de classificação das informações: pública, interna (acessível por todos na organização) e confidencial (acessível apenas por pessoas, grupos ou entidades autorizadas);
- Os proprietários das informações e/ou riscos normalmente definem o nível de classificação das informações.

Dicas de implementação:

- Existência, comunicação e uso de uma política ou procedimento sobre classificação da informação;
- Pode estar associado com os procedimentos usados no requisito 7.5 para controle da informação documentada do SGSI;
- Testar o conhecimento das pessoas sobre o entendimento dos diferentes graus de classificação/ sigilo e a quais informações cada um se aplica;
- Buscar evidências da classificação das informações;
- Normalmente é avaliado em conjunto com os controles associados ao “controle de acesso” e “restrição de acesso às informações”, “transferência de informações”, entre outros.

Controle

Um conjunto apropriado de procedimentos para rotulagem de informações deve ser desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização.

- É um controle preventivo;
- As informações classificadas pela Organização devem ser rotuladas, sempre que isso for técnica e economicamente viável;
- Os rótulos têm o objetivo de deixar claro para os usuários das informações o grau de sigilo que elas possuem;
- Formas de rotular as informações podem incluir:
 - rótulos físicos;
 - cabeçalhos e rodapés;
 - metadados;
 - marcas d'água;
 - carimbos
- Existem ferramentas de software que permitem aplicar rótulos também em arquivos e pastas em rede, bem como aplicações e bancos de dados (avaliar custo benefício)

Dicas de implementação:

- Aplicação da rotulagem em documentos impressos e arquivos eletrônicos;
- Existência de ferramentas de software que gerenciam rótulos em arquivos eletrônicos e pastas de rede;
- Existência do procedimento de rotulagem (normalmente parte integrante do procedimento de classificação das informações)
- Regras claras nos procedimentos sobre quando os rótulo NÃO PODEM ou NÃO DEVEM ser usados (por exemplo, em documentos públicos).

Controle

Regras, procedimentos ou acordos de transferência de informações devem estar em vigor para todos os tipos de meios de transferência dentro da organização e entre a organização e outras partes.

- É um controle preventivo;
- Proteger a segurança das informações transferidas tanto internamente quanto entre a organização e partes externas contra interceptação, acesso não autorizado, cópia, modificação, desvios de rota, destruição e negação de serviços;
- Assegurar a rastreabilidade e o não-repúdio das informações transferidas por qualquer meio;
- Meios de transferência de informação a ser considerados incluem: e-mail; FTP; aplicativos de mensageria; links de comunicação; aplicações de reuniões/ conferências; transferências de informação em mídias físicas; transmissão verbal; etc..

Dicas de implementação:

- Existência e uso de uma política ou procedimentos contendo as regras para transferência de informações, incluindo os tipos de informação que podem (ou não podem) ser transferidas e os meios que podem (ou não podem) ser usados para isso.

Controle

Regras para controlar o acesso físico e lógico às informações e outros ativos associados devem ser estabelecidas e implementadas com base em requisitos de negócio e da segurança da informação.

- É um controle preventivo;
- O objetivo deste controle é o de garantir o acesso autorizado e prevenir o acesso não autorizado a informações e outros ativos associados;
- Uma boa prática geral é utilizar o princípio do “*need-to-know*”, ou seja, conceder acesso apenas ao mínimo necessário que cada pessoa possa realizar o seu trabalho;
- Este controle inclui práticas atribuídas através de outros controles como: segregação de funções (A.5.3); controle de acesso privilegiado (A.8.2); controles de acesso físico (como por exemplo A.7.2; A.7.3; A.7.4), entre outros;
- Uma solução conceitualmente utilizada é o RBAC (*Role Based Access Control*);

Dicas de implementação:

- Buscar por regras, práticas e procedimentos de controle de acesso;
- Evidenciar juntos aos “donos” das informações as restrições de acesso que eles próprios aplicam às informações sob sua guarda;
- Buscar evidenciar se a organização utiliza os princípios do *need-to-know* ou do RBAC;
- Verificar quais são as regras para controle de acesso físico (por funcionários, visitantes, terceiros, etc..);
- Buscar evidenciar as regras para uso de direitos de acesso privilegiados e o uso de credenciais de “super-administradores”.

Controle

O ciclo de vida completo das identidades deve ser gerenciado.

- É um controle preventivo;
- “identidade” é o conceito de identificar unicamente uma entidade (pessoas, grupos ou entidades não-humanas);
- Identidades costumem ser únicas, inequívocas e imutáveis entre o momento de sua criação e exclusão;
- “Direitos de acesso” mudam; “identidades” não mudam;
- Exemplos de identidades: nomes de usuários; RG; CPF; Matrícula de funcionário;
- Minimizar o uso de identidades compartilhadas (por exemplo: usuário “marketing” que pode ser compartilhado por todas as pessoas do departamento de marketing);
- Devem ser eliminadas quando não mais necessárias.

Dicas de implementação:

- Evidenciar um processo e respectivas regras de gestão de identidades (criação; atribuição; monitoramento; exclusão);
- Quando uma identidade pode ser criada? Quando deve ser eliminada? avaliar regras;
- O ideal é uma identidade para cada pessoa ou entidade individual, porém às vezes podem ser necessárias algumas identidades de grupo; analisar pertinência;
- Identidades para entidades não-humanas podem ser necessárias em alguns casos; evidenciar e investigar;
- Verificar como as identidades são monitoradas e eliminadas quando não forem mais necessárias;

Controle

A alocação e o gerenciamento das informações de autenticação devem ser controlados por um processo de gestão, incluindo o aconselhamento do pessoal sobre o manuseio adequado das informações de autenticação.

- É um controle preventivo;
- Trata-se da criação e gerenciamento de senhas, números de identificação pessoal (PINs) e outras formas de autenticação de pessoas e entidades;
- O objetivo é garantir a autenticação apropriada e evitar falhas de autenticação;
- Senhas, mesmo que temporárias, devem ser únicas e individuais; preferencialmente os usuários devem ser requeridos a trocá-las no primeiro uso;
- Os meios de envio das senhas aos usuários devem garantir confidencialidade (envio por canais seguros);
- Senhas *default* predefinidas ou criadas por fornecedores devem ser modificadas imediatamente após a instalações de softwares ou sistemas;
- Os usuários devem ser conscientizadas sobre as boas práticas no uso de senhas;
- Não armazenar senhas em texto plano.

Dicas de implementação:

- Buscar pelo processo de geração e envio de senhas aos usuários;
- Buscar por evidências de que as senhas criadas são de conhecimento apenas do “dono” da senha, ou no máximo de conhecimento da pessoa que criou a senha (caso não seja criada por processos automatizados);
- Processos que forcem os usuários a alterar suas senhas iniciais quando do primeiro acesso a um sistema ou software;
- Testar o conhecimento dos usuários a respeito de boas práticas de proteção de senhas;
- Avaliar em conjunto com o controle A.8.5.

Controle

Os direitos de acesso a informações e outros ativos associados devem ser provisionados, revisados, modificados e removidos de acordo com a política específica para esse tópico da organização e as regras para controle de acesso.

- É um controle preventivo;
- Direitos de acesso limitam o acesso às informações e outros ativos conforme regras definidas pela Organização e são sempre vinculados a uma identidade;
- Podem ser individuais ou atribuídos a grupos;
- Deve existir uma política específica para este tópico;
- A política deve deixar claros as regras para: provisionar os acessos; revisar e/ou modificar os acessos; retirar (revogar, remover) os acessos;
- É implementado via segregação de funções, definição de perfis de acesso em sistemas e aplicações, criação de grupos de acesso a redes, pastas de arquivos e arquivos, acessos a locais físicos e outros;
- Este controle é implementado em conjunto com A.5.3, A.5.15 e A.8.2.

Dicas de implementação:

- Definições perfis de acesso a redes, pastas de arquivos, arquivos, sistemas e aplicações;
- Checar identidades X perfis de acesso;
- Buscar por um processo estruturado de concessão inicial de acessos;
- Checar direitos de acesso privilegiado (ver A.8.2);
- Buscar por um processo estruturado de revisão periódica dos direitos de acesso e de ajuste dos direitos de acesso no caso de mudanças nas funções dos colaboradores;
- Buscar por um processo estruturado de revogação de acessos.

Controle

Processos e procedimentos devem ser definidos e implementados para gerenciar os riscos de segurança da informação associados ao uso de produtos ou serviços de fornecedores.

- É um controle preventivo;
- Seu objetivo é manter um nível adequado de segurança no relacionamento com fornecedores;
- Uma política ou procedimento específico deve ser implementado;
- Fornecedores podem oferecer diferentes níveis de riscos à segurança da informação da organização;
- Importante identificar os diferentes tipos de fornecedores para atribuir um nível apropriado de riscos a cada um deles;
- Implementar o processo de seleção e avaliação considerando o que exigir de cada tipo de fornecedor considerando os riscos;
- Fornecedores que possuem acesso às informações e aos recursos de TI da Empresa devem ter atenção especial.

Dicas de implementação:

- Existência e uso de uma política/ procedimento de segurança da informação para fornecedores;
- Uso de critérios para seleção de fornecedores com base em segurança da informação (por exemplo: existência de certificações; questionários de segurança da informação; auditorias; etc.);
- Avaliar se o nível de exigência é apropriado ao tipo de fornecedor;
- Entre os tipos de fornecedores encontram-se: serviços de TIC, logística, infraestrutura de TIC, SaaS de qualquer natureza, processamento de folha de pagamentos, etc.;
- Avaliar em conjunto com A.5.20; A.5.21; A.5.22; A.5.23

Controle

Requisitos relevantes de segurança da informação devem ser estabelecidos e acordados com cada fornecedor com base no tipo de relacionamento com o fornecedor.

- É um controle preventivo;
- Atuando em conjunto com o controle anterior, visa assegurar que cada fornecedor será cobrado por suas responsabilidades específicas em relação à segurança da informação;
- Implementado através de procedimentos de seleção de fornecedores, da inclusão de cláusulas de segurança da informação, confidencialidade, privacidade e proteção da propriedade intelectual nos contrato e estabelecimento (ou aceite) de termos de serviços e SLAs mencionando segurança da informação e proteção de dados;
- Boa prática: NDAs assinados antes mesmo de existir obrigações entre as partes;
- Tipos de regras: acesso e compartilhamento de informações; cumprimento de requisitos legais de segurança e privacidade; controles a ser usados; etc..

Dicas de implementação:

- Existência e uso de políticas ou procedimentos para gestão da segurança da informação em fornecedores;
- Evidências de certificações de segurança (ISO, PCI, etc.). aplicável ao escopo dos produtos e serviços fornecidos;
- Existência de NDAs, contratos, termos de serviço e SLAs abordando requisitos de segurança da informação apropriados, aceitos entre a Organização e seus fornecedores.

Controle

Processos e procedimentos devem ser definidos e implementados para gerenciar os riscos de segurança da informação associados à cadeia de fornecimento de produtos e serviços de TIC.

- É um controle preventivo;
- Uma categoria especial de fornecedores é aquela relacionada à cadeia de TIC da Organização, por seu potencial impacto na segurança;
- Incluem-se nessa categoria: fornecedores de links de dados e voz; infraestrutura física de TIC; serviços em nuvem; sistemas e bancos de dados; aplicações de segurança (firewall, IDS, IPS, SIEM, soluções de backup, antivírus); sistemas operacionais; entre outros;
- Podem ser necessárias medidas de controle adicionais, como incluir tais fornecedores na cadeia de dependências para gestão da continuidade da segurança da informação/ continuidade de negócios
- Implementar em conjunto com os demais controles de gestão de fornecedores.

Dicas de implementação:

- Devem ser buscadas as mesmas evidências verificadas nos dois controles anteriores;
- Podem ser necessárias evidências adicionais, como a inclusão destes nas análises de riscos de continuidade.

Controle

A organização deve monitorar, revisar, avaliar e gerenciar regularmente as mudanças nas práticas de segurança da informação e entrega de serviços do fornecedor.

- É um controle preventivo;
- Além de selecionar fornecedores levando-se em consideração requisitos de segurança, deve-se avaliar regularmente suas práticas de segurança e sua entrega de serviços, em especial caso haja mudanças nos serviços do fornecedor ou no próprio fornecedor (por exemplo, quando há uma mudança de controlador do fornecedor);
- Costuma-se implementar através de avaliações de desempenho em segurança aplicadas a fornecedores selecionados, *reports* e monitoramento on line;
- Exemplo de questões a avaliar:
 - Segurança intrínseca do produto/ serviço;
 - Disponibilidade dos serviços;
 - Ocorrência de incidentes de segurança;
 - Atendimento às funcionalidades acordadas.

Dicas de implementação:

- Sistemas de avaliação de fornecedores;
- Resultados de avaliações de segurança da informação periódicas em fornecedores;
- Reuniões, troca e-mails e apresentações enviadas pelo fornecedor, conforme acordado;
- Monitoramento on line do status dos produtos e serviços do fornecedor;
- Demonstrações de conformidade do fornecedor (certificados) e de capacidades de continuidade.

Controle (NOVO)

Os processos de aquisição, uso, gerenciamento e saída de serviços em nuvem devem ser estabelecidos de acordo com os requisitos de segurança da informação da organização.

- É um controle preventivo;
- Pode ser implementado como parte integrante dos controles A.5.21 e A.5.22 (segurança e desempenho de fornecedores);
- Estabelecer requisitos mínimos de segurança a serem atendidos pelo provedor dos serviços em nuvem, incluindo certificações;
- Levar em consideração as responsabilidades compartilhadas entre o cliente e o provedor;
- Considerar as garantias informadas pelo provedor
- Recomendação: Criar uma política de segurança para o uso de serviços em nuvem;
- Normalmente a Organização não tem capacidade de impor seus requisitos; ela então seleciona um provedor que se encaixe de acordo.

Dicas de implementação:

- Buscar por regras especificamente desenhadas para provedores de serviços em nuvem;
- Buscar por uma política de segurança para o uso de serviços em nuvem;
- Buscar por certificações do provedor de serviços em nuvem, como ISOs 27001; 27701; 27017; 27018; 22301;
- Buscar as garantias declaradas pelo provedor de serviços em nuvem (contratos; termos de serviços; SLA's).

Controle

A organização deve planejar e se preparar para gerenciar incidentes de segurança da informação definindo, estabelecendo e comunicando processos, funções e responsabilidades para a gestão de incidentes de segurança da informação.

- É um controle corretivo;
- O objetivo deste controle é assegurar respostas rápidas, efetivas e consistentes a eventos e incidentes de segurança da informação;
- Uma política ou procedimento de gestão de incidentes deve ser estabelecido e deve abordar os seguintes itens:
 - Papéis e responsabilidades na gestão de incidentes;
 - Meios de detecção, análise e decisão sobre eventos de segurança da informação;
 - Meios de resposta e tratamento dos eventos de segurança que foram confirmados como incidentes de segurança da informação;
 - Comunicação interna e externa sobre incidentes de segurança da informação.

Dicas de implementação:

- Existência de políticas ou procedimentos para gestão de incidentes de segurança;
- Existência de atribuição de responsabilidade para pessoas e/ou equipes para lidar com eventos e incidentes de segurança em suas diferentes fases de tratamento;
- Existência de critérios para avaliar eventos de segurança física e lógica de diferentes origens;
- Existência de canais de comunicação internos para que os colaboradores possam reportar eventos de segurança (ver controle A.6.8);

Controle

A organização deve avaliar os eventos de segurança da informação e decidir se eles devem ser categorizados como incidentes de segurança da informação.

- É um controle detectivo;
- O objetivo deste controle é assegurar a efetiva categorização e priorização dos eventos de segurança da informação;
- Os procedimentos de gestão de incidentes devem incluir critérios para decidir quando um evento de segurança é, de fato, um incidente de segurança;
- Levar em consideração as ferramentas automatizada de monitoramento do ambiente e os logs produzidos por estas ferramentas;
- As fontes de informação incluem: monitoramento de firewall; antivírus; logs de acesso a sistemas e aplicações; consoles de administração de servidores, sistemas operacionais, serviços em nuvem; logs de IDS/ IPS, DLP e outros; monitoramento da “saúde” dos ambientes;

Dicas de implementação:

- Buscar por processos automatizados ou manuais de análise de eventos de segurança;
- Buscar pela aplicação de critérios de decisão sobre eventos de segurança (eventos que possam afetar a confidencialidade, integridade e disponibilidade das informações);
- Incluir critérios de decisão para incidentes de segurança física e lógica.

Controle

Os incidentes de segurança da informação devem ser respondidos de acordo com os procedimentos documentados.

- É um controle corretivo;
- Incidentes de segurança da informação confirmados devem ser respondidos de forma rápida e efetiva;
- Fases de resposta a incidentes incluem as ações iniciais de bloqueio dos efeitos do incidente e posterior análise de causas e tomada de ações para evitar a recorrência de incidentes similares;
- Incidentes podem se tornar crises – atentar para a ligação dos procedimentos de tratamento de incidentes com aqueles de continuidade de negócios/ continuidade de segurança da informação.

Dicas de implementação:

- Registros de tratamento dos incidentes (relatórios, chamados, GMUDS, registros de não conformidades e ações corretivas, etc.);
- Evidências de que os tratamentos seguiram os procedimentos documentados.

Controle

O conhecimento adquirido a partir dos incidentes de segurança da informação deve ser usado para fortalecer e melhorar os controles de segurança da informação.

- É um controle preventivo;
- Seu objetivo é reduzir a probabilidade de ocorrência e a potencial consequência de futuros incidentes (realimentação dos riscos de SI);
- Após o encerramento das atividades de resposta e tratamento dos incidentes de segurança, deve-se avaliar os incidentes levando em consideração sua recorrência ou gravidade, para determinar novos controles que reduzam as probabilidades e impactos de futuros incidentes;
- Na prática é a realimentação do processo de gestão de riscos via gestão de incidentes: um incidente ou é um risco preexistente que se manifestou, ou um risco que a Organização não tinha avaliado até então (e portanto passa a fazer parte do inventário de riscos).

Dicas de implementação:

- Relatórios “post-mortem” contendo as lições aprendidas com os incidentes e planos de ação complementares;
- Revisão do inventário de riscos para alteração de riscos existentes associados aos incidentes ocorridos; ou a inclusão de um novo risco associado ao incidente ocorrido.

Controle

A organização deve estabelecer e implementar procedimentos para a identificação, coleta, aquisição e preservação de evidências relacionadas a eventos de segurança da informação.

- É um controle corretivo;
- Seu propósito é o de assegurar a coleta e a preservação de evidências de incidentes de segurança que possam ser usadas para basear medidas disciplinares e ações legais;
- Os procedimentos devem prever que as evidências dos incidentes devem ser coletadas por pessoal independente de que causou o incidente, e que devem ser mantidas de forma segura;
- O acesso às evidências dos incidentes deve ser restrito;
- Evidências incluem: imagens de CFTV; telas de sistemas e aplicações; logs de acessos físicos e lógicos; alertas de sistemas de monitoramento.

Dicas de implementação:

- Verificar o que os procedimentos de gestão de incidentes determinam quanto à coleta e preservação de evidências;
- Verificar de forma amostral se de fatos as evidências de incidentes ocorridos estão sendo mantidas;
- Verificar os mecanismos para proteger as evidências contra alterações ou exclusões.

Controle

A organização deve planejar como manter a segurança da informação em um nível apropriado durante uma interrupção.

- É um controle preventivo e corretivo;
- Incidentes podem evoluir para crises que cheguem a causar uma interrupção nos negócios, afetando a capacidade de manutenção dos controles de segurança nessas situações;
- Os processos de gestão de continuidade de negócios devem incluir os requisitos para segurança da informação;
- Garantir o fluxo de informações ao mesmo tempo em que se preserva a confidencialidade, integridade e disponibilidade são elementos críticos durante crises;
- Devem ser desenvolvidos planos de continuidade capazes de manter ou restaurar as informações de negócio críticas seguindo uma interrupção ou falha
- Implementar em conjunto com A.5.30 e A.8.14.

Dicas de implementação:

- Buscar por planos de continuidade de segurança da informação ou continuidade de negócios contemplando os cenários de risco que se caracterizem como crises;
- Buscar por processos e planos de continuidade de negócios contemplando a segurança física e lógica das informações.

Controle

A prontidão de TIC deve ser planejada, implementada, mantida e testada com base nos objetivos de continuidade de negócios e nos requisitos de continuidade de TIC.

- É um controle corretivo
- Deve ser entendido em conjunto com o controle A.5.29 e A.8.14;
- Os requisitos de continuidade de ICT costumam ser uma saída do BIA – *Business Impact Analysis*;
- Convém estabelecer os RTO e RPO associados aos recursos de ICT que precisam ser recuperados prioritariamente durante uma interrupção;
- Pode ser um controle limitado à TI ou pode fazer parte do conjunto mais amplo de estratégias de continuidade de negócios;
- Cuidado com os conceitos de INCIDENTE x CRISE.

Dicas de implementação:

- Mesmas evidências requeridas em A.5.29 e mais o seguinte:
- Cronogramas de exercícios e testes de continuidade/prontidão de ICT;
- Redundâncias de instalações de processamento de dados (servidores, DC's, links de dados e voz, backup de informações) que possam ser acionadas em uma crise que comprometa os recursos primários.

Controle

Os requisitos legais, estatutários, regulatórios e contratuais relevantes para a segurança da informação e a abordagem da organização para atender a esses requisitos devem ser identificados, documentados e mantidos atualizados.

- É um controle preventivo;
- Visa identificar qualquer obrigação relacionada à segurança da informação que a Organização possua em relação às partes interessadas;
- Requisito legal: Leis e outros diplomas legais – por exemplo LGPD, Marco Civil da Internet, Lei da Propriedade Intelectual;
- Requisito regulatório: Norma de órgão regulador – BACEN, SUSEP, ANPD;
- Requisito contratual: estabelecidos por clientes ou grupos de clientes – PCI DSS (Visa & Master);
- Pode ser implementado no contexto do requisito 7.5.3 – Controle de informações documentadas de origem externa.

Dicas de implementação:

- Listas de requisitos legais, estatutários, regulatórios e contratuais monitorados pela Organização;
- Contratos com clientes não costumam estar nessas listas; a organização costuma lidar com cada contrato individualmente;
- Buscar por evidências que as exigências são cumpridas no contexto do sistema de gestão da segurança da informação.

Controle

A organização deve implementar procedimentos apropriados para proteger os direitos de propriedade intelectual.

- É um controle preventivo;
- Uma das principais preocupações de uma Organização deveria ser a preservação do seu “know-how” e a sua propriedade intelectual – é um dos pontos-chave da ISO/IEC 27001;
- Aborda também a necessidade de respeitar a propriedade intelectual de terceiros
- O tema deve ser tratado em um procedimento específico, ou incluído como parte de outras políticas e procedimentos;
- Abordar o tema em contratos de trabalho, contratos com clientes, termos de uso, NDA, etc.. para as soluções proprietárias da Organização;
- Respeitar os contratos e termos de uso de soluções proprietárias de terceiros.

Dicas de implementação:

- Existências de cláusulas de propriedade intelectual nos contratos de trabalho, contratos de prestação de serviços, contratos com clientes, NDAs, termos de uso, termos de serviço, contratos de licenciamento, etc..
- Buscar por evidências de que a Organização respeita a propriedade intelectual de terceiros (uso de software licenciado, uso de acordo com as licenças, termos de uso, SLAs, etc.)

Controle

Registros devem ser protegidos contra perda, destruição, falsificação, acesso não autorizado e liberação não autorizada.

- É um controle preventivo;
- Visa assegurar proteção adequada aos registros gerados pelo curso das atividades da organização, em qualquer meio;
- Pode ser implementado em conjunto com o requisito 7.5.3 da ISO/ IEC 27001;
- Por padrão, registros devem ser arquivados por tempo indeterminado, a não ser que requerido de outra forma por alguma legislação, regulamento ou exigência de alguma parte interessada (clientes, por exemplo);
- Assegurar que os registros sejam acessados apenas por pessoas autorizadas, e que não possam ser adulterados, falsificados ou destruídos;
- Este controle deve ser enxergado em conjunto com classificação da informação e restrição de acesso a informações.

Dicas de implementação:

- Existência de práticas de preservação de registros, restrição de acesso aos registros, classificação dos registros (públicos, internos, confidenciais);
- Avaliar em conjunto com o requisito 7.5.3 da ISO/ IEC 27001 e os controles A.5.12, A.5.13, A.5.14, A.8.3, A.8.4

Controle

A organização deve identificar e atender aos requisitos relativos à preservação da privacidade e proteção de PII de acordo com as leis e regulamentos aplicáveis e os requisitos contratuais.

- É um controle preventivo;
- Remete à necessidade de a Organização estar atenta às legislações de proteção de dados pessoais;
- No Brasil, trata-se de cumprir os requisitos da LGPD;
- Embora o controle não seja específico, cabe à Organização tomar as providências mais amplas para estar em conformidade com a Lei;
- A implementação é evidenciada através das providências internas para atendimento à LGPD e demais controles de segurança aplicáveis;
- Evidenciar, no mínimo: política corporativa de privacidade da informação; Designação do DPO e publicidade de sua identidade; Cláusulas de proteção de dados em acordos, contratos e termos de serviço;
- Entendimento complementado pela ISO/ IEC 27701.

Dicas de implementação:

- Existência e comunicação de uma política de proteção de dados pessoais;
- Cláusulas de proteção de dados pessoais nos contratos de trabalho, contratos com fornecedores e parceiros, contratos com clientes;
- Designação do DPO e publicidade de sua identidade;
- Não é necessária uma abordagem profunda e detalhada do atendimento à LGPD.

Controle

A abordagem da organização para gerenciar a segurança da informação e a sua implementação, incluindo pessoas, processos e tecnologias, deve ser analisada criticamente de forma independente em intervalos planejados ou quando ocorrerem mudanças significativas.

- É um controle preventivo e corretivo;
- O objetivo é assegurar a contínua pertinência, adequação e eficácia da abordagem da Organização em relação à Segurança da Informação;
- A implementação dos requisitos 9.2 e 9.3 da ISO/ IEC 27001 atende à intenção deste controle, que pode ser implementado em conjunto com o controle A.5.36;

Dicas de implementação:

- Buscar pelos processos de auditoria interna do SGSI e de Análise Crítica pela Direção, conforme requisitos 9.2 e 9.3 da ISO/ IEC 27001;
- Verificar se a auditoria interna está sendo realizada de forma independente (no mínimo os auditores internos não devem auditar o próprio trabalho);
- Verificar se a auditoria interna está sendo capaz de cobrir todos os elementos do SGSI;
- Verificar se as análises críticas pela Direção estão cobrindo os elementos exigidos em 9.3 e no controle.

ORGANIZACIONAL

A.5.36. Conformidade com políticas, regras e normas de segurança da informação

Controle

A conformidade com a política de segurança da informação, políticas de tópicos específicos, regras e normas deve ser analisada criticamente regularmente.

- É um controle preventivo;
- Também pode ser atendido via a implementação do requisito 9.2 da ISO/IEC 27001;
- Ver controle A.5.35.

Dicas de implementação:

- Buscar pelas mesmas evidências sugeridas para o controle A.5.35.

Controle

Procedimentos operacionais para instalações de processamento de informações devem ser documentados e disponibilizados ao pessoal que precisa deles.

- É um controle preventivo e corretivo;
- A implementação desse controle pode ser evidenciada através da disponibilidade de procedimentos operacionais que atendem a todos os controles do SGSI, as políticas corporativas e os procedimentos técnicos utilizados pela Organização;
- *Runbooks* e *playbook* detalhando questões operacionais também são aceitos como meios de implementação deste controle;
- Avaliar se, além do conjunto mínimo de procedimentos exigidos pela ISO/ IEC 27001, não há outros procedimentos operacionais que sejam necessários para a Organização demonstrar a operação eficaz do seu SGSI.

Dicas de implementação:

- Disponibilidade e uso de políticas e procedimentos que implementam os controles exigidos e aplicáveis à Organização, conforme a ISO/ IEC 27001;
- Buscar pelos procedimentos determinados pela própria organização como necessários para manter uma operação eficaz em relação à segurança da informação.

A.6

CONTROLES DE PESSOAS

Controle

Verificações de antecedentes de todos os candidatos a se tornarem funcionários devem ser realizadas antes de se ingressar na organização e de forma contínua, levando em consideração as leis, regulamentos e ética aplicáveis, e devem ser proporcionais aos requisitos de negócio, à classificação das informações a serem acessadas e aos riscos percebidos.

- É um controle preventivo;
- O objetivo é assegurar que as pessoas que venham a ser contratadas pela Organização atendam às necessidades do negócio e de proteção das informações;
- No mínimo a Organização deve confirmar se o histórico profissional e as informações do CV (currículo) são suficientes e verdadeiras;
- Fazer uso de fontes públicas de consulta (por exemplo, LinkedIn);
- Em alguns casos, pode ser necessário e justificada a consulta a antecedentes criminais (funções no sistema financeiro, trabalho com informações sigilosas, vigilância e transporte de valores – entendimento do TST).

Dicas de implementação:

- Verificar como funciona o processo de checagem de antecedentes dentro do processo de recrutamento e seleção da Organização;
- Buscar se existem funções para as quais a checagem de antecedentes criminais é necessária, e se a Organização está fazendo este processo;
- Verificar se ao menos o histórico profissional (CV e LinkedIn) é confirmado pela organização.

Controle

Os acordos contratuais de trabalho devem indicar as responsabilidades do pessoal e da organização para a segurança da informação.

- É um controle preventivo;
- O controle é necessário para assegurar que funcionários e terceiros compreendam e se comprometam em cumprir requisitos de segurança da informação da Organização;
- O tema costuma ser resolvido por uma ou mais das seguintes formas:
 - Cláusulas de confidencialidade e segurança da informação incluídas nos contratos de trabalho ou de prestação de serviços;
 - Termos avulsos de confidencialidade e de segurança da informação, quando não incluídos em contratos.
- As cláusulas devem indicar a responsabilidade das pessoas no cumprimento das regras, políticas e procedimentos de segurança da Organização.

Dicas de implementação:

- Buscar por cláusulas de confidencialidade, proteção da propriedade intelectual e segurança da informação em contratos de trabalho ou de prestação de serviços e as assinaturas/ aceites das pessoas;
- Buscar por termos avulsos sobre estes temas, quando não forem cobertos nos contratos.

Controle

O pessoal da organização e as partes interessadas relevantes devem receber conscientização, educação e treinamento em segurança da informação apropriados e atualizações regulares da política de segurança da informação, políticas de tópicos específicos e procedimentos da organização, conforme relevante para sua função.

- É um controle preventivo;
- O propósito deste controle é assegurar que funcionários, terceiros, parceiros e outras partes interessadas estejam conscientes de seus papéis com relação à segurança da informação, como contribuir pessoalmente para reduzir os riscos de segurança e proteger a si e à organização contra as ameaças conhecidas;
- Implementado via treinamentos de *on boarding* e um programa de educação contínua sobre segurança da informação;
- Temas abordados incluem conceitos de segurança, o que são riscos de segurança da informação e como se proteger das principais ameaças, especialmente os ataques de engenharia social;
- Trabalhar este controle em conjunto com os requisitos 7.2 e 7.3 da ISO/ IEC 27001.

Dicas de implementação:

- Existência de um programa estruturado para educação e treinamento em segurança da informação;
- Verificar como o tema é tratado nos processos de *on boarding*;
- Abordar as políticas da organização para uso aceitável da informação e outros ativos associados com informação;
- Verificar quais os treinamentos de segurança aplicados ao longo do tempo;
- Conversar com as pessoas de modo geral para testar o seu grau de conhecimento
- Buscar por outros meios de conscientização, como campanhas de *phishing*, treinamentos gamificados, etc..

Controle

Um processo disciplinar deve ser formalizado e comunicado para tomar medidas contra o pessoal e outras partes interessadas relevantes que cometeram uma violação da política de segurança da informação.

- É um controle preventivo e corretivo;
- As pessoas precisam estar conscientes das consequências potenciais de não cumprir com as regras da Segurança da Informação na Organização;
- Quando as pessoas cometem desvios ou não cumprem as regras, políticas e procedimentos de segurança da informação, estão sujeitas a processo disciplinar que, em último caso, pode resultar em demissão, além de outras possíveis consequências administrativas e jurídicas;
- No Brasil, um processo disciplinar genérico já é previsto na CLT: advertência verbal; advertência por escrito; suspensão; demissão.

Dicas de implementação:

- Buscar pelo processo disciplinar estabelecido pela Organização;
- Buscar por casos concretos onde tenha sido necessário aplicar o processo disciplinar (nem sempre a Organização terá esses casos concretos).

Controle

As responsabilidades e deveres de segurança da informação que permaneçam válidos após a rescisão ou mudança de emprego devem ser definidas, aplicadas e comunicadas ao pessoal relevante e outras partes interessadas.

- É um controle preventivo;
- Segurança da informação é uma obrigação que permanece válida mesmo após o encerramento ou mudança nos contratos de trabalho;
- As pessoas precisam estar conscientes de que as obrigações de sigilo, confidencialidade e de proteção da propriedade intelectual permanecem válidas mesmo após o término do contrato de trabalho;
- Este controle é implementado via adoção de cláusulas nos contratos de trabalho ou de prestação de serviços; pode ser abordado em termos específicos também;
- Implementado em conjunto com o controle A.6.2;

Dicas de implementação:

- Buscar as mesmas evidências de A.6.2, considerando que as cláusulas mencionem as obrigações pós-encerramento de contratos e acordos.

Controle

Acordos de confidencialidade ou não divulgação refletindo as necessidades da organização para a proteção de informações devem ser identificados, documentados, revisados regularmente e assinados pelo pessoal e outras partes interessadas relevantes.

- É um controle preventivo;
- O propósito deste controle é o de assegurar a confidencialidade das informações acessadas pelo pessoal ou partes interessadas externas;
- Funcionários, terceiros, clientes, potenciais clientes, fornecedores, potenciais fornecedores ou outras partes interessadas que possam acessar informações confidenciais devem assinar acordos de confidencialidade de não divulgação;
- Estes acordos devem deixar claras quais são as informações confidenciais que devem ser protegidas e quais são as responsabilidades de cada parte com relação à proteção dessas informações;
- Em situações específicas, devido ao grau de sensibilidade das informações, os acordos devem prever o monitoramento e a auditoria da outra parte envolvida no acordo.

Dicas de implementação:

- Para funcionários e terceiros, as evidências poderão estar em A.6.2 e A.6.5;
- Buscar por acordos assinados entre a Organização e seus clientes e fornecedores;
- Em alguns casos, um NDA será necessário mesmo antes de as partes terem um compromisso entre si (por exemplo, um potencial fornecedor de TIC pode ter que obter informações técnicas sigilosas para subsidiar a elaboração de uma proposta para a Organização).

Controle

Medidas de segurança devem ser implementadas quando o pessoal estiver trabalhando remotamente para proteger as informações acessadas, processadas ou armazenadas fora das instalações da organização.

- É um controle preventivo;
- O trabalho remoto ganhou muita relevância e a segurança da informação precisa ser garantida para quem trabalha fora da organização;
- Cuidados com a segurança devem ser previstos para dispositivos usados no trabalho remoto; para o ambiente físico de trabalho remoto; e para o comportamento das pessoas trabalhando remotamente;
- Controles podem incluir a limitação de horários de acesso, os softwares de segurança a ser instalados nos dispositivos de usuários, os softwares seguros para comunicação e acesso aos recursos de informação da Organização (VPN e firewalls), etc.;
- Cuidado especial deve ser tomado para o uso de espaços públicos (cafés, bares, aeroportos, shoppings, etc..)

Dicas de implementação:

- Existência e comunicação das regras para o trabalho remoto;
- Medidas de segurança tomadas sobre os dispositivos de endpoint de usuários, sejam eles corporativos ou BYOD;
- Medidas de segurança tomadas do lado da Organização, como utilização de firewalls e VPNs;
- Buscar pelas orientações dadas às pessoas sobre como devem configurar seus ambientes físicos de trabalho remoto e como se comportar pessoalmente;
- Entrevistar as pessoas que trabalham remotamente para testar seu nível de conhecimento e práticas de segurança no trabalho remoto.

Controle

A organização deve fornecer mecanismos para o pessoal relatar eventos de segurança da informação observados ou suspeitos em tempo hábil, por meio de canais apropriados.

- É um controle detectivo;
- Muitos incidentes de segurança podem ser detectados pelas pessoas, sem que uma ferramenta automatizada esteja envolvida;
- Exemplos de situações passíveis de reporte:
 - Erros humanos;
 - Comportamentos anômalos ou suspeitos de pessoas;
 - Brechas nas medidas de segurança física;
 - Testemunho de violações de cumprimento de regras, políticas e procedimentos SI;
 - Comportamentos anômalos de aplicações e sistemas.
- Disponibilizar canais seguros para que as pessoas possam realizar esses reporte ou denúncias;
- Pode ser implementado em conjunto com o requisito 7.4 da ISO/ IEC 27001.

Dicas de implementação:

- Buscar pela existência e uso dos canais de comunicação internos para reporte de eventos de segurança;
- Testar o conhecimento das pessoas sobre a existência desses canais de comunicação e as circunstâncias nas quais devem ser usados;
- Algumas aplicações de mercado voltadas para treinamento e conscientização em segurança possuem esta funcionalidade;
- Desconfiar da eficácia de canais que nunca tenham sido usados.

A.7

CONTROLES FÍSICOS

Controle

Perímetros de segurança devem ser definidos e utilizados para proteger áreas que contenham informações e outros ativos associados.

- É um controle preventivo;
- Visa assegurar a proteção do entorno e dos acessos de edifícios, instalações e recursos de TIC contra o acesso físico não autorizado (o “lado de fora”; os muros; os limites físicos das organizações);
- Muros, cercas, portões, telhados, caixas de passagem de cabeamento, portões de acesso, recepções de edifícios, guaritas, garagens, docas, entre outros, são objeto da implementação deste controle;
- Medidas de proteção física incluem: alarmes de perímetro, sensores de movimento e de calor, CFTV, alarmes de presença, alarmes de tempo de abertura de portas, vigilância armada, catracas de acesso, porteiros eletrônicos, portas de segurança, sistema de proteção contra incêndios, guaritas blindadas, etc..

Dicas de implementação:

- Verificar “no lado de fora” dos edifícios e instalações, quais as medidas de segurança de perímetro implementadas;
- Testar se os controles funcionam (registros de imagens, testes de alarmes, etc..);
- Verificar se as medidas implementadas são suficientes para as necessidades da Organização, considerando os riscos de acesso físico não autorizado.

Controle

Áreas seguras devem ser protegidas por controles de entrada e pontos de acesso apropriados.

- É um controle preventivo;
- O objetivo é que apenas pessoas autorizadas tenham acesso à organização e suas áreas consideradas seguras;
- Os objetos deste controle são os pontos de acesso físico, tais como: recepções de edifícios; recepções e portas secundárias; garagens; docas e áreas de recebimento/ expedição; acessos de serviço; etc..;
- Regras de restrição de entrada de objetos;
- Quanto maiores forem as Organizações, maiores serão as necessidades deste controle;
- Medidas incluem: cadastro de acesso em recepções; vigilância armada; porteiros; catracas de acesso com credenciais (crachás, acesso biométrico, etc..); CFTV; sistema de registro de acesso físico; separação de acessos físicos (funcionários, visitantes, etc..); restrição de entrada de objetos; revistas físicas; etc..

Dicas de implementação:

- Aplicação de medidas de segurança nos pontos de acesso físico;
- Buscar por: sistema de controle de acesso físico; cadastramento de visitantes em portarias e recepções; sistema de monitoramento por vídeo (CFTV); barreiras físicas de acesso; segregação de acessos (recepção de visitantes, entrada de funcionários, áreas de entrega e despacho de mercadorias, etc..);
- Buscar por regras de restrição de entrada de equipamentos (notebooks; pen drives; celulares; entre outros).

Controle

Segurança física para escritórios, salas e instalações deve ser projetada e implementada.

- É um controle preventivo;
- Além do acesso físico principal a edifícios e instalações, é comum as Organizações possuírem áreas de acesso restrito dentro da própria Empresa;
- Normalmente nem todos os funcionários têm acesso a todas as dependências da Organização;
- Exemplos de ambientes onde tipicamente há restrições adicionais de acessos físicos:
 - Recursos humanos;
 - Datacenters e CPDs;
 - Escritórios de engenharia e inovação;
 - Laboratórios de ensaio de novos produtos;
 - Salas técnicas/ Salas de máquinas;
 - Arquivos de documentos da Empresa.
- Medidas incluem: porteiro eletrônico; sistema de controle de acesso físico por crachás ou biometria; portarias internas com vigilantes, etc..

Dicas de implementação:

- Buscar por evidências de aplicação dos controles de acesso físico internos proporcionais aos requisitos de segurança da Organização;
- Áreas tipicamente envolvidas: segurança patrimonial; *facilities*/ manutenção; administração; entre outras.

Controle (NOVO)

As instalações devem ser continuamente monitoradas com relação ao acesso físico não autorizado.

- É um controle preventivo e detectivo;
- Considerar a “dose certa” para o remédio: as soluções podem ser das mais simples como um controle de registro de portaria e uma webcam até sistemas complexos de controle de acessos físicos que incluem: CFTV; Sistema de registro de acessos; sensores e alarmes; entre outros;
- Atribuir responsabilidades pelo monitoramento do acesso físico;
- Proteger os sistemas de monitoramento de acesso contra acessos não autorizados ou possibilidade de serem desarmados ou adulterados por quaisquer meios;
- Reter as informações de logs de acessos e imagens de câmeras por um período mínimo determinado pela Organização.

Dicas de implementação:

- Salas de monitoramento de segurança e pessoal dedicado a este monitoramento;
- Armazenamento de logs de acesso físico, imagens de CFTV, etc.;
- Restrição de acesso aos logs e demais recursos de registro de acessos físicos;
- Configurações de alertas para tentativas de acesso não autorizado;
- Configurações de alarmes para condições suspeitas de segurança física (por exemplo: uma porta de acesso controlado aberta por mais de um minuto).

Controle

Proteção contra ameaças físicas e ambientais, como desastres naturais e outras ameaças físicas intencionais ou não intencionais à infraestrutura, deve ser projetada e implementada.

- É um controle preventivo;
- Além das medidas contra o acesso físico não autorizado, medidas contra “forças da natureza” e ataques e distúrbios sociais devem ser previstas, conforme apropriado a cada Organização;
- Isso inclui:
 - Localização dos edifícios e instalações (em regiões mais seguras e menos sujeitas a sofrer com inundações, tempestades, terremotos);
 - Vigilância armada, portões e guaritas blindados;
 - Portas e vidros blindados e portas corta-fogo;
 - Salas seguras e botões de pânico;
 - Sistemas de prevenção, detecção e combate a incêndios.
- Essas medidas devem ser proporcionais aos riscos e necessidades de controle da Organização.

Dicas de implementação:

- Buscar por medidas de segurança física focadas na prevenção e combate a desastres naturais;
- Buscar por medidas de proteção contra tentativas de invasão e distúrbios sociais;
- Buscar por medidas de proteção contra atacantes físicos (ação de bandidos, distúrbios sociais, etc..)
- Essas medidas podem ou não ser necessárias, dependendo do tipo de organização, seu negócio, sua localização geográfica, etc..

Controle

Medidas de segurança para trabalhar em áreas seguras devem ser projetadas e implementadas.

- É um controle preventivo;
- Áreas seguras são aquelas em que, além do controle de acesso físico, devem ser implementadas medidas de organização do trabalho focadas em segurança;
- Exemplos de áreas seguras:
 - Cofres de instituições financeiras;
 - Ambientes de produção de cartões bancários;
 - Locais de manuseio de informações sigilosas;
 - Salas de atendimento em *call centers*.
- Medidas de segurança nessas áreas podem incluir:
 - Controle de acesso físico;
 - Restrição de porte de objetos como celulares, câmeras, notebooks, pen drives, etc..
 - Monitoramento de CFTV em tempo integral;
 - Proteção de visualização de telas;
 - Revistas físicas de pessoal;
 - Vidros jateados.

Dicas de implementação:

- Questionar a existência de áreas seguras na Organização;
- Buscar pela definição e aplicação de medidas adicionais de segurança para essas áreas;
- Além do acesso físico de pessoas, buscar pela restrição de acesso/ porte de objetos que possam representar riscos à segurança;
- Buscar pelos meios de monitoramento do trabalho em áreas seguras.

Controle

Regras de mesa limpa para papéis e mídias de armazenamento removível e regras de tela limpa para instalações de processamento de informações devem ser definidas e impostas adequadamente.

- É um controle preventivo;
- O seu propósito é reduzir os riscos associados à exposição de informações em qualquer meio, nos locais de trabalho;
- Informações confidenciais impressas não devem estar expostas desnecessariamente, especialmente fora dos horários de trabalho;
- Bloqueio automático de telas deve estar ativo nos dispositivos de *endpoint* de usuário e monitores;
- Tanto quanto possível, as conexões para mídias de armazenamento externas devem estar desabilitadas;
- Aplicar proteção física e lógica a dispositivos de *endpoint* de usuários para quando não estiverem em uso ou quando estiverem desatendidos;
- Aplicar regras de encerramento automático de sessões;
- Restringir visualização em salas seguras (NOC/ SOC).

Dicas de implementação:

- Uso de regras para o bloqueio automático de telas de dispositivos (por exemplo, política de grupo no AD);
- Criptografia de discos de dispositivos usuários;
- Uso de regras de bloqueio de portas USB e outras formas de conexão de mídias de armazenamento externa, conforme necessidades da Organização;
- Buscar por evidências físicas mesa limpa e exposição de documentos impressos;
- Limitação de visão de informações em telas de consulta;
- Evidenciar aplicação de regras para o desligamento automático de sessões de usuário;
- Entrevistas o pessoal sobre regras de mesa e tela limpa.

Controle

Equipamentos devem estar localizados de forma segura e protegida.

- É um controle preventivo;
- Este controle está associado principalmente às organizações que mantêm instalações relevantes de processamento de informações *on premises*;
- Trata-se de abordar a segurança em salas de CPD, datacenters, armários de equipamentos, instalação de desktops, equipamentos industriais e médicos com conexão IoT, etc..;
- Considerar a restrição de acesso físico, característica de construção das salas de equipamentos (salas-cofre, paredes resistentes a fogo, saídas de emergência, climatização, etc.);
- Considerar equipamentos alocados em linhas de produção, ambientes industriais, hospitais e clínicas, etc..

Dicas de implementação:

- Avaliar as condições de instalação dos equipamentos de infraestrutura de TIC, em especial: servidores, roteadores, *firewalls*, *switches*, *storages*, entre outros;
- Outros equipamentos em locais fixos também devem ser avaliados (*desktops* e computadores em linhas de produção industriais, equipamentos médicos conectados à rede local ou internet, por exemplo);
- Verificar as condições de proteção desses equipamentos (salas seguras e protegidas, climatização, etc.).

Controle

Ativos fora das instalações devem ser protegidos.

- É um controle preventivo;
- O objetivo é prevenir perda, dano, roubo ou comprometimento de ativos fora das instalações;
- Pode ser aplicado tanto para equipamentos de grande porte, quanto para dispositivos móveis e BYOD;
- Cuidados incluem: conscientização sobre o porte e a guarda física do equipamento; respeitar as regras de uso do fabricante; autorização de saída de equipamentos e mídias de armazenamento, conforme for apropriado; capacidade de monitoramento remoto e deleção remota das mídias de armazenamento; criptografia dos dispositivos de armazenamento;
- Considerar equipamentos instalados permanentemente fora da organização (antenas, caixas automáticos, tecnologia embarcada, etc.).

Dicas de implementação:

- Regras definidas e aplicadas sobre os dispositivos da Organização mantidos fora de maneira temporária ou permanente;
- Orientação aos usuários para proteção de dispositivos móveis (*notebooks*, celulares, *tablets*), tanto os da organização quanto BYOD usados para a Organização;
- Considerar qualquer equipamento que se encaixe no conceito de “computador” e “unidade de armazenamento de dados” (CPU e *Storages*);
- Exemplos de outros equipamentos: Antenas; Caixas automáticos; controladores semafóricos; drones; entre outros.

Controle

Mídias de armazenamento devem ser gerenciadas ao longo de seu ciclo de vida de aquisição, uso, transporte e descarte de acordo com o esquema de classificação da organização e os requisitos de manuseio.

- É um controle preventivo;
- Seu propósito é o assegurar que ocorra apenas a divulgação, modificação, remoção ou destruição de informações em mídias de forma autorizada;
- Cuidados com mídias removíveis: autorização de saída das mídias quando for necessário manter rastreabilidade; guarda em local seguro e de acesso restrito; criptografia se possível; cuidados com preservação (proteção contra calor e humidade excessivos) e backup quando necessário; cuidados no transporte físico (ver controle A.5.14);
- Descarte ou reutilização: deleção segura (*wiping*) ou formatação da mídia; destruição física quando não for mais reutilizada; uso de serviços especializados na coleta e destruição de mídias de armazenamento; manter registros de disposição ou reutilização seguros (ver A.7.14).

Dicas de implementação:

- Buscar pelas práticas de destruição segura de mídias (*wiping*, formatação, destruição física), de acordo com os requisitos definidos pela organização ou outras partes interessadas (por exemplo, PCI DSS);
- É comum a existência de uma “política para reutilização e descarte seguro de informações e mídias”;
- Buscar registros que permitam rastrear as mídias reutilizadas ou descartadas (reutilização pode se dar por doação a outras instituições – como escolas e bibliotecas – por exemplo);
- Dar preferência à destruição física da mídia, quando do descarte.

Controle

As instalações de processamento de informações devem ser protegidas contra falhas de energia e outras interrupções causadas por falhas em utilidades de suporte.

- É um controle preventivo e detectivo;
- Visa evitar falhas que levem a interrupção de operações ou perda de informações;
- Utilidades incluem: energia elétrica; telecomunicações; climatização e ventilação; água; entre outros; sistemas de prevenção e combate a incêndios;
- Assegurar a manutenção adequada das instalações e equipamentos que fornecem as utilidades (ver A.7.13) e a gestão da capacidade (ver A.8.6);
- Atentar para: fornecimento de primário de energia; geradores de emergência; *no-breaks*; sistemas de ar-condicionado;
- Atentar para a disponibilidade de redundâncias conforme apropriado (ver controle A.8.14)

Dicas de implementação:

- Processos para gerenciar e monitorar as utilidades de apoio;
- Disponibilidades de redundâncias apropriadas, em especial para energia e climatização;
- Atenção para as utilidades de proteção de ativos (sistemas de prevenção e combate a incêndios);
- Verificar se as utilidades disponíveis possuem capacidade suficiente de atender a demanda em situações normais e anormais de operação;
- Atentar para o planejamento da capacidade futura das utilidades de apoio em linha com os planos de expansão da Organização.

Controle

Os cabos que transportam energia, dados ou suportam serviços de informação devem ser protegidos contra interceptação, interferência ou danos.

- É um controle preventivo;
- Evitar que haja interrupção das operações, interferência ou roubo de informações;
- Cabos de energia, telecomunicações e dados que levam a instalações de processamento de informações devem possuir proteção física ou instalação que dificulte o acesso a eles; uso de piso elevado em instalações de processamento de dados;
- Instalação subterrânea destes cabos deve ser considerada; manter caixas de passagem trancadas; segregar os cabos de energia e telecomunicações; evitar qualquer tipo de exposição do cabeamento;
- Em sistemas sensíveis ou críticos, considerar outras medidas como uso de fibra ótica, uso de escudos eletromagnéticos, inspeção periódica das linha de cabeamento em busca de conexões não autorizadas de dispositivos; alarmes de presença, etc..

Dicas de implementação:

- Avaliar as condições de chegada dos diferentes tipos de cabeamento nos edifícios e instalações;
- Em redes internas, avaliar a identificação do cabeamento desde os pontos de conexão em equipamentos (roteadores, switches, firewalls) até os *endpoints*; verificar se conexões de endpoint não utilizadas estão desabilitadas;
- Verificar se existe cabeamento de energia, telecomunicações e dados exposto, especialmente nos arredores da Organização/ pontos de chegada;
- Verificar se o acesso ao cabeamento é restrito.

Controle

Os equipamentos devem ser mantidos corretamente para garantir a disponibilidade, integridade e confidencialidade das informações.

- É um controle preventivo;
- Equipamentos devem ser mantidos para evitar falhas de disponibilidade ou funcionamento;
- Implementar práticas de inspeção e manutenção preventiva conforme recomendações dos fabricantes;
- Em caso de existir apenas manutenção corretiva, assegurar que aconteçam em tempo hábil no caso de ocorrência de falha;
- Assegurar que o pessoal que executa a manutenção cumpra as políticas de segurança da informação da Organização, em especial segurança física;
- Garantir a segurança de equipamentos enviados para manutenção fora da Organização (ver A.7.9);
- Inspecionar equipamentos que receberam manutenção antes de coloca-los novamente em uso para assegurar que estejam funcionando.

Dicas de implementação:

- Existência e implementação de planos de manutenção preventiva;
- Execução de manutenções corretivas;
- Eventualmente as manutenções são substituídas pela troca rápida de equipamentos em redundância, com posterior recuperação do equipamento primário;
- Verificar como a Organização assegura que equipes de manutenção externa cumprem os requisitos de segurança e confidencialidade.

Controle

Itens do equipamentos contendo mídias de armazenamento devem ser verificados para garantir que quaisquer dados confidenciais e software licenciado tenham sido removidos ou sobrescritos com segurança antes do descarte ou reutilização

- É um controle preventivo;
- Os componentes de equipamentos que armazenam informações (HD's, SSD's e outras mídias de armazenamento) devem ser reutilizados ou descartados de forma segura;
- Reutilização de mídias: assegurar que informações previamente gravas tenham sido apagadas ou sobrescritas com segurança (*wiping*, formatação); Softwares licenciados devem ser sido desinstalados, quando não puderem ser usados pelo novo proprietário (as exceções costumam ser os sistemas operacionais, necessários ao funcionamento dos equipamentos);
- Descarte: dar preferência à destruição ou inutilização física das mídias de armazenamento.

Dicas de implementação:

- Existência e uso de procedimentos para a reutilização e o descarte seguros de mídias (ver controle A.7.10);
- Verificar se softwares previamente instalados foram desinstalados antes do descarte ou reutilização (exceção: sistemas operacionais, que normalmente podem ser reutilizados);
- Procurar por registros de doação, transferência e descarte de equipamentos ou mídias.

A.8

CONTROLES TECNOLÓGICOS

Controle

As informações armazenadas, processadas ou acessíveis por meio de dispositivos de *endpoint* do usuário devem ser protegidas.

- É um controle preventivo;
- Dispositivos de *endpoint* de usuários incluem: notebooks, celulares e tablets (da Organização ou BYOD);
- Abordar o tema na política de uso aceitável de ativos;
- Definir regras para o uso de dispositivos BYOD;
- Aplicar segurança física e lógica;
- Garantir o uso de antivírus;
- Aplicar criptografia aos dispositivos de armazenamento, se possível;
- Limitar a possibilidade de armazenar informações nas mídias locais de armazenamento;
- O atendimento a este controle pode ser verificado através de outros controles, por exemplo: A.6.3; A.7.9; A.7.7; A.7.10; A.8.7, A.8.12, entre outros.

Dicas de implementação:

- Verificar quais as políticas da Organização para o uso de dispositivos de *endpoint*;
- Verificar as regras definidas para o uso de BYOD e se são compatíveis com os riscos introduzidos pelo uso destes dispositivos;
- Identificar no inventário de ativos os dispositivos de *endpoint* de usuários e checar os controles de segurança aplicados a eles (restrição à instalação de softwares, criptografia de discos, antivírus, bloqueio de portas, etc.);
- Verificar como a organização tenta prevenir o vazamento de dados através dos dispositivos de *endpoint* (desde conscientização até monitoramento/ DLP, se aplicável).

Controle

A atribuição e uso de direitos de acesso privilegiado devem ser restritos e gerenciados.

- É um controle preventivo;
- São uma fonte de risco relevante para a Organização;
- Os direitos de acesso privilegiado podem existir para usuários, componentes de software e serviços;
- Garantir que exista um número mínimo de pessoas com direitos de acesso privilegiado, tanto físico como lógico;
- Sistemas e aplicações devem possuir um ou mais papéis definidos para “administradores”;
- Evitar o uso de contas-padrão e senhas-padrão, como as que são geradas durante instalações;
- “Superadministradores” devem ser ainda mais restritos, mas não ao ponto de que eles próprios se tornem um risco (ter no mínimo dois para cada sistema ou recurso relevante);
- Garantir a revisão periódica dos direitos de acesso privilegiado (ver A.5.18);

Dicas de implementação:

- Existência e uso da política de controle de acessos, que inclua a abordagem aos direitos de uso privilegiado;
- Buscar pela atribuição e controle dos direitos de acesso privilegiado;
- Avaliar se são utilizadas contas compartilhadas ou genéricas para acesso privilegiado;
- Incluir nessa verificação o acesso físico privilegiado (por exemplo, que pode acessar o DC da Organização);
- Verificar se a Organização limita a concessão de direitos de acesso privilegiados, mas não a ponto de criar dependência em relação a indivíduos;
- Verificar o processo de revisão periódicas de acessos.

Controle

O acesso às informações e outros ativos associados deve ser restrito de acordo com a política de tópico específico para controle de acessos.

- É um controle preventivo;
- Deve existir uma política específica para restrição de acesso a informações (ou como documento específico ou como parte do conteúdo de outro documento);
- As pessoas e entidades devem ter acesso apenas às informações mínimas necessárias para que realizem o seu trabalho;
- Mesmo dentro de setores, pode haver necessidade de restrição de acesso às informações;
- Trabalhar em conjunto com as políticas de controle de acesso e identidades (A.5.3; A.5.15; A.5.16; A.5.18; A.8.2);
- Considerar os princípios de “*need-to-know*” e RBAC (*role based access control*).

Dicas de implementação:

- Existência e comunicação da política de restrição de acesso a informações;
- Verificar medidas administrativas (*need-to-know* e RBAC) e tecnológicas (segmentação de redes, pastas);
- Buscar por: segregação de funções, restrição de acesso a redes, pastas de rede e arquivos;
- Buscar por segmentação de redes e *drives* de armazenamento compartilhado; políticas de acesso por grupos (comercial, marketing, produção, jurídico, TI, compras, SI, etc.);
- Buscar por restrições de acesso a informações impressas (salas de guarda de documentos, por exemplo).

Controle

O acesso de leitura e gravação ao código-fonte, ferramentas de desenvolvimento e bibliotecas de software deve ser gerenciado adequadamente.

- É um controle preventivo;
- Restringir o acesso ao código fonte para evitar acessos não autorizados e perda de integridade;
- Garantir a proteção da propriedade intelectual da Organização associada aos códigos fonte;
- O acesso à integralidade dos códigos fonte deve ser ainda mais restrito, mas não ao ponto em que isso se transforme em um risco por si só;
- Não armazenar códigos-fonte em repositórios de GIT públicos e centralizar em GITs privados/ fechados;
- Garantir que os desenvolvedores estejam cientes de suas responsabilidades sobre propriedade intelectual;
- Assegurar segregação de funções e controle de acesso conforme políticas específicas.

Dicas de implementação:

- Verificar se existe segregação de acesso ao código fonte por papéis (arquiteto, desenvolvedor, líder tech);
- Verificar as limitações de acesso de acordo com os perfis definidos;
- Verificar quem pode ter acesso integral ao código fonte e como isso é controlado;
- Verificar como os códigos fonte são armazenados e controlados, incluindo versionamento, para evitar perda de integridade.

Controle

Tecnologias e procedimentos de autenticação segura devem ser implementados com base nas restrições de acesso à informação e na política de tópico específico para controle de acesso.

- É um controle preventivo;
- A autenticação segura dificulta a ação de atacantes que desejam roubar identidades e senhas;
- São práticas adequadas:
 - Uso de senhas fortes, com período de validade definido e impossibilidade de reutilização;
 - Métodos de autenticação alternativos e complementares, como certificados digitais; *smart cards*; tokens físicos; verificação biométrica;
 - Tecnologias *zero trust* e *one-time login*;
 - Mascaramento das informações de login;
 - Não permitir mensagens de retorno em telas de login que possam fornecer pistas a atacantes;
 - Limitar o número de tentativas de login e bloqueio por tentativas malsucedidas;
 - Encerramento de sessões por inatividade.

Dicas de implementação:

- Buscar por regras de senhas fortes aplicadas a diferentes ambientes, sistemas e aplicações;
- Testar os procedimentos de login em conjunto com o auditor;
- Buscar pelas formas como as senhas são armazenadas nas aplicações e se está sendo evitado guardar senhas em texto plano;
- Buscar por regras de alteração de senhas, validade de senhas, bloqueio de login por tentativas mal sucedidas, encerramento de sessões após tempo de inatividade, uso de múltiplos fatores de interação, proteção contra tentativas de ataques de força bruta ou adivinhação.

Controle

O uso de recursos deve ser monitorado e ajustado de acordo com os requisitos de capacidade atuais e esperados.

- É um controle preventivo e detectivo;
- Evitar que o esgotamento da capacidade comprometa a disponibilidade e a integridade;
- Identificar e gerenciar as capacidades em termos de recursos de TIC, recursos humanos e outros;
- O monitoramento da “saúde” dos ambientes entra neste controle; itens de monitoramento incluem: capacidade de processamento, memória, espaço em disco, largura de banda, quantidade de requisições, entre outras;
- Configurar alertas de uso de recursos;
- Ações de gestão incluem: planejamento das expansões do negócio x capacidades de TIC; descarte de dados obsoletos; descomissionamento de sistemas, bancos de dados e ambientes; uso de computação em nuvem; otimização da alocação de recursos em horários de pico de processamento;

Dicas de implementação:

- Existência e uso de um Plano de Gestão da Capacidade;
- Existência e uso de recursos para monitoramento do ambiente de tecnologia, seja *on premises* ou em nuvem;
- Evidência de tomada de decisão e previsão de investimentos em pessoas, tecnologias e processos considerando os planos de expansão dos negócios;

Controle

A proteção contra malware deve ser implementada e suportada pela conscientização apropriada dos usuários.

- É um controle preventivo, detectivo e corretivo;
- A proteção contra malware deve ser baseada em software de detecção e correção, conscientização em SI, controle de acesso a sistemas e gestão de mudanças;
- Implementar controles para detecção de uso de software não autorizado (ver A.8.19 e A.8.32);
- Bloquear o acesso a sites maliciosos (ver A.8.23);
- Reduzir as vulnerabilidades que podem ser exploradas por malware (ver A.8.8 e A.8.19);
- Restringir a obtenção de arquivos ou programas de fontes externas ou quaisquer outros meios;
- Instalar e manter atualizados softwares antivírus;
- Controlar redes e isolar ambientes onde consequências catastróficas podem ocorrer (A.8,20);
- Conscientizar as pessoas sobre os riscos associados a malware e como preveni-los.

Dicas de implementação:

- Existência e uso de software antivírus protegendo os ativos e o acesso à informações internas e externas;
- Uso de aplicações para gestão de ativos tecnológicos para monitorar uso de software não autorizado;
- Avaliar este controle em conjunto com os controles de gerenciamento de vulnerabilidades, instalação de softwares e segurança de redes.

Controle

Informações sobre vulnerabilidades técnicas dos sistemas de informação em uso devem ser obtidas, a exposição da organização a tais vulnerabilidades deve ser avaliada e medidas apropriadas devem ser tomadas.

- É um controle preventivo;
- Vulnerabilidades técnicas podem se apresentar de diversas maneiras:
 - Em softwares de terceiros em uso pela Organização;
 - Em softwares desenvolvidos pela Organização;
 - Em ambientes de rede e de nuvem;
 - Na infraestrutura física da Organização.
- Controles incluem:
 - Atualização de softwares (*patching*);
 - Testes de penetração (*pentests*) em softwares, sites e ambientes de rede e de nuvem;
 - Testes de invasão física;
 - Ciclo de vida de desenvolvimento seguro (ver A.8.25 até A.8.29);
- Classificar, priorizar e tratar as vulnerabilidades identificadas em tempo hábil.

Dicas de implementação:

- Processo usado pela Organização para gerenciar a instalação e manutenção de softwares, em especial atualizações de segurança (*patching*);
- Existência e uso do processo de desenvolvimento seguro de software (avaliar em conjunto com A.8.25 a A.8.29);
- Uso de *pentesting* para avaliar aplicações, sites, redes e ambientes em nuvem da Organização;
- Verificar como a organização prioriza e trata as vulnerabilidades, assegurando que as críticas e altas seja resolvidas da forma mais rápida quanto for possível;
- Realização de testes de invasão física (onde isso for relevante para a Organização).

Controle (NOVO)

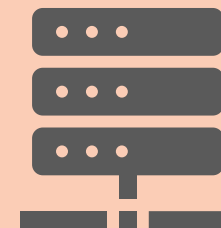
Configurações, incluindo configurações de segurança, de hardware, de software, de serviços e de redes devem ser estabelecidas, documentadas, implementadas, monitoradas e revisadas.

- É um controle preventivo;
- Origens no ITIL e ISO 20000-1;
- Abrange: hardware; software; serviços (por exemplo, computação em nuvem); redes – inclui configurações operacionais e de segurança;
- Relação direta com a gestão de ativos;
- Pode envolver mais de um departamento;
- Estabelecer um ou mais processos para gestão da configuração;
- Atribuir responsabilidades pela gestão da configuração;
- Criar uma linha de base dos itens de configuração existentes;
- Assegurar que novas configurações ou mudanças em configurações existentes sejam autorizadas por pessoal apropriado (GMUDs);

Dicas de implementação:

- Inventário de ativos e listagem de configurações de hardware e software dentro do inventário;
- Para software desenvolvido, identificar rastreabilidade de mudanças e controle de versões;
- Atentar para configurações de ambientes de rede, equipamentos e aplicações de segurança, dispositivos de *endpoint* de usuários, servidores e ambientes em nuvem;
- Verificar como as mudanças em configurações são gerenciadas para preservar rastreabilidade e prevenção a erros de configuração GMUDs).

Inventário de ativos



Controle (NOVO)

As informações armazenadas em sistemas de informação, dispositivos ou em qualquer outro meio de armazenamento devem ser excluídas quando não forem mais necessárias.

- É um controle preventivo;
- Parte das preocupações surgidas com as leis de proteção de dados;
- O conceito de “quando não forem mais necessárias” deve ser interpretado com cuidado;
- Cada organização pode ter um critério diferente;
- Departamentos ou área dentro da organização podem ter critérios diferentes;
- Além de proteção das informações, este controle auxilia na gestão da capacidade (espaços de armazenamento);
- Possuir um plano de descarte baseado em períodos de retenção de informações e registros;
- Higienizar periodicamente as bases de dados existentes, incluindo logs, imagens e vídeos de segurança, etc..

Dicas de implementação:

- Buscar pelas regras definidas pela Organização para o descarte de informações;
- Cruzar informações com eventuais exigências legais de preservação ou descarte de (CLT, LGPD, requisitos de clientes e de outras partes interessadas);
- Determinados tipos de negócios são mais sensíveis a este controle (por exemplo, um call center gravando todos os atendimentos prestados);
- Buscar por *scripts* de deleção automática de arquivos, arquivos temporários, imagens, vídeos, etc..
- Atentar para o descarte seguro das informações.

Controle (NOVO)

O mascaramento de dados deve ser usado de acordo com a política de tópico específico da organização para controle de acesso e outras políticas de tópicos específicos relacionadas e requisitos de negócios, levando em consideração a legislação aplicável.

- É um controle preventivo;
- Também tem origem nas legislações de proteção de dados pessoais;
- Evitar a exposição desnecessária de informações durante o seu ciclo de vida;
- O objetivo é “esconder” a informação verdadeira;
- Técnicas podem incluir: anonimização; encriptação; anulação de caracteres;
- Criação de modos de exibição seguros, “for your eyes Only”;
- Encriptação de dados em repouso ou em transmissão (ver A.8.24);
- Requer no mínimo uma política específica, como parte do conteúdo da política de controle de acessos.

Dicas de implementação:

- Mascaramento de caracteres em telas de login;
- Em telas de consulta em sistemas internos e de suporte a clientes, buscar pelo mascaramento de dados sensíveis (por exemplo, números de cartões de crédito, números de contas bancárias, senhas do cliente, CPF, nome completo, entre outros);
- Buscar por técnicas de encriptação de dados em repouso ou em transmissão (uso de SFTP, VPNs, etc..);
- No desenvolvimento de sistemas, considerar esta prática como um dos itens para desenvolvimento seguro e *privacy by design*.

Controle (NOVO)

Medidas de prevenção contra vazamento de dados devem ser aplicadas a sistemas, redes e quaisquer outros dispositivos que processem, armazenem ou transmitam informações confidenciais.

- É um controle preventivo e detectivo;
- O objetivo é proteger as informações que possuem valor para a Organização;
- Informações confidenciais da Organização, tais como modelos de precificação, projetos de produtos, fórmulas químicas, informações pessoais, bancos de dados contendo cadastros e o histórico de vendas e de relacionamento com clientes são exemplos de informações que valem ouro;
- Possui ligação com outros controles, como aqueles associados à criptografia e restrição de acesso a informações;
- Restringir a capacidade de usuários de copiar informações, enviar informações da empresa para seu e-mail pessoal e para e-mails externos suspeitos
- Técnicas e ferramentas incluem, mas não se limitam, a: antivírus; IDS/ IPS, *web filters*, *firewalls*, DLP.

Dicas de implementação:

- Em conjunto com outros controles (restrição de acesso a informações, proteção contra malware, conscientização em SI, mídias de armazenamento, etc..), verificar medidas que possam reduzir as chances de que informações saiam da empresa de forma não autorizada;
- Isso inclui regras para o pessoal se manifestar sobre assuntos da Organização em redes sociais;
- Ferramentas de DLP (*Data Loss Prevention*) são recomendadas nos casos em que a Organização possui ativos de informação sensíveis para ela (segredos industriais, projetos de produtos, cadastros contendo dados pessoais, de crédito e financeiros, etc..).

Controle

Cópias de *backup* de informações, software e sistemas devem ser mantidas e testadas regularmente de acordo com uma política de tópico específico para backup acordada.

- É um controle preventivo;
- Permite a recuperação de informações ou sistemas perdidos por qualquer razão;
- Uma política específica para o tema deve ser estabelecida e implementada;
- Todas as informações essenciais ou crítica para os negócios devem ser cobertas pelos *backups*;
- Ambientes de *backup* devem ser segregados física e logicamente de outros ambientes;
- As cópias de *backup* devem ser mantidas em locais físicos distintos dos locais físicos principais;
- O acesso aos *backups* deve ser restrito e protegido;
- Testar periodicamente os *backups* (testes de recuperação/ *restore*);
- Monitorar os *jobs* de *backup*;
- Manter *logs* dos *backups* e testes realizados.

Dicas de implementação:

- Existência e uso de uma política de *backup* e *restore*;
- Buscar pelo *backup* regular e bem sucedido das informações e sistemas críticos para a Organização;
- A frequência de *backup* deve ser suficiente para que perdas de dados sejam minimizadas, de acordo com os requisitos operacionais da organização (se as operações ocorrem na casa de milhares de transações por hora, por exemplo, um *backup* diário pode ser insuficiente face aos riscos enfrentados);
- Buscar por um programa regular de testes de *restore*, para que em um situação de incidente exista confiança de que a recuperação ocorrerá sem maiores problemas.

Controle

Instalações de processamento de informações devem ser implementadas com redundância suficiente para atender aos requisitos de disponibilidade.

- É um controle preventivo;
- As redundâncias devem ser suficientes para que a Organização não prejudique a disponibilidade das informações/ sistemas;
- Em um banco, por exemplo, as redundâncias devem espelhar o ambiente primário em tempo real; Já em uma empresa de advocacia, pode não ser necessário manter um ambiente secundário espelhado em tempo real (depende da dinâmica do negócio);
- Sites de *disaster recovery* não são mandatórios;
- As redundâncias podem ser implementadas na forma de componentes de reposição ou ter todos os recursos duplicados; podem ser do tipo *hot site* (espelhamento em tempo real com acionamento imediato) ou *cold site* (ativação a partir de recuperação de cópias de *backup* em tempo pré-acordado) – ver com A.5.29, A.5.30 e A.8.13.

Dicas de implementação:

- Buscar pelas redundâncias implementadas pela Organização: nos próprios equipamentos (por exemplo, máquinas com dupla fonte de energia); em ambientes inteiros (por exemplo, espelhamento de máquinas físicas e virtuais), em *facilities* (por exemplo, disponibilidade de geradores de energia de emergência para lidar com interrupções de fornecimento prolongadas);
- Buscar por evidências que demonstrem que as redundâncias existentes garantem a manutenção da disponibilidade de informações e sistemas de acordo com as exigências do negócio e das partes interessadas (cumprimento dos SLA de disponibilidade).

Controle

Logs para registro de atividades, exceções, falhas e outros eventos relevantes devem ser produzidos, armazenados, protegidos e analisados.

- É um controle detectivo;
- Visa manter as evidências que possam ser usadas para investigar eventos, incidentes e monitorar as atividades nos ambientes da Organização;
- Abrangência: acessos autorizados e tentativas de acesso não-autorizado a sistemas, dados e outros recursos; alertas de atividades maliciosas, tentativas de intrusão e intrusão; uso de privilégios; mudanças em configurações de sistemas e *hardware*; arquivos acessados e o tipo de acesso, incluindo a deleção de informações importantes; criação, modificação e exclusão de identidades e direitos de acesso; transações executadas pelos usuários nas aplicações;
- *Logs* devem ter acesso restrito e devem ser protegidos contra perda, adulteração e exclusão;
- *Logs* devem ser analisados (manualmente ou de forma automatizada) para tomada de ações.

Dicas de implementação:

- Existência de *logs* dos mais variados dentro da Organização;
- Existência e uso de um processo analisar os *logs* – pode ser a análise por exceções ou alertas gerados pelos sistemas de monitoramento de atividades;
- A análise manual de *logs* pode ser evidenciada, mas é muito difícil de ser implementada – gerenciar pelos alertas é o caminho mais comum;
- Verificar como a Organização guarda e protege os *logs*, e como recupera estas informações em caso de necessidade (conduzir uma investigação sobre um incidente de SI, por exemplo).

Controle (NOVO)

Redes, sistemas e aplicativos devem ser monitorados quanto a comportamentos anômalos e ações apropriadas devem ser tomadas para avaliar potenciais incidentes de segurança da informação

- É um controle detectivo e corretivo;
- Busca por ameaças externas e internas;
- Inclui as proteções contra ameaças externas aos ativos (em especial redes e ambientes em nuvem), uso de sistemas por parte de usuários internos e externos, monitoramento do tráfego de informações, *logs* de atividades;
- Aqui interessam os *logs* produzidos pelas ferramentas de antivírus; IDS/ IPS, web filters, firewalls, DLP, SIEM;
- Trabalha em conjunto com os controles A.5.24, A.5.25, A.5.26 e A.8.15;
- Monitoramento da “saúde” dos ambientes de tecnologia, especialmente comportamento do consumo de recursos (CPU, memória, discos, largura de banda, etc..).

Dicas de implementação:

- Buscar pelo uso de soluções de monitoramento dos ambientes: SIEM, DLP, IDS/ IPS;
- Algumas aplicações populares: Wazuh; Zabbix; Grafana; Sophos; Splunk; Kaspersky; ArcSight; Qradar; Nessus; entre outras;
- Verificar a atribuição de responsabilidades pelo monitoramento de ambientes e critérios para tomada de decisão sobre eventos detectados;
- Buscar pela automação de análises básicas do ambiente e *thresholds* para acionamento de ações de resposta a incidentes.

Controle

Os relógios dos sistemas de processamento de informações usados pela organização devem ser sincronizados com fontes de tempo aprovadas.

- É um controle detectivo;
- Visa assegurar que diferentes sistemas, aplicações e hardware estejam com relógios sincronizados entre si, gerando confiança nos *logs* e atividades de monitoramento;
- Exemplo: relógios dos sistemas de controle de acesso físico devem estar sincronizados com os relógios do sistema de CFTV, para permitir o cruzamento das informações de acesso com as de monitoramento por imagem;
- Solução comum é apontar os relógios para um mesmo servidor NTP.

Dicas de implementação:

- Cruzar informações de registros de horários de *logs* entre diferentes sistemas e aplicações para confirmar o sincronismo de relógios;
- Confirmar quais são as fontes de tempo utilizadas pela Organização para sincronizar relógios.

Controle

O uso de programas utilitários que sejam capazes de sobrepor os controles de sistemas e aplicações deve ser restrito e rigidamente controlado.

- É um controle preventivo;
- Muitos sistemas de informação possuem um ou mais programas utilitários que tem a capacidade de sobrepor a controles existentes, por exemplo programas de diagnóstico, consoles de administração de antivírus, ferramentas de rede, ferramentas de acesso remoto a computadores, etc..;
- Para estes casos, o uso desses programas deve ser limitado a poucos usuários autorizados (por exemplo, equipes de suporte);
- Usuários autorizados de programas privilegiados devem ter acesso via credencial específica para uso destas características e essas credenciais não devem ser compartilhadas;
- Implementar este controle em conjunto com o A.8.2.

Dicas de implementação:

- Buscar sobre como são controlados os usos de funções privilegiadas de sistemas operacionais e aplicações;
- Verificar os registros (*logs*) de utilização de aplicativos utilitários privilegiados (por exemplo: acesso remoto à área de trabalho; agentes de inventário de ativos; consoles de administração de antivírus; funções de atualização de softwares em sistemas operacionais; etc..)
- Verificar as restrições para que usuários comuns não sejam capazes de alterar ou *bypassar* controles de segurança.

Controle

Procedimentos e medidas devem ser implementados para gerenciar com segurança a instalação de software em sistemas operacionais.

- É um controle preventivo;
- Seu propósito é o de assegurar a integridade de sistemas operacionais e prevenir a exploração de vulnerabilidades técnicas;
- Atualização de sistemas operacionais deve ser feita por pessoal capacitado;
- Garantir que apenas códigos executáveis aprovados sejam executados;
- Apenas instalar e atualizar softwares que tenham sido testados (garantidos pelo fornecedor ou por testes internos);
- Definir planos de *rollback* antes de as mudanças serem implementadas;
- Manter controle das configurações/ versões instaladas.

Dicas de implementação:

- Buscar por regras aplicadas para a atualização de softwares;
- Verificar quem são os times/ pessoas responsáveis pela instalação/ atualização de softwares;
- Verificar como os softwares são validados/ testados antes de serem instalados;
- Verificar como são escolhidas as janelas de tempo para instalação, visando causar o mínimo possível de interferência nos ambientes de produção;
- Verificar como são estabelecidos planos de *rollback* para os casos em que uma instalação/ atualização for mal sucedida.

Controle

Redes e dispositivos de rede devem ser protegidos, gerenciados e controlados para proteger as informações em sistemas e aplicações.

- É um controle preventivo e detectivo;
- O objetivo é o de proteger as informações que trafegam e são armazenadas em redes, incluindo *wifi*;
- Assegurar processos seguros de autenticação em redes, incluindo as redes;
- Proteger e filtrar as conexões de entrada e de saída das redes (por exemplo, através do uso de *firewalls*);
- Detectar, restringir e autenticar a conexão de equipamentos e dispositivos nas redes;
- Evitar o uso de protocolos de rede vulneráveis;
- Segregar os canais de administração das redes dos demais canais;
- Realizar o *hardening* de dispositivos de rede;
- Manter atualizados os mapas de topologia das redes;
- Monitorar os dispositivos e o tráfego nas redes.

Dicas de implementação:

- Buscar pelos mapas de topologia da rede atualizados;
- Verificar as responsabilidades por configurar e manter os equipamentos de rede (*firewall*, roteadores, *switches*, bridges, etc..);
- Verificar quais os protocolos de comunicação utilizados nas redes, buscando por protocolos seguros (https, SSH, FTPS);
- Buscar pelos acessos protegidos de administradores das redes;
- Verificar se as portas desnecessárias ou não utilizadas de dispositivos de rede estão desabilitadas (incluindo portas de switches conectadas a *endpoints* não utilizados).

Controle

Mecanismos de segurança, níveis de serviço e requisitos de serviços de rede devem ser identificados, implementados e monitorados.

- É um controle preventivo;
- Enquanto o controle anterior se ocupa da segurança dos dispositivos de rede e o acesso autenticado às redes, esse olha para os controles de segurança no acesso aos serviços de rede disponíveis para os usuários autenticados;
- Serviços de rede incluem: serviços de rede privada; serviços de segurança gerenciada de redes como *firewalls*, *IDS* e *IPS*;
- Este controle complementa o anterior; basicamente ao se atender o controle anterior, atende-se a este controle.

Dicas de implementação:

- Buscar pelas mesmas evidências descritas no controle anterior, focando nos acessos aos diferentes serviços que uma rede pode oferecer, como acessar um servidor de arquivos, um servidor de impressão ou meios de conexão (como VPN e *wifi*).

Controle

Grupos de serviços de informação, usuários e sistemas de informação devem ser segregados nas redes da organização.

- É um controle preventivo;
- Considerar a segmentação quando as redes forem muito grandes ou quando sistemas e informações mais sensíveis necessitarem de uma camada adicional de segurança;
- A segmentação dificulta com que um ataque se espalhe rapidamente na rede;
- Implementar domínios de rede apartados e isolados da rede pública (internet);
- Se o acesso entre as redes for permitido, controlar o perímetro através de *firewalls* ou filtragem por roteadores;
- Redes *wifi* para convidados devem ser segregadas das redes *wifi* usadas pelo pessoal da Organização e seu uso deve ser limitado ao mínimo necessário, com controles rígidos de acesso e tempo de sessão.

Dicas de implementação:

- Buscar pelas segregações na Organização, que geralmente ocorrem da seguinte maneira:
 - Em uma mesma rede: criação de grupos de acesso pastas de rede por grupos (por exemplo: comercial; marketing; RH; Operações);
 - Em redes diferentes: buscar por redes dedicadas a grupos ou serviços críticos (por exemplo, rede do time de desenvolvimento; rede para as linhas de produção; redes para os laboratórios; etc.);
 - Buscar pela segregação das redes *wifi*: quais redes existam, quem pode acessá-las e o que pode ser acessado através delas.

Controle (NOVO)

O acesso a sites externos deve ser gerenciado para reduzir a exposição a conteúdo malicioso.

- É um controle preventivo;
- Implementar como parte das políticas aplicadas aos usuários;
- White lists e black lists de acesso a sites externos;
- Limitar o acesso a sites que não sejam necessários para o exercício das atividades profissionais ou pessoais essenciais (como por exemplo o acesso a internet banking);
- Evitar liberar o acesso a sites de e-commerce de produtos pessoais.

Dicas de implementação:

- Buscar pelas regras definidas para bloqueio de acesso a sites com conteúdo malicioso, incluindo aqueles identificados no processo de inteligência contra ameaças (ver A.5.7);
- Testar o entendimento dos usuários sobre as regras de acesso à internet e sites externos;
- Buscar pelo bloqueio de conteúdo ilícito (drogas, racismo, pornografia, violência, pirataria, etc.);
- Buscar pelo bloqueio de conteúdo que possa ferir as políticas de uso aceitável dos ativos (correntes, *download* de músicas e vídeo, etc.. – a não ser que sejam permitidos para propósitos válidos de negócios).

Controle

As regras para o uso efetivo da criptografia, incluindo o gerenciamento de chaves criptográficas, devem ser definidas e implementadas.

- É um controle preventivo;
- Seu propósito é o de proteger a confidencialidade, integridade e disponibilidade das informações de acordo com os requisitos legais e de negócios;
- Identificar as necessidades de uso de controles criptográficos em diversos cenários de negócio;
- Considerar a criptografia de informações mantidas em dispositivos móveis, mídias de armazenamento ou transmitidas em redes e canais externos;
- Definir abordagem para gestão de chaves criptográficas, incluindo métodos para gerar e proteger as chaves e como recuperar as informações no caso de as chaves serem perdidas, comprometidas ou danificadas;
- A gestão de chaves inclui as atividades de gerar, armazenar, arquivar, recuperar, distribuir, remover e destruir as chaves criptográficas.

Dicas de implementação:

- Buscar pelas regras definidas pela Organização para o uso de controles criptográficos – é comum existir uma política específica sobre o tema (exigida na versão 2013 da ISO/ IEC 27001);
- Regras podem ser impostas por partes interessadas (clientes ou órgão reguladores, por exemplo);
- Buscar por evidências de implementação dos controles criptográficos nas mais diversas situações – para proteção de comunicações, proteção de dados em repouso, etc..

Controle

Regras para o desenvolvimento seguro de software e sistemas devem ser estabelecidas e aplicadas.

- É um controle preventivo;
- Garantir o desenvolvimento de sistemas seguros;
- Pontos a ser considerados ao desenhar as regras para o desenvolvimento seguro:
 - Política ou procedimento específico;
 - Especificação de requisitos de segurança nos projetos (ver A.5.8 e A.8.26);
 - Metodologias e técnicas para o desenvolvimento seguro (ver A.8.27 e A.8.28);
 - Testes de segurança e de funcionamento (ver A.8.29);
 - Uso de repositórios seguros para o código fonte e configuração de sistemas (ver A.8.4 e A.8.9);
 - Competências do time de desenvolvimento;
 - Uso de desenvolvimento terceirizado (A.8.30);
 - Separação dos ambientes de desenvolvimento, testes e produção (ver A.8.31).

Dicas de implementação:

- Avaliar este controle em conjunto com os demais de A.8.26 a A.8.32);
- Avaliar os softwares desenvolvidos que fazem parte do escopo do sistema de gestão;
- Requisitos de segurança da informação devem ser pensados desde fases iniciais do projeto (especificação de requisitos/ definição de arquitetura da solução);
- Fases de verificação de código fonte e testes devem contemplar: revisão manual ou automatizada de código; testes de funcionalidades e de segurança;
- Avaliar a capacitação em desenvolvimento seguro aplicada aos times (próprios ou terceirizados).

Controle

Requisitos de segurança da informação devem ser identificados, especificados e aprovados quando do desenvolvimento ou aquisição de aplicativos.

- É um controle preventivo;
- Controle possui ligação com o A.8.4 (segurança da informação no gerenciamento de projetos);
- Requisitos relevantes de SI em aplicações incluem:
 - Autenticação segura;
 - Segregação de funções no acesso a dados e funcionalidades da aplicação;
 - Resiliência contra ataques maliciosos ou falhas não intencionais (por exemplo, *buffer overflow*, *SQL injections*);
 - Validação de dados de entrada;
 - Mascaramento de dados;
 - Proteção e privacidade de dados;
 - Proteção dos dados enquanto são processados, em trânsito ou em repouso;
 - Validação e proteção de transações.

Dicas de implementação:

- Verificar como a Organização identifica os requisitos de segurança das aplicações, desde as fases iniciais de um projeto de desenvolvimento ou de aquisição de software;
- Verificar como os requisitos de segurança identificados são levados adiante e validados nas diversas fases de um projeto de desenvolvimento software, até sua liberação para produção;
- Para software adquiridos, verificar como a Organização garante que a aplicação atende aos seus requisitos de segurança (por exemplo, realizando POCs).

Controle

Princípios para engenharia de sistemas seguros devem ser estabelecidos, documentados, mantidos e aplicados a quaisquer atividades de desenvolvimento de sistemas de informação.

- É um controle preventivo;
- Toma a forma de uma política ou procedimento (ver A.8.25);
- Este controle deve considerar a análise de:
 - Controles de segurança necessários para proteger sistemas contra ameaças identificadas;
 - Capacidades para prevenir, detectar ou responder a eventos de segurança;
 - Requisitos para encriptação de informações sensíveis, verificação de integridade e assinaturas digitais;
 - Infraestrutura técnica de segurança (por exemplo, infraestrutura de chave pública – PKI, gestão de identidades e acessos – IAM, prevenção contra vazamento de dados, gestão dinâmica de acessos;
 - Uso de princípios de *zero trust*.

Dicas de implementação:

- Existência e uso de uma política/ procedimento para o desenvolvimento seguro;
- Aplicação destes princípios aos sistemas em desenvolvimento na Organização;
- Atenção especial à arquitetura de proteção de processos de autenticação; armazenamento de informações de autenticação; armazenamento de dados em trânsito e repouso; proteção das transações realizadas nas aplicações; interfaces com APIs externas; gestão das identidades e acessos às aplicações; capacidade da aplicação de aceitar conexões e usuários simultâneos.

Controle (NOVO)

Princípios de codificação segura devem ser aplicados ao desenvolvimento de software.

- É um controle preventivo;
- Faz parte do conjunto de controles que abordam o tema “desenvolvimento de software seguro”;
- Aqui vale a pena incorporar a iniciativa da OWASP;
- Capacitar os desenvolvedores no tema;
- Uso de linguagens de programação consideradas seguras e eficientes;
- Configurações de segurança para os ambientes de desenvolvimento (como o uso de IDEs – *integrated Development environments*);
- Proibição do uso de técnicas de codificação inseguras (por exemplo, o uso de *hard-coded passwords*, amostras de códigos não aprovadas, *web services* não autenticados).
- Amadurecer o processo de codificação, evitando “idas e vindas” quando do momento de realização dos testes de segurança (QA).

Dicas de implementação:

- Buscar pelo uso das recomendações do projeto OWASP e *Owasp Top Ten Vulnerabilities*;
- Buscar por evidências de treinamento dos times de desenvolvimento em princípios e técnicas de codificação segura;
- Considerar princípios aplicáveis a diferentes tipos de ambiente: softwares instaláveis em infra estrutura interna (privada); softwares para ambiente web; software para dispositivos móveis;
- Atentar para o uso seguro de repositórios de código, IDEs e controle da documentação e versionamento do código-fonte.

Controle

Processos de testes de segurança devem ser definidos e implementados no ciclo de vida de desenvolvimento.

- É um controle preventivo;
- Visa validar se os requisitos de SI foram atendidos antes de aplicações ou códigos serem liberados no ambiente de produção;
- Estabelecer planos de testes conforme apropriado;
- Os testes devem cobrir:
 - Funções de segurança (autenticação de usuários, restrições de acesso, criptografia);
 - Codificação segura;
 - Configurações de segurança, incluindo sistemas operacionais, *firewalls* e outros componentes de segurança do software;
 - Revisões de código;
 - Testes unitários e integrados;
 - *Scan* de vulnerabilidades e *pentesting* (ver A.8.8).

Dicas de implementação:

- Buscar por planos de teste estabelecidos para cada novo desenvolvimento, atualização ou correção de erros (*bugs*);
- Buscar pela realização de revisões de código antes da realização dos testes;
- Softwares não devem ser liberados antes que tenham cumprido de forma bem sucedida as etapas de testes requeridas;
- Verificar como são realizados os *scans* de vulnerabilidades e testes de penetração nas aplicações em desenvolvimento e em produção.

Controle

A organização deve dirigir, monitorar e analisar criticamente as atividades relacionadas ao desenvolvimento terceirizado de sistemas.

- É um controle preventivo e detectivo;
- Exigir de desenvolvedores terceirizados no mínimo o mesmo nível de segurança aplicado na Organização;
- Acordar com os terceiros:
 - Requisitos para o desenvolvimento, codificação e testes de segurança (ver A.8.25 a A.8.29);
 - Fornecimento de evidências de que níveis mínimos de aceitação para segurança e privacidade são estabelecidos;
 - Fornecimento de evidência de que foram aplicados testes de segurança suficientes para proteger contra a presença de conteúdo malicioso e vulnerabilidades conhecidas;
 - Requisitos de segurança para o ambiente de desenvolvimento;
 - Atividades de monitoramento e auditoria dos processos de desenvolvimento terceirizado.

Dicas de implementação:

- Contratos estabelecidos entre a Organização e seus parceiros de desenvolvimento;
- Registros de capacitação dos terceiros nos processos de desenvolvimento seguro da Organização;
- Testar o conhecimento das equipes terceirizadas a respeito das práticas de desenvolvimento seguro;
- Verificar como o código desenvolvido por terceiros é testado e aprovado nos mesmos níveis exigidos pela Organização.

Controle

Os ambientes de desenvolvimento, testes e produção devem ser separados e protegidos.

- É um controle preventivo;
- Seu objetivo é garantir que os ambientes de produção não sofram interferência ou sejam comprometidos pelas atividades de desenvolvimento e testes;
- Garantir que estes ambientes operem em diferentes domínios (ambientes físicos ou virtuais);
- Definir as regras de transição dos softwares do desenvolvimento para testes (homologação), e de testes (homologação) para produção;
- Não realizar testes em ambientes de produção;
- Nomear os ambientes com rótulos adequados visando minimizar a chance de erros;
- Não manter cópias de dados reais de produção nos ambientes de desenvolvimento e testes (usar preferencialmente dados fictícios).

Dicas de implementação:

- Configurações válidas dos ambientes de desenvolvimento, testes e produção;
- Evidenciar que exista segregação de funções nos ambientes (quem desenvolve não testa; quem testa e aprova não implementa em produção);
- Verificar como a Organização assegura que apenas códigos aprovados são implementados;
- Sempre que possível, uma única pessoa não deve ter liberdade para desenvolver, testar e colocar um software em produção;
- Os processos para liberação do software em produção devem ser rigidamente controlados (ver A.8.32).

Controle

As mudanças nas instalações de processamento de informações e nos sistemas de informação devem estar sujeitas a procedimentos de gestão de mudanças.

- É um controle preventivo;
- Este controle é aplicado para gerenciar mudanças em: infraestrutura física; sistemas desenvolvidos internamente; sistemas adquiridos externamente;
- Estabelecer um procedimento para gestão de mudanças (GMUD);
- Planos de gestão de mudanças devem incluir:
 - Avaliação dos impactos da mudança considerando todas as suas dependências;
 - Autorização das mudanças;
 - Comunicação com partes interessadas relevantes;
 - Tarefas para realização da mudança;
 - Procedimentos de *roll back*;
 - Atualização dos procedimentos operacionais e de continuidade/ recuperação de desastres, se necessário.

Dicas de implementação:

- Existência e uso do procedimento para gestão de mudanças (como um documento específico ou como parte do conteúdo de outro documento);
- Buscar por registros de GMUDs realizadas, nas diversas modalidades que possam ocorrer na Organização.

Controle

As informações de teste devem ser adequadamente selecionadas, protegidas e gerenciadas.

- É um controle preventivo;
- Dados para teste são importantes para garantir a acuracidade e confiabilidade dos resultados dos testes de segurança das aplicações;
- Caso sejam copiadas informações dos ambientes operacionais para os ambientes de teste, isto deve ser feito de forma segura e controlada;
- Informações de teste devem ser protegidas contra o acesso ou modificação não-autorizados;
- Deletar as informações de testes após a conclusão dos testes;
- Preferencialmente, usar dados de teste fictícios; há vários “geradores de dados” confiáveis disponíveis no mercado.

Dicas de implementação:

- Buscar de que forma a organização seleciona e aplica os dados de teste nas aplicações que pretende testar (próprias ou de terceiros);
- Verificar como os dados de teste são segregados e mantidos de forma segura;
- Verificar como os dados de testes são apagados após o seu uso.

Controle

Testes de auditoria e outras atividades de garantia envolvendo avaliação de sistemas operacionais devem ser planejados e acordados entre o testador e a gerência apropriada.

- É um controle preventivo;
- Testes de auditoria realizados em sistemas operacionais, aplicações e ambientes podem interferir no desempenho;
- Os testes de auditoria devem ser limitados a operações de somente leitura; se o acesso somente leitura não estiver disponível, o teste deve ser executado por um administrador experiente do sistema, que terá os direitos de acesso necessários em nome do auditor;
- Se o auditor tiver acesso direto ao ambiente, garantir segurança de autenticação e do dispositivo usado para o acesso;
- Realizar a auditoria em momentos de pouca exigência de disponibilidade dos ambientes.

Dicas de implementação:

- Buscar por situações em que a Organização faça testes de auditoria em sistemas (por exemplo, *pentestings*);
- Verificar como a organização acorda com o testador as melhores práticas para realizar os testes, incluindo horários, largura de banda necessária, dispositivos a serem usados nos testes, etc..;
- Verificar quais foram os acordos estabelecidos com o testador para preservação das evidências dos testes.

